

Daily Vulnerability Report - 2026-10-01

Window (UTC): 2026-09-30T06:35 to 2026-10-01T06:35 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-10-01 06:36:53 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
866	741	125	0	1	68	349	274	159	383

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76504	New	9.8	CRIT	Yes		cisco:catalyst_sd-wan_manager	A vulnerability in the API session-based authentication management of Cisco Catalyst SD-WAN Manager could allow an unauthenticated, remote attacker to access an affected system with privileges of the admin user. This vulnerability is due to improper handling of URI encoding in an HTTP request, which allows the request to bypass an authentication rule that is intended to r...
CVE-2026-102427	New	10.0	CRIT				Joomla Extension - ordasoft.com - Unauthenticated Remote Code Execution in OrdaSoft Joomla CCK < 8.3.16 - site/uploader.php is reached through the component's normal frontend routing (task=getContent), a task with no authentication or ACL check anywhere in the dispatch chain. The handler validates the uploaded file's content with a real magic-byte MIME check, but the extensi...
CVE-2026-55107	New	10.0	CRIT				Kobako is a Ruby gem that embeds a Wasm-isolated mruby interpreter inside applications, allowing execution of untrusted Ruby scripts (LLM-generated code, user formulas, student submissions, third-party plugins) in-process without giving them access to host memory, files, network, or credentials. From version 0.1.0 to before version 0.9.1, a guest mruby script running inside ...
CVE-2026-76570	New	10.0	CRIT				Joomla Extension - joomcode.com - Unauthenticated SQL injection in read and write queries in JCTables 1.21.1 - The front-end CRUD API controller performs no Joomla token validation and no authentication check on any task. Table names, column names, and values are taken directly from request parameters and concatenated into SQL queries, allowing SQLi for reading and writing ...
CVE-2026-96349	New	10.0	CRIT				Unauthenticated Remote Code Execution (RCE) in SiteSkite <= 2.1.8 versions.
CVE-2026-100512	New	9.8	CRIT				Contributor PHP Object Injection in Nested Pages <= 3.3.2 versions.
CVE-2026-102115	New	9.8	CRIT				Kiteworks Core did not correctly validate a parameter submitted to the password reset workflow. An unauthenticated attacker who knew the email address of a user with a locally stored password could potentially reset that account's password without access to the emailed reset link and then authenticate as that user, including where the account holds administrative privileges.
CVE-2026-18782	New	9.8	CRIT				Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Trex Digital Smart Manufacturing Systems Inc. Trex MES allows Command Line Execution through SQL Injection. This issue affects Trex MES: through 2026-09-29.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55494	New	9.8	CRIT				Tugtainer is a self-hosted app for automating updates of Docker containers. Prior to version 1.30.4, Tugtainer Agent allows unauthenticated access to Docker management APIs when AGENT_SECRET is not configured. The Agent uses request signatures to protect its API routes. However, in agent/auth.py, the signature verification function returns successfully if Config.AGENT_SECRET...
CVE-2026-82307	New	9.8	CRIT				Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Dolusoft Software Technologies SOPLOG allows SQL Injection. This issue affects SOPLOG: before Soplog 2026.9.4.1.
CVE-2026-88920	New	9.8	CRIT				An authentication bypass in the DOM security processor in Apache WSS4J allows unauthenticated remote attackers to forge authenticated SOAP messages via a crafted unsigned SAML sender-vouches assertion containing an attacker-controlled key. Users are recommended to upgrade to versions 4.0.2 or 3.0.6 or 2.4.4, which fix this issue.
CVE-2026-96350	New	9.8	CRIT				Subscriber Privilege Escalation in Estatik <= 4.3.5 versions.
CVE-2026-97248	New	9.8	CRIT				Unauthenticated PHP Object Injection in Booking Activities <= 1.18.7.1 versions.
CVE-2026-97274	New	9.8	CRIT				Unauthenticated Bypass Vulnerability in OAuth Single Sign On – SSO (OAuth Client) <= 7.1.2 versions.
CVE-2026-102149	New	9.4	CRIT				Kiteworks Email Protection Gateway did not sufficiently restrict which account a certificate could be assigned to. This could allow an attacker to associate a certificate with another user's account, affecting the confidentiality and integrity of that account's encrypted mail and, where certificate-based login is enabled, potentially permitting unauthorized access to the acc...
CVE-2026-102489	New	9.4	CRIT				Zammad versions 6.3.0 to 6.5.4 are vulnerable a session hijack vulnerability that leads to remote code execution as the zammad user. The vulnerability is also present in version 7.0.0 to version 7.1.3, but not exploitable due to environment conditions.
CVE-2026-102490	New	9.4	CRIT				All versions of Zammad including the latest alpha enable the local zammad user to escalate privileges to root.
CVE-2026-14157	New	9.4	CRIT				Use of an Externally Controlled Format String in the ASUS Router modules allow a remote authenticated user to execute arbitrary commands via a crafted file uploaded through the web management interface.
CVE-2026-55181	New	9.4	CRIT				Tugtainer is a self-hosted app for automating updates of Docker containers. Prior to version 1.30.3, Tugtainer's OIDC authentication can still be initiated even when OIDC_ENABLED=false. The /auth/oidc/enabled endpoint correctly reports that OIDC is disabled. However, a direct request to /auth/oidc/login still starts the OIDC login flow, returns HTTP 302, sets an oidc_state c...
CVE-2026-93903	New	9.4	CRIT				LiteSpeed Web Server (LSWS) before 6.3.7 build 1 mishandles internal redirect URL validation in a certain "corner case."
CVE-2026-102147	New	9.3	CRIT				A stored cross-site scripting (XSS) weakness in Kiteworks Core could allow an unauthenticated attacker to store crafted content that later executes arbitrary JavaScript in the authenticated session of an administrator who views the affected page. This could have permitted the attacker to gain full administrative control, including the creation of a new administrative account.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102455	New	9.3	CRIT				EasyFlow .NET developed by Digiwin has a Insecure Deserialization vulnerability. Unauthenticated remote attackers can execute arbitrary code on the server by sending maliciously crafted serialized content.
CVE-2026-102458	New	9.3	CRIT				EasyFlow .NET developed by Digiwin has a Missing Authentication vulnerability. Unauthenticated remote attackers can obtain other users' plaintext passwords through a specific API.
CVE-2026-103395	New	9.3	CRIT				LightLLM through 1.2.0 visual_only deployments expose an unauthenticated RPyC service with allow_pickle enabled that deserializes attacker-supplied arguments in the remote_infer_images method. Attackers can reach the visual RPyC port and pass objects with __reduce__ methods to execute arbitrary code with service account privileges.
CVE-2026-103470	New	9.3	CRIT				In Internet2 Grouper before 7.5.1 (in some configurations), a user who is allowed to create or edit rules in the User Interface can escalate privileges.
CVE-2026-103475	New	9.3	CRIT				yii2-starter-kit through 4.2.0 exposes the Yii debug and Gii modules to all IP addresses by setting allowedIPs to [*] in its default development configuration. Unauthenticated remote attackers can access the debug endpoint to read sensitive data including session cookies and database queries, or access the Gii endpoint to generate and write PHP files into the application d...
CVE-2026-74864	New	9.3	CRIT				sogo_yhn configures SOGo with a parameter that forces the request with HTTP header "x-webobjects-remote-user" to be treated as sent by a verified user without performing password validation. Since Nginx does not strip this header, any client can supply it arbitrarily and gain access as any user, including a privileged user, without providing a password. This issue was fi...
CVE-2026-76142	New	9.3	CRIT				Insufficient authentication and access control on the internal-only IPC SOAP endpoint of the Genian NAC/ZTNA policy server allows an unauthenticated attacker to invoke internal functions
CVE-2026-82824	New	9.3	CRIT				Hitachi Coding Software Suite contains a vulnerability related to Path Traversal vulnerability that allows an attacker to access, create, modify, or delete files. This issue affects Hitachi Coding Software Suite: through 3.3.0.
CVE-2026-82825	New	9.3	CRIT				Hitachi Coding Software Suite contains a vulnerability related to Missing Authentication for Critical Function. This allows an unauthenticated attacker to invoke a critical API, potentially leading to unauthorized retrieval or alteration of sensitive information, or unauthorized manipulation. This issue affects Hitachi Coding Software Suite: through 3.3.0.
CVE-2026-82827	New	9.3	CRIT				Hitachi Coding Software Suite contains a vulnerability related to Use of Hard-coded Cryptographic Key. The Hardcoding of JWT signing secret key allows an attacker to generate unauthorized Bearer tokens and exploit administrative functions. This issue affects Hitachi Coding Software Suite: through 3.3.0.
CVE-2026-82829	New	9.3	CRIT				Hitachi Coding Software Suite contains a vulnerability related to Hidden Functionality vulnerability which allows an attacker to gain unauthorized access by exploiting hidden accounts or hard coded credentials. This issue affects Hitachi Coding Software Suite: through 3.3.0.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96822	New	9.3	CRIT				Unauthenticated SQL Injection in Books Gallery <= 4.8.3 versions.
CVE-2026-101276	New	9.2	CRIT				iperf3 3.21 (esnet/iperf) contains a remote, unauthenticated heap use-after-free: the server's per-test watchdog server_timer_proc() frees streams without cancelling/joining their worker threads, so a blocked worker dereferences a freed iperf_stream; fixed in 3.22.
CVE-2026-101283	New	9.2	CRIT				iperf3 3.20–3.21 (esnet/iperf) has a pre-auth heap buffer overflow in decrypt_rsa_message(): a 256-byte RSA buffer is BIO_read with the attacker-controlled ciphertext length (guard warns only), so an unauthenticated client overflows the heap via an oversized authtoken; fixed in 3.22
CVE-2026-102508	New	9.2	CRIT				Improper Verification of Cryptographic Signature and Improper Certificate Validation in the OPC UA driver of Apache PLC4X (PLC4J) allows an attacker in a network position between client and server to impersonate the OPC UA server and to read, forge or modify secure-channel traffic, including user credential ssent by the client. The defect manifests differently depending on ...
CVE-2026-102992	New	9.2	CRIT				piscina is a node.js worker pool implementation. Prior to 4.9.4, 5.3.2, and 6.0.0-rc.5, Piscina stores ThreadPool.options in src/index.ts as a plain object that inherits from Object.prototype. Applications with a separate prototype-pollution primitive can therefore supply inherited values for security-sensitive options that do not have own defaults. An inherited execArgv val...
CVE-2026-103547	New	9.2	CRIT				In Idapd in OpenBSD 7.8 before errata 057 and 7.9 before errata 021, delegated BSD authentication results are correlated only by the LDAP child process client file descriptor and LDAP message ID. After a connection closes, a later connection that reuses the same file descriptor and message ID can receive the earlier authentication result. A remote attacker who can reach Idapd...
CVE-2026-19445	New	9.2	CRIT				A remote, unauthenticated TLS client can make a server crash or call through a freed pointer if its sni_callback assigns a different context to SSLSocket.context (the documented way to select a certificate per server name) and nothing else keeps the original ssl.SSLContext alive. Typical cases are servers that create an SSLContext per connection or replace it while connectio...
CVE-2026-74865	New	9.2	CRIT				sogo_yhn configures SOGo with a parameter "SOGoTrustProxyAuthentication=YES". This causes the password to be bypassed during HTTP Basic authentication. An unauthenticated attacker who provides the username of an existing user and any arbitrary password can successfully log in to that user's account. This issue was fixed in version 5.8.0-ynh9.
CVE-2026-102095	New	9.1	CRIT				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Server-Side Request Forgery. Kiteworks Email Protection Gateway performed server-side fetches of URLs contained in the message content it processed, without adequately restricting the fetch destination. A remote, unauthenticated sender could craft a message that caused the gateway to issue requests to i...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102102	New	9.1	CRIT				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Server-Side Request Forgery (SSRF). A server-side request forgery (SSRF) weakness in Kiteworks Email Protection Gateway could allow a remote, unauthenticated attacker to induce the gateway to issue crafted requests to internal or otherwise unintended network destinations. The requests are triggered whil...
CVE-2026-102103	New	9.1	CRIT				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Server-Side Request Forgery (SSRF). A server-side request forgery (SSRF) weakness in Kiteworks Email Protection Gateway could allow a remote, unauthenticated attacker to induce the gateway to issue crafted requests to internal or otherwise unintended network destinations. The requests are triggered whil...
CVE-2026-102104	New	9.1	CRIT				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Server-Side Request Forgery (SSRF). A server-side request forgery (SSRF) weakness in Kiteworks Email Protection Gateway could allow a remote, unauthenticated attacker to induce the gateway to issue crafted requests to internal or otherwise unintended network destinations. The requests are triggered whil...
CVE-2026-102105	New	9.1	CRIT				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Server-Side Request Forgery (SSRF). A server-side request forgery (SSRF) weakness in Kiteworks Email Protection Gateway could allow a remote, unauthenticated attacker to induce the gateway to issue crafted requests to internal or otherwise unintended network destinations. The requests are triggered whil...
CVE-2026-102106	New	9.1	CRIT				Improper authentication in a Kiteworks Email Protection Gateway administrative service. An administrative service in Kiteworks Email Protection Gateway did not consistently enforce administrator authentication, so the required password check could be bypassed. An attacker who referenced a valid administrator account could potentially create, modify, or delete internal users ...
CVE-2026-62308	New	9.1	CRIT				Tugtainer is a self-hosted app for automating updates of Docker containers. Prior to version 1.30.6, Tugtainer allows an authenticated user to make the backend server send outbound HTTP requests to arbitrary user-supplied URLs through the notification test endpoint. The /settings/test_notification endpoint accepts a urls field and passes it directly to Apprise without restri...
CVE-2026-75969	New	9.1	CRIT				Missing authentication for critical function vulnerability for all PTZOptics cameras and the Firmware Upgrade Tool - Firmware Update modules. A missing authentication vulnerability in the firmware update mechanism of affected PTZOptics cameras allows an unauthenticated user to install modified firmware on the device without administrator credentials. This vulnerability al...
CVE-2026-77185	New	9.1	CRIT				Authentication bypass in sshd-core in Apache MINA SSHD versions 2.0.0 to 2.19.0 and 3.0.0-M1 to 3.0.0-M5 for a certain (presumed rare) way to implement an SSH server. Apache MINA SSHD is a Java library for client- and server-side SSH. In the server part of the library, a mechanism to perform "asynchronous authentication" exists. A server implemented with Apache MINA SSHD...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87830	New	9.1	CRIT				In the StAX streaming WS-SecurityPolicy validator, certain relative or unsupported XPath expressions can be converted into paths that never match the actual XML element path. A remote SOAP peer may therefore send a required element without the expected signature or encryption. Users are recommended to upgrade to versions 4.0.2 or 3.0.6 or 2.4.4, which fix this issue.
CVE-2026-89238	New	9.1	CRIT				WSS4J EncryptedHeader child confusion could promote an attacker-controlled plaintext element as the decrypted header, leading to incorrect confidentiality coverage and possible policy bypass. Users are recommended to upgrade to versions 4.0.2 or 3.0.6 or 2.4.4, which fix this issue.
CVE-2026-92966	New	9.1	CRIT				The The Appointment Booking Plugin – LatePoint Calendar & Scheduling for WordPress plugin for WordPress is vulnerable to arbitrary shortcode execution in all versions up to, and including, 5.7.0. This is due to the software allowing users to execute an action that does not properly validate a value before running do_shortcode. This makes it possible for unauthenticated att...
CVE-2026-94052	New	9.1	CRIT				A missing check in LdapPasswordAuthenticator in component sshd-lldap in Apache MINA SSHD versions 1.2.0 to 2.19.0 or 3.0.0-M1 to 3.0.0-M5 bypassed authentication checks. Apache MINA SSHD is a Java library for client-side and server-side SSH. The optional sshd-lldap component provides support for integrating password and publickey authentication on the server side with an L...
CVE-2026-94053	New	9.1	CRIT				Authentication bypass via LDAP injection in component sshd-lldap in Apache MINA SSHD versions 1.2.0 to 2.19.0 and 3.0.0-M1 to 3.0.0-M5. Apache MINA SSHD is a Java library for client-side and server-side SSH. The optional sshd-lldap component provides support for integrating password and publickey authentication on the server side with an LDAP server. sshd-lldap is an...
CVE-2026-97196	New	9.1	CRIT				Improper Validation of Unsafe Equivalence in Input vulnerability in Liquid Web / StellarWP GiveWP allows Authentication Bypass. This issue affects GiveWP: from n/a through 4.16.9.
CVE-2026-55176	New	9.0	CRIT				Soft Machine is a Virtual Machine–based agentic development environment / Cloud OS. In versions 0.2.247 and prior, two authentication helpers in /app/server.js — verifyContainerAuth() and authenticateWorkspaceHttp() — accept the global CONTAINER_SHARED_SECRET as a bearer token without verifying which workspace the caller belongs to. Because that secret is set identically on ...
CVE-2026-94389	New	9.0	CRIT				Unauthenticated Remote Code Execution (RCE) in AcyMailing SMTP Newsletter <= 11.0.5 versions.
CVE-2026-100277	New	8.9	HIGH				In JetBrains YouTrack before 2026.2.19197 account takeover was possible by replaying a notification signature
CVE-2026-13313	New	8.9	HIGH				An Active Debug Code vulnerability in certain ASUS router models allows a remote authenticated user, via a crafted HTTP request, to bypass security mechanisms and enable the Telnet service, thereby executing arbitrary commands with root privileges and potentially affecting other devices connected to the router. Refer to the ' Security Update for ASUS Router Firmware ' sectio...
CVE-2026-100253	New	8.8	HIGH				In JetBrains TeamCity before 2026.2, 2026.1.4, 2025.11.8 sandbox escape leading to code execution was possible via the versioned settings Kotlin DSL

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100254	New	8.8	HIGH				In JetBrains TeamCity before 2026.2, 2026.1.4, 2025.11.8 authenticated users could execute commands on Windows servers via CRLF injection in Pipeline Git connection settings
CVE-2026-101880	New	8.8	HIGH				OpenClaw Windows Node before 2026.7.1 contains an incorrect authorization vulnerability in the system.run exec-approval policy where ExecShellWrapperParser fails to split commands on pipe operators or extract command substitutions. Connected gateways or agents can bypass approval rules by placing denied commands behind allowed prefixes using pipe operators or command substit...
CVE-2026-101882	New	8.8	HIGH				OpenClaw Windows Node before 2026.7.1 contains an incomplete validation vulnerability in system.execApprovals.set that accepts wildcard-executable rules and abusable system binaries like mshta, rundll32, and certutil. Remote callers can add broad allow rules to execute arbitrary commands on the Windows host through system.run without operator checks or user prompts.
CVE-2026-102120	New	8.8	HIGH				A privilege escalation vulnerability in Kiteworks could have allowed an attacker who had already obtained code execution on one node of a clustered Kiteworks deployment to run operating system commands with elevated privileges on another node of the same cluster. Insufficient input validation in an internal cluster management function let attacker-supplied values reach a pri...
CVE-2026-102125	New	8.8	HIGH				The sandbox that isolates document conversion on a Kiteworks appliance did not fully confine the code running inside it. Code already executing within that sandbox could potentially escape its confinement and act with the privileges of the service account that runs the application, which could allow an attacker in that position to read or modify application data and configur...
CVE-2026-102377	New	8.8	HIGH				Contributor PHP Object Injection in Photo Gallery by 10Web <= 1.8.46 versions.
CVE-2026-103474	New	8.8	HIGH				yii2-starter-kit through 4.2.0 fails to validate file types in the backend storage upload actions, allowing authenticated managers to upload PHP files. Attackers with manager role can upload PHP scripts to the web-accessible storage directory and request them to execute arbitrary code on the server.
CVE-2026-18783	New	8.8	HIGH				Missing authentication for critical function vulnerability in Trex Digital Smart Manufacturing Systems Inc. Trex MES allows Authentication Bypass. This issue affects Trex MES: through 2026-09-29.
CVE-2026-80275	New	8.8	HIGH				Comelit Multi-User Gateway for VIP System (model 1456B) firmware versions 2.9.1 and 2.10.0 fail to enforce server-side authorization on an administrative password-change function. An authenticated user level can invoke this function to overwrite the installer (administrator) account password.
CVE-2026-94076	New	8.8	HIGH				Contributor PHP Object Injection in SEO Plugin by Squirrly SEO <= 14.2.5 versions.
CVE-2026-94121	New	8.8	HIGH				Contributor PHP Object Injection in 10Web Booster – Website speed optimization, Cache & Page Speed optimizer <= 2.33.6 versions.
CVE-2026-94678	New	8.8	HIGH				Contributor PHP Object Injection in Go Live Update Urls <= 7.0.8 versions.
CVE-2026-94683	New	8.8	HIGH				Contributor PHP Object Injection in DesignSetGo <= 2.8.0 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-95531	New	8.8	HIGH				Subscriber PHP Object Injection in Conversational Forms for ChatBot <= 1.5.0 versions.
CVE-2026-96831	New	8.8	HIGH				Contributor PHP Object Injection in Themify Builder <= 7.8.1 versions.
CVE-2026-96837	New	8.8	HIGH				Contributor Remote Code Execution (RCE) in CartFlows <= 3.2.0 versions.
CVE-2026-96838	New	8.8	HIGH				Unauthenticated Cross Site Request Forgery (CSRF) in Blacklist Manager – WooCommerce Anti-Fraud, Blacklist & Checkout Verification <= 2.3.1 versions.
CVE-2026-97291	New	8.8	HIGH				Contributor PHP Object Injection in Schema & Structured Data for WP & AMP <= 1.66 versions.
CVE-2026-102092	New	8.7	HIGH				Kiteworks Core before version 9.5.0 is vulnerable to Stored Cross-site Scripting (XSS) that could allow an authenticated user to store crafted content that executes arbitrary JavaScript in another user's authenticated session when they preview shared content. This could potentially lead to session compromise and account takeover.
CVE-2026-102100	New	8.7	HIGH				Kiteworks Core before version 9.5.0 is vulnerable to Stored Cross-Site Scripting. A stored cross-site scripting (XSS) weakness in Kiteworks Core could allow an authenticated user to submit content that, when later viewed by another user, executes arbitrary JavaScript in that user's authenticated session. This could be used to perform actions on the victim's behalf and may ha...
CVE-2026-102509	New	8.7	HIGH				Memory Allocation with Excessive Size Value, Allocation of Resources Without Limits, and Uncontrolled Recursion in the Java implementation of Apache PLC4X (PLC4J) allow a malicious or impersonated device to exhaust the memory or stack of the client application, causing a denial of service. In the OPC UA driver these defects are reachable before authentication: the offending...
CVE-2026-102510	New	8.7	HIGH				Integer Overflow, Improper Validation of Array Index, Uncontrolled Recursion and Memory Allocation with Excessive Size Value in the Go implementation of Apache PLC4X (PLC4Go) allow a malicious device, or an attacker able to inject network traffic, to crash or exhaust the memory of the client application, causing a denial of service. The individual defects are: - Generated p...
CVE-2026-102993	New	8.7	HIGH				pypdf is a free and open-source pure-python PDF library. Prior to 6.17.0, a crafted PDF can provide unusually large Roman page-label values that cause pypdf/_page_labels.py to generate excessively large numeral strings when an application retrieves document page labels, consuming large amounts of memory and potentially making the application unavailable. This issue is fixed ...
CVE-2026-102994	New	8.7	HIGH				pypdf is a free and open-source pure-python PDF library. Prior to 6.18.0, a crafted PDF containing indirect-object identifiers or generation-number tokens that continue for a long time without whitespace can cause pypdf/_reader.py and pypdf/generic/_base.py to scan excessive input through read_until_whitespace, resulting in long runtimes and application unavailability. This ...
CVE-2026-102995	New	8.7	HIGH				pypdf is a free and open-source pure-python PDF library. Prior to 6.18.1, a crafted PDF can place unusually large source-code or destination-string tokens in a font /ToUnicode mapping, causing pypdf/_cmap.py parse_bfchar to decode and retain oversized values during operations such as text extraction and consume excessive memory. This is a second follow-up to earlier /ToUnico...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102996	New	8.7	HIGH				pypdf is a free and open-source pure-python PDF library. Prior to 6.18.1, a crafted PDF can provide a TrueType or Type1 simple font with an unusually large /Widths array, causing pypdf/_font.py Font._collect_tt_t1_character_widths to process entries beyond the 256 character codes meaningful for a simple font and consume excessive memory during operations such as text extract...
CVE-2026-102997	New	8.7	HIGH				pypdf is a free and open-source pure-python PDF library. Prior to 6.18.1, a crafted PDF containing a partially malformed /FlateDecode stream with padded data can force pypdf/filters.py to use inefficient byte-by-byte decompression while the earlier recovery counter fails to advance for bytes that successfully decode, causing long runtimes and application unavailability. This...
CVE-2026-102998	New	8.7	HIGH				pypdf is a free and open-source pure-python PDF library. Prior to 6.19.0, a crafted PDF with form field values can cause pypdf/generic/_appearance_stream.py appearance-stream generation to repeat invariant selection-data work inside a loop when an application updates fields with flattening enabled, resulting in excessive runtimes and application unavailability. This issue is...
CVE-2026-102999	New	8.7	HIGH				pypdf is a free and open-source pure-python PDF library. Prior to 6.19.0, a crafted PDF containing many embedded files can cause the dictionary-based attachments API in pypdf/_doc_common.py to reparse the full attachment list for each content lookup, producing repeated work and long runtimes when an application accesses the embedded-file mapping. This issue is fixed in versi...
CVE-2026-103000	New	8.7	HIGH				pypdf is a free and open-source pure-python PDF library. Prior to 6.19.0, a crafted PDF can provide unusually large alphabetical page-label values that cause pypdf/_page_labels.py to generate strings beyond a reasonable page-label length when an application retrieves document page labels, consuming excessive memory and potentially making the application unavailable. This iss...
CVE-2026-103235	New	8.7	HIGH				MISP contains a mass assignment vulnerability in the event delegation feature. When a user with delegation permission submits a delegation request, the application authorized the user against the event identified in the URL but then persisted the entire submitted record, including caller-supplied fields such as the primary key and event_id. An authenticated attacker could i...
CVE-2026-103270	New	8.7	HIGH				LightLLM through 1.2.0 mounts reinforcement learning control routes on the public HTTP API without authentication checks. Unauthenticated attackers can call endpoints like /pause_generation, /abort_request, /flush_cache, and /init_weights_update_group to disrupt inference operations and wedge workers on deployments started with --enable_rl.
CVE-2026-103471	New	8.7	HIGH				restbed through 5.0.0 buffers HTTP request headers without enforcing a maximum size limit, allowing remote unauthenticated attackers to exhaust server memory. Attackers can open TCP connections and stream bytes indefinitely without sending the header delimiter, forcing the server to allocate unbounded heap memory until the process is killed.
CVE-2026-10764	New	8.7	HIGH				Information disclosure in BVMS 4.5 up to 12.3 including allows man-in-the-middle attackers to gain unauthorized access to sensitive data.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47097	New	8.7	HIGH				AJA HELO Plus firmware before 2.1.7 contains an information disclosure vulnerability that allows unauthenticated attackers to decrypt sensitive diagnostics bundles by exploiting a static AES passphrase embedded in obfuscated form within the firmware. Attackers can reverse engineer the publicly available firmware image to recover the shared passphrase and decrypt diagnostics ...
CVE-2026-55094	New	8.7	HIGH				Taskcluster is the task execution framework that supports Mozilla's continuous integration and release processes. Prior to version 100.3.0, Taskcluster is vulnerable to unauthenticated RCE on Taskcluster deployments with an anonymous role that exposes the GraphQL endpoint and parses filter arguments using the sift library. This issue has been patched in version 100.3.0.
CVE-2026-55224	New	8.7	HIGH				MineAdmin is a ready-to-use backend management system suitable for quickly building website backends, operation platforms, permission centers, internal management systems, CMS, CRM, OA, ERP and other business applications. Prior to version 3.2.0-alpha.2, the app-store plugin service concatenates unsanitized user-supplied identifier values directly into file system paths. An ...
CVE-2026-76992	New	8.7	HIGH				The CODESYS Gateway Client allocates memory based on a size field in a gateway response without enforcing an appropriate upper limit. An unauthenticated remote attacker controlling a malicious gateway can exploit this behavior to trigger excessive memory consumption, resulting in a denial-of-service condition thus leading to a total loss of availability.
CVE-2026-82826	New	8.7	HIGH				Hitachi Coding Software Suite contains a vulnerability related to the Cleartext Transmission of Sensitive Information which allows an attacker to eavesdrop on with authentication credentials and sensitive data in transit. This issue affects Hitachi Coding Software Suite: through 3.3.0.
CVE-2026-82828	New	8.7	HIGH				Hitachi Coding Software Suite contains an Incorrect Authorization vulnerability that allows an unprivileged user to perform administrator-level operations. This issue affects Hitachi Coding Software Suite: through 3.3.0.
CVE-2026-92867	New	8.7	HIGH				An out-of-bounds write vulnerability exists in Pgpool-II , which may allow an authenticated attacker to cause abnormal process termination or arbitrary code execution.
CVE-2026-92870	New	8.7	HIGH				A stack-based buffer overflow vulnerability exists in Pgpool-II, which may allow an unauthenticated attacker to cause abnormal process termination.
CVE-2026-92871	New	8.7	HIGH				A NULL pointer dereference vulnerability exists in Pgpool-II, which may allow an unauthenticated attacker to cause abnormal termination of the watchdog process.
CVE-2026-102121	New	8.6	HIGH				A form-rendering interface in the Advanced Forms component is reachable without authentication so that published forms can be displayed to anonymous visitors, but it returned more data than the form itself required. Anyone who knew the web address of a published form could potentially retrieve the form owner's Kiteworks account profile, including personal details, along with...
CVE-2026-102454	New	8.6	HIGH				EasyFlow .NET developed by Digiwin has an Arbitrary File Upload vulnerability. Privileged remote attackers can upload and execute web shell backdoors, thereby enabling arbitrary code execution on the server.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103239	New	8.6	HIGH				MISP contains a privilege escalation vulnerability in the tag collection creation and editing functionality. The affected actions accepted the full HTTP request payload and passed it to a bulk-association save operation, which writes not only the intended tag collection record but also any associated model data present in the payload. A user holding the tag editor permissio...
CVE-2026-103398	New	8.6	HIGH				OpenSave through 2.4.0 fails to properly validate save paths supplied by paired peers in the manifest request handler. Attackers can specify arbitrary directories outside configured save locations to read and write files through manifest and sync routes.
CVE-2026-97150	New	8.6	HIGH				When converting baserCMS4-style addons to baserCMS5-style ones, BcAddonMigrator includes "config.php" from the addon, which means the PHP code in the file is executed. Arbitrary files on the system may be read or deleted by an administrative user.
CVE-2026-102511	New	8.5	HIGH				Improper Verification of Source of a Communication Channel in the ADS discovery of the Go implementation of Apache PLC4X (PLC4Go) allows an attacker able to send UDP datagrams to the discovering host to redirect subsequent connections to an arbitrary, attacker-chosen address. The discovery result's connection address was derived from the AmsNetId claimed in the response bod...
CVE-2026-10739	New	8.5	HIGH				Cato Networks SDP Client for Windows before 6.12.6 allows a local user to delete arbitrary files with SYSTEM privileges via improper validation of a client-supplied SID over a local IPC named pipe.
CVE-2026-94115	New	8.5	HIGH				Contributor SQL Injection in Easy Pricing Tables <= 4.1.2 versions.
CVE-2026-94177	New	8.5	HIGH				Unauthenticated SQL Injection in GamiPress <= 8.0.2 versions.
CVE-2026-97287	New	8.5	HIGH				Contributor SQL Injection in Event Tickets <= 5.29.5 versions.
CVE-2026-97293	New	8.5	HIGH				Contributor SQL Injection in Media Library Assistant <= 3.41 versions.
CVE-2026-76146	New	8.4	HIGH				An OS command injection vulnerability in Genian SSL PNS allows an attacker who knows only the client access ID, without the password, to execute arbitrary commands remotely
CVE-2026-103237	New	8.3	HIGH				MISP contains an improper input validation vulnerability in its ORM save path. When a user submits data through various endpoints (attribute add/edit, event edit, free-text import, sighting capture, shadow attribute proposal, event report creation, object reference add, user admin edit), the application sanitizes the flat record by stripping the primary key and pinning the e...
CVE-2026-103321	New	8.3	HIGH				MISP contains a stored cross-site script (XSS) vulnerability in the event graph preview feature. The event graph preview image field was accepted and stored without server-side validation. On the client side, the stored value was rendered into an HTML img element's src attribute via string concatenation, allowing a crafted value to break out of the attribute context and inj...
CVE-2026-46711	New	8.3	HIGH				Soft Machine is a Virtual Machine–based agentic development environment / Cloud OS. In versions 0.2.247 and prior, the workspace HTTP service that listens on 0.0.0.0:8080 inside each sm-ws-* Fly Machine exposes endpoints (/health, /file/<path>, /archive/<dir>) without any authentication or origin check. Any host that can reach TCP/8080 on a workspace can read arbitrary files...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-100273	New	8.2	HIGH				In JetBrains YouTrack before 2026.2.19197 authorisation bypass in the scripts debugger allowed arbitrary code execution
CVE-2026-102984	New	8.2	HIGH			npm:@astrojs/node	Astro is a web framework for content-driven websites. Prior to 11.1.3, the @astrojs/node adapter builds a request URL from the Host header, and a malformed port can make that URL invalid. The recovery path reuses the same malformed host and throws an uncaught TypeError: Invalid URL before routing begins. In the default standalone configuration, the request returns an HTTP 50...
CVE-2026-102990	New	8.2	HIGH				basic-ftp is an FTP client for Node.js. Prior to 6.2.1, Client.list() can be forced by a malicious or compromised FTP server to spend quadratic CPU time parsing a directory listing because the RE_LINE expression in src/parseListUnix.ts backtracks across adjacent variable-length owner and group fields when a long Unix-style line has a valid prefix but cannot satisfy the later...
CVE-2026-93621	New	8.2	HIGH				Unauthenticated SQL Injection in WP Data Access <= 5.5.84 versions.
CVE-2026-96817	New	8.2	HIGH				Subscriber Broken Access Control in MakeCommerce for WooCommerce <= 4.1.0 versions.
CVE-2026-100255	New	8.1	HIGH				In JetBrains TeamCity before 2026.2, 2026.1.4, 2025.11.8 administrator account takeover was possible via password reset
CVE-2026-102101	New	8.1	HIGH				Kiteworks Core before version 9.5.0 is vulnerable to Deserialization of Untrusted Data. A deserialization weakness in Kiteworks Core could, under certain conditions, allow crafted data to be deserialized unsafely, potentially resulting in remote code execution on the appliance. Exploitation depends on an attacker first being able to influence the affected data, so this issue...
CVE-2026-102126	New	8.1	HIGH				A stored cross-site scripting (XSS) weakness in Kiteworks Core could allow an administrator holding only a single, narrowly scoped delegated permission to store crafted content that later executes arbitrary JavaScript in the authenticated session of a System Administrator who views the affected page. This could have permitted the lower-privileged administrator to escalate to...
CVE-2026-103432	New	8.1	HIGH				apcupsd through 3.14.14 has an sscanf stack-based buffer overflow in getupsvar() in src/cgi/upsfetch.c (used by upsstats.cgi, multimon.cgi, and upsfstats.cgi), a related issue to CVE-2026-15544.
CVE-2026-103473	New	8.1	HIGH				Deno versions 2.7.0 through 2.9.7 on Windows contain a command injection vulnerability in node:child_process where shell arguments are escaped for the wrong shell type. Attackers can inject OS commands by passing untrusted arguments with the shell option, allowing arbitrary command execution with Deno process privileges.
CVE-2026-51568	New	8.1	HIGH				modelscope Agentscope v1.0.18-v1.0.0 is vulnerable to Path Traversal in write_text_file.
CVE-2026-51570	New	8.1	HIGH				modelscope Agentscope v1.0.0-v1.0.8 is vulnerable to Path Traversal in insert_text_file.
CVE-2026-87004	New	8.1	HIGH				Tugtainer is a self-hosted app for automating updates of Docker containers. Prior to version 1.31.3, when the OIDC login flow completes, backend/modules/auth/providers/auth_oidc_provider.py decodes the id_token returned by the identity provider's token endpoint using jose.jwt.get_unverified_claims() instead of jwt.decode(). This skips signature verification, audience (aud) v...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-93994	New	8.1	HIGH				Apache MINA SSHD is a Java library for client-side and server-side SSH. SSH servers can be configured to require multi-authentication schemes, for instance two different public keys, not just one. In OpenSSH, this would be done by setting in sshd_config AuthenticationMethods "publickey,publickey". Apache MINA SSHD provides an equivalent configuration mechanism. In Apache...
CVE-2026-100256	New	7.8	HIGH				In JetBrains IntelliJ IDEA before 2026.2.3 rCE via Structural Search script constraints was possible in untrusted projects
CVE-2026-101885	New	7.8	HIGH				ZeroClaw versions before 0.8.5 built with plugins-wasm feature contain a path traversal vulnerability in plugin installation that fails to validate the wasm_path manifest field. Attackers can convince users to install crafted plugins that write arbitrary files to paths outside the plugins directory, such as shell startup files, enabling code execution.
CVE-2026-102112	New	7.8	HIGH				A privilege escalation vulnerability in Kiteworks could allow an attacker who has already obtained code execution as an unprivileged backend service account on the appliance to escalate to root and run arbitrary commands with the highest privileges. Exploitation requires existing local access to that service account.
CVE-2026-102113	New	7.8	HIGH				A privilege escalation vulnerability in Kiteworks could allow an attacker who has already obtained code execution as an unprivileged backend service account on the appliance to escalate to root. A privileged routine did not safely handle a filesystem path that the lower-privileged account could influence, allowing the attacker to cause a root-owned operation to run arbitrary...
CVE-2026-102118	New	7.8	HIGH				A local privilege escalation vulnerability in Kiteworks could have allowed an attacker with an existing shell under a low-privileged service account to escalate to root privileges on the appliance.
CVE-2026-47489	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where permissions on read-only memory might not be preserved. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47491	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an unprivileged user can cause improper release of memory resources, leaving a mapping accessible after the underlying memory is reused. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and da...
CVE-2026-47493	New	7.8	HIGH				NVIDIA vGPU software for Windows and Linux contains a vulnerability in the GPU kernel driver where a guest may access privileged host GPU resources for which it is not authorized. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, data tampering, denial of service, and information disclosure.
CVE-2026-47494	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability where a user might be able to cause a format string issue. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, data tampering, denial of service, and information disclosure.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47495	New	7.8	HIGH				NVIDIA vGPU Virtual GPU Manager for Windows and Linux contains a vulnerability in the kernel mode layer where a user could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47497	New	7.8	HIGH				NVIDIA Virtual GPU Manager contains a vulnerability in the GPU System Processor (GSP) tracing component where a guest VM user may cause improper access by sending crafted data through a shared buffer. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, data tampering, denial of service, and information disclosure.
CVE-2026-47498	New	7.8	HIGH				NVIDIA vGPU Manager contains a vulnerability in the GPU System Processor (GSP) plugin where a guest VM user may cause an out-of-bounds write by sending a specially crafted RPC message. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, data tampering, denial of service, and information disclosure.
CVE-2026-47499	New	7.8	HIGH				NVIDIA vGPU Virtual GPU Manager for Windows and Linux contains a vulnerability in the kernel mode layer where a guest could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47500	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where improper cleanup of reference counts during error paths could lead to a use-after-free condition. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47501	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where a user could cause an out-of-bounds write by supplying mismatched memory buffers during event buffer setup. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47502	New	7.8	HIGH				NVIDIA vGPU Virtual GPU Manager for Windows and Linux contains a vulnerability in the kernel mode layer, where a guest user could cause an integer overflow leading to memory corruption. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47503	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the Virtual GPU Manager (vGPU plugin), where a guest VM user may cause an out-of-bounds write by sending a crafted RPC message with invalid performance state list size parameters. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, data tampering, denial of service,...
CVE-2026-47504	New	7.8	HIGH				NVIDIA Linux GPU Display Driver contains a vulnerability in the NGX updater where an outdated embedded cryptographic library is susceptible to type confusion. A successful exploit of this vulnerability might lead to code execution, denial of service, information disclosure, or data tampering.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47505	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel mode layer where an attacker could cause a use-after-free. A successful exploit of this vulnerability might lead to code execution, denial of service, or escalation of privileges, information disclosure, and data tampering.
CVE-2026-47507	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where a user could cause an out-of-bounds array access. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47508	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where a user could cause an incorrect conversion between numeric types. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47510	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where a user could cause an integer overflow leading to an out-of-bounds write to GPU memory. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47511	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where a user could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47512	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where a user could cause an out-of-bounds read leading to kernel information disclosure. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47513	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where a user could cause an out-of-bounds read from kernel heap memory. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47514	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where a user could cause exposure of kernel stack contents including return addresses and pointers. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47516	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability where an unprivileged user could cause a use-after-free. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, data tampering, denial of service, and information disclosure.
CVE-2026-47519	New	7.8	HIGH				NVIDIA vGPU Virtual GPU Manager for Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47520	New	7.8	HIGH				NVIDIA vGPU Virtual GPU Manager for Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47521	New	7.8	HIGH				NVIDIA vGPU Virtual GPU Manager for Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47523	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47528	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the firmware where an attacker could cause an access of an uninitialized pointer. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47530	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47535	New	7.8	HIGH				NVIDIA vGPU Virtual GPU Manager for Linux contains a vulnerability in the firmware where an attacker could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47536	New	7.8	HIGH				NVIDIA vGPU Virtual GPU Manager for Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47540	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause an integer underflow. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47541	New	7.8	HIGH				NVIDIA vGPU Virtual GPU Manager for Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47545	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47548	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47550	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel mode layer where an unprivileged local user can supply an untrusted pointer that the driver dereferences without validation. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47551	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where a user could cause a use-after-free. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47552	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an unprivileged user could bypass an authorization check and modify privileged configuration. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47553	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an unprivileged user could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47556	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an unprivileged user could cause an integer overflow that leads to an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47558	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an unprivileged user could cause a double-free of imported memory state. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47559	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where a user could access memory belonging to another user's process. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, data tampering, denial of service, and information disclosure.
CVE-2026-47560	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an unprivileged user could cause a use-after-free. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47561	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where the size of an ioctl input buffer is not validated, allowing an unprivileged caller to trigger an out-of-bounds write in kernel memory. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and dat...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47563	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where a user could cause a NULL pointer dereference. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47569	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where a user could cause a type confusion via a handle recycle race. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47570	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the CUDA driver where an attacker could cause a library to be loaded from an uncontrolled search path. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, information disclosure, data tampering, and denial of service.
CVE-2026-47571	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in kernel-mode escape handling where an attacker with local access could bypass an authorization check that is intended to restrict certain operations based on client execution context. A successful exploit of this vulnerability might lead to escalation of privilege, information disclosure, data tampering, denial...
CVE-2026-47572	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where a user could cause type confusion. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47573	New	7.8	HIGH				NVIDIA NVAPI for Windows contains a vulnerability where an attacker could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47574	New	7.8	HIGH				NVIDIA vGPU Virtual GPU Manager for Linux contains a vulnerability where an attacker could cause incorrect resource transfer between spheres. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47575	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the display driver DIAG escape handler where a local unprivileged attacker may cause an integer overflow and out-of-bounds write. A successful exploit of this vulnerability might lead to denial of service, and code execution.
CVE-2026-47577	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel module where an attacker could cause an incorrect comparison. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47578	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel mode layer where an attacker could cause an incorrect buffer size calculation. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47579	New	7.8	HIGH				The NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel mode driver through which a user might trigger a use-after-free condition. Successful exploitation of this issue could lead to code execution, escalation of privileges, denial of service, information disclosure, and data tampering.
CVE-2026-47583	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel module where an attacker could cause type confusion. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47585	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel module where an attacker could cause an integer underflow. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47587	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability where an unprivileged user could cause a use-after-free. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, denial of service, information disclosure, and data tampering.
CVE-2026-47588	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability where an unprivileged user could cause a use-after-free condition by issuing a sequence of driver commands. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, denial of service and information disclosure.
CVE-2026-47589	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability where an unprivileged user may cause a use-after-free condition by issuing a sequence of driver commands. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, denial of service, and information disclosure.
CVE-2026-47590	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability where an unprivileged user may cause a use-after-free condition by issuing a sequence of driver commands. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, denial of service, and information disclosure.
CVE-2026-47591	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an unprivileged user could bypass read-only memory protection due to incorrect authorization, enabling write access to memory marked read-only. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure,...
CVE-2026-47592	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an unprivileged user could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47593	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel mode layer where an unprivileged user can cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, and denial of service.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47594	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability where an unprivileged user may cause a use-after-free condition by issuing a sequence of driver commands. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, denial of service, data tampering, and information disclosure.
CVE-2026-47595	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an unprivileged user can write to read-only memory because the memory's permissions are not preserved. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, denial of service, information disclosure, and data tampering.
CVE-2026-47597	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the open-source kernel module Resource Server where an unprivileged local user could cause a use-after-free through a missing self-reference guard in the map cleanup path. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, denial of service, information...
CVE-2026-47599	New	7.8	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the open-source kernel module where an unprivileged local user could cause improper preservation of memory access permissions during DMA mapping. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, denial of service, information disclosure, and data tampering.
CVE-2026-47600	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an error-handling path could operate on an improperly initialized resource. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, denial of service, information disclosure, and data tampering.
CVE-2026-47601	New	7.8	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the open-source kernel module DMA-BUF import path where an unprivileged local user could cause improper preservation of memory access permissions when importing a read-only buffer from another device's DMA-BUF exporter. A successful exploit of this vulnerability might lead to code execution, escalati...
CVE-2026-53605	New	7.8	HIGH				Reachy Mini ISO for Wireless contains the necessary files to build a custom Raspberry Pi OS image for the Reachy Mini Wireless robot, using pi-gen. Prior to version 0.2.4, the Reachy Mini Wireless OS image shipped with an overly broad sudoers entry granting the pollen daemon user (uid 1000) passwordless sudo access to /usr/bin/systemctl with no subcommand or argument restric...
CVE-2026-62146	New	7.8	HIGH				A trust-boundary flaw in CRI-O's sandbox state persistence allows attacker-influenced pod metadata to overwrite CRI-O's own reserved sandbox bookkeeping; once reloaded as trusted after a restart, a later container recreate in that sandbox can expose a host-side runtime-management resource inside the container, enabling container escape.
CVE-2026-100266	New	7.7	HIGH				In JetBrains Hub before 2026.2.52366 missing authorisation allowed authenticated users to send arbitrary emails from the server's trusted address
CVE-2026-100268	New	7.7	HIGH				In JetBrains YouTrack before 2026.2.19197 project administrators could read comments from other projects via notification templates

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47576	New	7.7	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel module through which an attacker might initiate an out-of-bounds read. Successful exploitation of this issue could lead to denial of service and information disclosure.
CVE-2026-100262	New	7.6	HIGH				In JetBrains YouTrack before 2026.2.18991 missing authorisation allowed users with read-only project access to overwrite project notification templates
CVE-2026-19553	New	7.6	HIGH				ssl.SSLContext.wrap_bio() didn't require the server_hostname argument to not be None if ssl.SSLContext.check_hostname was set. Due to a missing parameter check in SSLObject, if the server_hostname argument isn't supplied then hostname verification would be silently skipped. This defect could lead to programs where certificate hostname verification *appeared* to be succeedi...
CVE-2026-55177	New	7.6	HIGH				CloudTAK is a browser-based Common Operating Picture and situational awareness tool compatible with TAK. Prior to version 13.10.0, every route in the ESRI helper family (api/routes/esri.ts) takes a fully attacker-controlled URL from the request (POST /api/esri body url, and the portal / server / layer query parameters on the GET /api/esri/* routes) and passes it into EsriBas...
CVE-2026-62085	New	7.6	HIGH				Administrator SQL Injection in WP Activity Log <= 5.6.6 versions.
CVE-2026-62097	New	7.6	HIGH				Improper Neutralization of Special Elements used in an SQL Command ('SQL Injection') vulnerability in WPTasty Business Directory business-directory-plugin allows Blind SQL Injection.This issue affects Business Directory: from n/a through 6.4.27.
CVE-2026-94082	New	7.6	HIGH				Author SQL Injection in Quiz Cat <= 3.1.1 versions.
CVE-2026-96345	New	7.6	HIGH				Administrator SQL Injection in Estatik <= 4.3.5 versions.
CVE-2026-96346	New	7.6	HIGH				Author SQL Injection in WP ERP <= 1.17.9 versions.
CVE-2026-96827	New	7.6	HIGH				Administrator SQL Injection in Admin Notices Manager <= 1.6.0 versions.
CVE-2026-96828	New	7.6	HIGH				Administrator SQL Injection in Category Discount Woocommerce <= 5.18 versions.
CVE-2023-54402	New	7.5	HIGH				iDocView contains a server-side request forgery vulnerability in its /doc/upload endpoint that allows remote unauthenticated attackers to fetch arbitrary URLs by supplying a hardcoded default token value (testtoken) to bypass authentication. Attackers can exploit the unrestricted URL scheme handling, including file:// URIs, to read arbitrary local files such as operating-sys...
CVE-2023-54403	New	7.5	HIGH				Yonyou U8 CRM before V16.5 and V18 contains an arbitrary file read vulnerability in /ajax/getemaildata.php that allows unauthenticated attackers to bypass authentication using the DontCheckLogin=1 parameter and read arbitrary files via an unvalidated filePath parameter. Attackers can exploit this flaw to read sensitive files outside the web application directory, including c...
CVE-2024-58387	New	7.5	HIGH				Inspur Haiyue HCM Cloud contains an arbitrary file read vulnerability in the /api/model_report/file/download endpoint that allows unauthenticated remote attackers to read arbitrary files by supplying unvalidated path parameters index and ext. Attackers can craft requests such as /api/model_report/file/download?index=/&ext=<path> to traverse the filesystem and disclose sensit...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101884	New	7.5	HIGH				OpenClaw Windows Node before 2026.7.1 contains an incomplete environment-variable sanitizer in system.run that fails to block GIT_CONFIG_*, DOTNET_STARTUP_HOOKS, and JAVA_TOOL_OPTIONS variables. Attackers with gateway or agent access can supply these variables to allowlisted tools like git, dotnet, or java to load attacker-controlled code and achieve arbitrary code execution.
CVE-2026-102091	New	7.5	HIGH				Kiteworks Secure Data Forms before version 9.5.0 is vulnerable to Server-Side Request Forgery that could allow an unauthenticated, remote attacker to make the server issue arbitrary outbound network requests and read back the responses. This could potentially be used to reach internal-only services or other network-restricted resources.
CVE-2026-102128	New	7.5	HIGH				An identity-verification weakness in Kiteworks Email Protection Gateway allowed the gateway to act on the Kiteworks platform on behalf of a user it had not authenticated, and to provision a platform account for an identity it did not already know. A remote, unauthenticated sender could potentially exploit this to obtain control of a platform account.
CVE-2026-102143	New	7.5	HIGH				An unauthenticated attacker could cause a file with attacker-controlled content to be written to the appliance filesystem through an administrative upload handler that did not properly authenticate the request. This did not by itself result in code execution, which would require a separate vulnerability to place the file in an executable location.
CVE-2026-102717	New	7.5	HIGH				MQTT WebSocket setter ABI mismatch may disclose memory or cause a crash
CVE-2026-103472	New	7.5	HIGH				restbed through 5.0.0 accepts WebSocket frames with declared payload lengths up to 2^63 bytes and buffers the payload without size limits in an unbounded stream buffer. Remote unauthenticated attackers can declare large frame sizes and stream payload data to exhaust server memory, causing denial of service through process crash.
CVE-2026-103591	New	7.5	HIGH				DeepWiki-Open through commit d92819a contains an unauthenticated arbitrary file read vulnerability in the GET /codemap/file endpoint via the repo_url parameter. Attackers can supply a non-URL repo_url value to bypass path containment checks and read any file accessible to the API process by specifying absolute file paths.
CVE-2026-6806	New	7.5	HIGH				The Motors – Car Dealership & Classified Listings Plugin plugin for WordPress is vulnerable to time-based blind SQL Injection via the 'stm_lat/stm_ing' parameter in all versions up to, and including, 1.4.109 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for unauthenticated attackers to read the contents of arbitrary files on the server, which can contain sensitive information. The endpoint's only authentication gate relies on a nonce and token...
CVE-2026-75098	New	7.5	HIGH				The Product Designer App plugin for WordPress is vulnerable to Directory Traversal in all versions up to, and including, 1.1.3 via the 'svg' parameter parameter. This makes it possible for unauthenticated attackers to read the contents of arbitrary files on the server, which can contain sensitive information. The endpoint's only authentication gate relies on a nonce and token...
CVE-2026-76145	New	7.5	HIGH				An improper privilege management vulnerability in Genian SSL PNS allows an attacker to escalate to super administrator privileges and force the creation of an OS account by manipulating the permission column during CSV bulk user registration

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-80276	New	7.5	HIGH				Comelit Multi-User Gateway for VIP System (model 1456B) firmware versions 2.9.1 and 2.10.0 expose a network-accessible management interface that does not require authentication. Through this interface, sensitive device configuration data - including the Remote Configuration Password - can be read in cleartext by a remote, unauthenticated attacker.
CVE-2026-85532	New	7.5	HIGH				Apache WSS4J accepted attacker-controlled derived-key lengths and offsets without adequate bounds. This could permit cryptographically weak keys or excessive CPU and memory consumption when processing crafted WS-Security messages. The fixes enforce a minimum key length of 16 bytes, a maximum length of 512 bytes, and a maximum offset of 4096 bytes. Users are recommended to up...
CVE-2026-89294	New	7.5	HIGH				The Simply Schedule Appointments plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 1.6.12.27 via the 'ssa_locale' parameter parameter. This makes it possible for authenticated attackers, with subscriber-level access and above, to include and execute arbitrary .php files on the server, allowing the execution of any PHP code in th...
CVE-2026-92121	New	7.5	HIGH				In the WSS4J streaming (StAX) code, a signature reference using the WS-Security STR-Transform leaves an internal "inside signed content" flag permanently set. The WS-SecurityPolicy enforcer uses that flag to decide whether an element needs checking, so it stops evaluating SignedParts and SignedElements for the rest of the message. A policy requiring the SOAP Body to be signe...
CVE-2026-92245	New	7.5	HIGH				The Simply Schedule Appointments plugin for WordPress is vulnerable to Sensitive Information Exposure in all versions up to, and including, 1.6.12.32 via the 'recursive' parameter. This makes it possible for unauthenticated attackers to extract customer PII — including names, email addresses, phone numbers, and custom form field data — stored in appointment records, as well ...
CVE-2026-94002	New	7.5	HIGH				Possible memory exhaustion in SFTP clients (DefaultSftpClient) in component sshd-sftp in Apache MINA SSHD versions 0.9.0 to 2.19.0 and 3.0.0-M1 to 3.0.0-M5. Apache MINA SSHD is a Java library for client-side and server-side SSH. The sshd-sftp component provides support for SFTP. The SFTP client implementation, when receiving a reply, did not check that this reply co...
CVE-2026-94120	New	7.5	HIGH				Unauthenticated Broken Access Control in GravityExport Lite for Gravity Forms <= 2.7.2 versions.
CVE-2026-94123	New	7.5	HIGH				Unauthenticated Arbitrary File Download in NextGEN Gallery <= 4.5.0 versions.
CVE-2026-94178	New	7.5	HIGH				Subscriber Privilege Escalation in Import and export users and customers <= 2.5.2 versions.
CVE-2026-95587	New	7.5	HIGH				Unauthenticated Broken Access Control in Hostinger Migrator <= 1.0 versions.
CVE-2026-95616	New	7.5	HIGH				An integer overflow in WSS4J's DER bounds check lets an oversized allocation pass validation. An unauthenticated attacker can send a SOAP message carrying an X.509 certificate whose SubjectKeyIdentifier extension declares a length of 0x7FFFFFFF; WSS4J decodes this while resolving the signature's key reference, before the message is authenticated, so an eleven-byte extension ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96348	New	7.5	HIGH				Unauthenticated Broken Access Control in Bookly <= 28.2 versions.
CVE-2026-96818	New	7.5	HIGH				Unauthenticated Broken Access Control in WP Express Checkout (Accept PayPal Payments) <= 2.4.9 versions.
CVE-2026-96823	New	7.5	HIGH				Unauthenticated Arbitrary Content Deletion in Customer Reviews for WooCommerce <= 5.120.0 versions.
CVE-2026-97197	New	7.5	HIGH				Unauthenticated Broken Access Control in WordPress Backup & Migration <= 1.6.0 versions.
CVE-2026-97240	New	7.5	HIGH				Unauthenticated Sensitive Data Exposure in StifLi Backup Tools <= 2.2.7 versions.
CVE-2026-97241	New	7.5	HIGH				Unauthenticated Sensitive Data Exposure in BackupEase <= 2.2.2 versions.
CVE-2026-97244	New	7.5	HIGH				Contributor Path Traversal in Creator LMS <= 1.2.19 versions.
CVE-2026-102123	New	7.4	HIGH				A Kiteworks appliance setup interface did not confine a user-supplied file path to its intended directory, which could allow an unauthenticated attacker to write a file to any location writable by the affected service account, potentially compromising the integrity of the appliance or rendering it unavailable until an operator intervenes. Exploitation requires network access...
CVE-2026-103446	New	7.4	HIGH				Authorization bypass through User-Controlled key vulnerability in The Wikimedia Foundation MediaWiki WikiLambda extension allows Authentication Bypass. This issue affects MediaWiki WikiLambda extension: 1.46.
CVE-2026-101295	New	7.3	HIGH				Path traversal / arbitrary file write in oc-mirror's operator catalog image extraction. When mirroring operator catalogs using either the legacy v1 path (--v1) or the OCI feature path (--use-oci-feature), oc-mirror extracts tar entries from catalog image layers without validating that file paths resolve within the intended destination directory.
CVE-2026-103229	New	7.3	HIGH				A vulnerability was found in AdithyaYelloju Restaurant-Management-System up to 7f0e7e84255e8fcfd488e83f8f91451bbbff6b9c. This issue affects the function mysqli_query of the file admin/delete1.php of the component Unauthenticated Action Script. Performing a manipulation of the argument ID results in sql injection. The attack can be initiated remotely. The exploit has been mad...
CVE-2026-103231	New	7.3	HIGH				A vulnerability was identified in AdithyaYelloju Restaurant-Management-System up to 7f0e7e84255e8fcfd488e83f8f91451bbbff6b9c. The affected element is the function mysqli_query of the file User/cancel.php of the component Order Cancellation. The manipulation of the argument ID leads to sql injection. The attack may be initiated remotely. The exploit is publicly available and ...
CVE-2026-103530	New	7.3	HIGH				A vulnerability was detected in decolua 9Router up to 0.5.55. The affected element is the function fetch of the file src/shared/utlis/ssrfGuard.js of the component Search Endpoint. Performing a manipulation of the argument provider_options.baseUrl results in server-side request forgery. The attack can be initiated remotely. Applying a patch is the recommended action to fix t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103536	New	7.3	HIGH				A vulnerability was identified in ZongXR Supermarket 1.0.0.0. Affected by this vulnerability is the function OrderController.addOrder of the file order/src/main/java/com/supermarket/order/controller/OrderController.java of the component save Endpoint. Such manipulation of the argument userId leads to missing authentication. The attack can be executed remotely. The exploit is...
CVE-2026-47496	New	7.3	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the Virtual GPU Manager (vGPU plugin) where a guest VM user may cause an out-of-bounds write by sending a specially crafted RPC call to the host. A successful exploit of this vulnerability might lead to escalation of privileges, data tampering, and denial of service.
CVE-2026-47580	New	7.3	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel module where an attacker could cause a missing authorization issue. A successful exploit of this vulnerability might lead to information disclosure and data tampering.
CVE-2026-76143	New	7.3	HIGH				A missing authorization vulnerability in Genian SSL PNS allows an attacker to bypass multi-factor authentication by manipulating a login request parameter.
CVE-2026-102089	New	7.2	HIGH				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to a path traversal weakness in an administrative import function allowed an authenticated administrator to write files to arbitrary locations on the server. This could potentially be leveraged to execute arbitrary code on the underlying system.
CVE-2026-102093	New	7.2	HIGH				Kiteworks Core before version 9.5.0 is vulnerable to Improper Privilege Management and does not correctly enforce restrictions on role assignment, which could allow an authenticated administrative user with limited, non-Sysadmin role-management permissions to elevate another user to full system-administrator privileges beyond those the administrative user was authorized to g...
CVE-2026-102094	New	7.2	HIGH				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Unsafe Reflection and does not sufficiently restrict the code that the mail-processing pipeline could load from an imported rule configuration. An authenticated administrator with mail-rule configuration privileges could cause the gateway to load and execute code beyond the approved set of mail-processi...
CVE-2026-102096	New	7.2	HIGH				Kiteworks Core before version 9.5.0 is vulnerable to OS Command Injection that allows an authenticated administrator to upload a configuration package whose contents were not sufficiently validated before being processed. A crafted package could cause the underlying system to execute arbitrary operating-system commands, potentially with elevated privileges, on the affected a...
CVE-2026-102097	New	7.2	HIGH				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Remote Code Execution. Kiteworks Email Protection Gateway allowed an authenticated administrator to import configuration whose contents were not sufficiently validated before being processed. A crafted submission could potentially allow arbitrary commands to be executed on the affected gateway.
CVE-2026-102098	New	7.2	HIGH				Kiteworks Core before version 9.5.0 is vulnerable to SQL Injection. A stored SQL injection vulnerability in a Kiteworks administrative reporting feature could allow an authenticated administrator to read sensitive data from the underlying database and to affect the availability of the service. Exploitation requires an existing, authenticated administrative account with acces...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102099	New	7.2	HIGH				Kiteworks Core before version 9.5.0 is vulnerable to Arbitrary File Write. An improper restriction of a user-supplied file path in a Kiteworks administrative export feature could allow an authenticated administrator to write a file to an arbitrary location on the underlying host, potentially leading to command execution on the appliance. Exploitation requires an existing, au...
CVE-2026-102108	New	7.2	HIGH				An authenticated administrator of Kiteworks Email Protection Gateway could submit a crafted serialized object to a cluster management interface that was deserialized without sufficient validation, potentially allowing arbitrary code execution in the context of the gateway service account. Exploitation requires an administrator account holding a specific queue-management priv...
CVE-2026-102114	New	7.2	HIGH				A command injection vulnerability in Kiteworks could allow a high-privileged authenticated administrator to execute arbitrary operating-system commands as root on the affected appliance node. Successful exploitation requires an administrative account with elevated privileges.
CVE-2026-102116	New	7.2	HIGH				-A weakness could have allowed an authenticated Kiteworks Email Protection Gateway administrator to write a file outside its intended location and cause the application to execute it, potentially resulting in remote code execution as the underlying service account.
CVE-2026-102117	New	7.2	HIGH				On deployments where the remote-support capability is licensed and enabled, an authenticated System Administrator who also possessed the key protecting the submitted data could redirect the underlying system's outbound support connection to a destination of their choosing. That destination could then have operating-system commands executed on the node and receive their outpu...
CVE-2026-102119	New	7.2	HIGH				A path traversal weakness in an optional, non-default administrative feature allowed an authenticated administrator to move files to unintended locations outside the feature's designated directory. This could potentially be leveraged to execute arbitrary code on the underlying system.
CVE-2026-102129	New	7.2	HIGH				A user-provisioning interface in Kiteworks Core did not verify that the requesting administrator was entitled to grant the role being assigned. An administrator whose delegated permissions covered role changes alone could therefore raise an account to full system-administrator privileges.
CVE-2026-102130	New	7.2	HIGH				Kiteworks Email Protection Gateway did not sufficiently validate the content of an uploaded backup, and allowed an administrator to influence how the application loaded it. An authenticated administrator could potentially use this to execute arbitrary code on the gateway as the underlying service account.
CVE-2026-102131	New	7.2	HIGH				Kiteworks Email Protection Gateway rejected certain configuration settings, but its validation did not recognize every form in which they could be supplied. An authenticated administrator could potentially use an unrecognized form to have a file of their choosing written to the gateway and executed, resulting in code execution as the gateway service account.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102132	New	7.2	HIGH				An administrative import function in Kiteworks Core did not verify that the requesting administrator was entitled to create the privileged integration credential being imported. A delegated administrator holding a single narrowly scoped administrative permission could therefore obtain full system administrator privileges, without any action by an existing system administrator.
CVE-2026-102142	New	7.2	HIGH				A system notification template on the Kiteworks appliance was rendered by a template engine that evaluated expressions contained in the stored template body. An authenticated System Administrator could potentially store a crafted template that executed operating-system commands on the appliance when the notification was next sent.
CVE-2026-102150	New	7.2	HIGH				A function in the Kiteworks Advanced Forms component was reachable without authentication. An unauthenticated attacker could potentially use it to carry out a limited set of internal service operations on the Kiteworks platform; it did not permit access to user accounts, stored files, or form submissions.
CVE-2026-102392	New	7.2	HIGH				Shop manager PHP Object Injection in Extra Product Options For WooCommerce Custom Product Addons and Fields <= 3.3.8 versions.
CVE-2026-103441	New	7.2	HIGH				Deserialization of untrusted data vulnerability in The Wikimedia Foundation MediaWiki Wikibase extension allows Leverage Executable Code in Non-Executable Files. This issue affects MediaWiki Wikibase extension: 1.46, 1.45, and 1.43.
CVE-2026-103442	New	7.2	HIGH				External control of system or configuration setting vulnerability in The Wikimedia Foundation MediaWiki CentralAuth extension allows Code Injection. This issue affects MediaWiki CentralAuth extension: 1.46, 1.45, and 1.43.
CVE-2026-79625	New	7.2	HIGH				Affected products do not properly synchronize access to their monitoring functionality. When multiple clients send concurrent requests, this may lead to incorrect reads or writes, or to corruption of internal memory structures. An authenticated remote attacker with monitoring access can exploit this issue to cause incorrect data processing or a denial-of-service condition.
CVE-2026-85679	New	7.2	HIGH				The Extendify plugin for WordPress is vulnerable to Stored Cross-Site Scripting via 'styles.blocks' Block Type Key in all versions up to, and including, 3.1.6 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. Thi...
CVE-2026-93624	New	7.2	HIGH				Shop manager PHP Object Injection in Music Player for WooCommerce <= 1.9.1 versions.
CVE-2026-93651	New	7.2	HIGH				Author PHP Object Injection in Minimum and Maximum Quantity for WooCommerce <= 2.1.2 versions.
CVE-2026-93771	New	7.2	HIGH				Shop manager PHP Object Injection in Cost of Goods for WooCommerce <= 3.5.2 versions.
CVE-2026-94122	New	7.2	HIGH				Editor PHP Object Injection in Responsive Slider Gallery <= 1.5.5 versions.
CVE-2026-94677	New	7.2	HIGH				Shop manager PHP Object Injection in Kadence WooCommerce Email Designer <= 1.5.19.1 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96343	New	7.2	HIGH				Custom role PHP Object Injection in WP ERP <= 1.17.9 versions.
CVE-2026-96344	New	7.2	HIGH				Custom role PHP Object Injection in eCommerce Product Catalog <= 3.6.0 versions.
CVE-2026-96561	New	7.2	HIGH				The AI Engine – The Chatbot, AI Framework & MCP for WordPress plugin for WordPress is vulnerable to Stored Cross-Site Scripting in versions up to, and including, 3.8.0 This is due to a chain of missing input neutralization and output escaping across the /mwai-ui/v1/chats/submit REST endpoint, the PHP error-log parser (MeowKit_MWAI_Helpers::php_error_logs), the Advisor task (...)
CVE-2026-96815	New	7.2	HIGH				Custom role Privilege Escalation in Vitepos <= 3.5.0 versions.
CVE-2026-96832	New	7.2	HIGH				Shop manager PHP Object Injection in Content Egg <= 6.3.1 versions.
CVE-2026-96833	New	7.2	HIGH				Editor PHP Object Injection in Ultimate Addons for Contact Form 7 <= 3.5.51 versions.
CVE-2026-97245	New	7.2	HIGH				Shop Worker Privilege Escalation in SureCart <= 4.7.2 versions.
CVE-2026-97256	New	7.2	HIGH				Editor PHP Object Injection in Page Builder by SiteOrigin <= 2.36.0 versions.
CVE-2026-97347	New	7.2	HIGH				The Post Views Stats Counter plugin for WordPress is vulnerable to Stored Cross-Site Scripting via User-Agent Header in all versions up to, and including, 1.1.7 due to insufficient input sanitization and output escaping. This makes it possible for unauthenticated attackers to inject arbitrary web scripts in pages that will execute whenever a user accesses an injected page. T...
CVE-2026-100507	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in If-So Dynamic Content Personalization <= 1.10.1 versions.
CVE-2026-100510	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Post and Page Builder by BoldGrid <= 1.27.14 versions.
CVE-2026-102109	New	7.1	HIGH				A SQL injection vulnerability existed in Kiteworks Secure Data Forms, where a value derived from the authenticated user's stored account data was incorporated into a database query without proper sanitization. An authenticated user could potentially influence that value to inject SQL. Exploitation requires an authenticated session and applies only to deployments where a spec...
CVE-2026-102376	New	7.1	HIGH				Subscriber Cross Site Scripting (XSS) in Branda <= 3.4.32 versions.
CVE-2026-102385	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Ninja Forms <= 3.15.3 versions.
CVE-2026-102391	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in JetFormBuilder <= 3.6.5.4 versions.
CVE-2026-102395	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Easy Google Maps <= 1.14.6 versions.
CVE-2026-102396	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Ultimate Maps by Supsysic <= 1.5.5 versions.
CVE-2026-102398	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Popup by Supsysic <= 1.13.1 versions.
CVE-2026-102456	New	7.1	HIGH				EasyFlow .NET developed by Digiwin has an SQL Injection vulnerability. Authenticated remote attackers can inject arbitrary SQL commands to read database contents.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102457	New	7.1	HIGH				EasyFlow .NET developed by Digiwin has an Arbitrary File Read vulnerability. Authenticated remote attackers can exploit this vulnerability to download arbitrary system files.
CVE-2026-103242	New	7.1	HIGH				A heap-based buffer overflow flaw was found in rpm. RPMTAG_FILESIGNATURES in a crafted, unsigned RPM package's main header is declared with the wrong header type, causing hex2binv() to allocate a one-byte buffer and then write the tag's attacker-controlled, hex-decoded content — of attacker-chosen length — past the end of that allocation. This is reachable via rpm2cpio, rpm2...
CVE-2026-27371	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in WPFunnels <= 3.13.1 versions.
CVE-2026-47554	New	7.1	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where improper verification of cryptographic signatures may cause signature verification to be bypassed under memory pressure. A successful exploit of this vulnerability might lead to denial of service and data tampering.
CVE-2026-47602	New	7.1	HIGH				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode driver where a local user can cause the driver to dereference an untrusted pointer. A successful exploit of this vulnerability might lead to denial of service and information disclosure.
CVE-2026-78210	New	7.1	HIGH				In affected versions of Octopus Server, users with certain scoped permission sets could execute arbitrary scripts in an environment without possessing the required authorization.
CVE-2026-92869	New	7.1	HIGH				An out-of-bounds write vulnerability exists in Pgpool-II, which may allow an authenticated attacker to cause abnormal process termination.
CVE-2026-93512	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in JW Player for WordPress <= 2.3.11 versions.
CVE-2026-93514	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Notification for Telegram <= 3.5.2 versions.
CVE-2026-93770	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in WP Statistics <= 14.16.13 versions.
CVE-2026-94078	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Site Reviews <= 8.3.1 versions.
CVE-2026-94081	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in WordPress Persistent Login <= 3.1.3 versions.
CVE-2026-94171	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in CURCY <= 2.2.16 versions.
CVE-2026-94499	New	7.1	HIGH				Subscriber Broken Access Control in FormGent <= 1.12.2 versions.
CVE-2026-96351	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Classified Listing <= 6.1.3 versions.
CVE-2026-96352	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in YITH WooCommerce Ajax Search <= 2.28.0 versions.
CVE-2026-96814	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in WooCommerce Product Table Lite <= 5.6.7 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96816	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Trusted Shops Easy Integration for WooCommerce <= 2.0.6 versions.
CVE-2026-96819	New	7.1	HIGH				Subscriber Cross Site Scripting (XSS) in oik <= 4.15.4 versions.
CVE-2026-96820	New	7.1	HIGH				Subscriber Cross Site Scripting (XSS) in Awesome Support <= 6.3.9 versions.
CVE-2026-96830	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in GiveWP <= 4.16.9 versions.
CVE-2026-96836	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Parsi Date <= 6.3 versions.
CVE-2026-97065	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Happyforms <= 1.26.15 versions.
CVE-2026-97077	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Ad Inserter <= 2.8.18 versions.
CVE-2026-97235	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in ThemeREX Addons < 2.45.0 versions.
CVE-2026-97237	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in JetEngine <= 3.8.14.3 versions.
CVE-2026-97250	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Geo Mashup <= 1.13.21 versions.
CVE-2026-97253	New	7.1	HIGH				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Kreatura LayerSlider allows Reflected XSS. This issue affects LayerSlider: from n/a through 8.4.0.
CVE-2026-97271	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in WPFunnels <= 3.13.1 versions.
CVE-2026-97272	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Premmerce Permalink Manager for WooCommerce <= 2.3.13 versions.
CVE-2026-97289	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Quiz And Survey Master <= 11.2.6 versions.
CVE-2026-97290	New	7.1	HIGH				Unauthenticated Cross Site Scripting (XSS) in Photonic Gallery & Lightbox for Flickr, SmugMug & Others <= 3.36 versions.
CVE-2026-102127	New	7.0	HIGH				An XML parser used by Kiteworks Email Protection Gateway did not restrict external entity references. Where an optional, non-default message-processing feature is enabled, a remote and unauthenticated sender could potentially use a crafted message to read files accessible to the gateway service account, including cryptographic key material and credentials, and have them sent...
CVE-2026-47582	New	7.0	HIGH				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel module where an attacker could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47596	New	7.0	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an unprivileged user can write to read-only memory because the memory's permissions are not preserved. A successful exploit of this vulnerability might lead to code execution and escalation of privileges.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47598	New	7.0	HIGH				NVIDIA GPU Display Driver for Linux contains a vulnerability in the open-source kernel module event delivery path where an unprivileged local user could cause a use-after-free through a race between asynchronous event delivery and file close. A successful exploit of this vulnerability might lead to code execution, escalation of privileges, denial of service, information disc...
CVE-2026-93495	New	7.0	HIGH				Improper initialization in an ASUS certain motherboard allows an physically proximate user to read or write arbitrary memory by inserting a specially crafted device.
CVE-2026-100275	New	6.9	MEDI				In JetBrains YouTrack before 2026.2.19197 stored XSS in the workflow error notification toast was possible
CVE-2026-92868	New	6.9	MEDI				An improper certificate validation vulnerability exists in Pgpool-II, which may allow an unauthenticated attacker to bypass client certificate authentication.
CVE-2026-92873	New	6.9	MEDI				Pgpool-II contains an incorrect implementation of an authentication algorithm, which may allow an unauthenticated attacker to promote an arbitrary watchdog node to the leader node.
CVE-2026-93462	New	6.9	MEDI				A missing authentication for critical function vulnerability exists in baserCMS. If this vulnerability is exploited, a remote attacker may obtain sensitive information.
CVE-2026-96342	New	6.9	MEDI				Missing Authorization vulnerability in Amauri.IO WPMobile.App wpappninja allows Retrieve Embedded Sensitive Data.This issue affects WPMobile.App: from n/a through 11.83.
CVE-2026-10726	New	6.8	MEDI				Cato Windows SDP Client before version 6.12.6 contains an arbitrary file disclosure vulnerability. A low-privileged local user can cause the Windows service, running as Local System, to read and disclose arbitrary local files due to improper file path validation and missing TLS certificate enforcement.
CVE-2026-96824	New	6.8	MEDI				Editor Arbitrary File Deletion in Template Kit – Import <= 1.0.16 versions.
CVE-2026-97242	New	6.8	MEDI				Author Arbitrary File Deletion in WEBO MCP <= 3.0.18 versions.
CVE-2026-102141	New	6.7	MEDI				Two Kiteworks Core cluster-management operations did not validate file paths supplied to them, so an attacker holding root on one node of a cluster could write files as root onto another node and cause them to be executed there. Exploitation requires backend root access on a cluster node and a pending software patch present on the target node.
CVE-2026-47509	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where a user could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47515	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where a user could cause an out-of-bounds read via an unbounded string operation. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47522	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause improper input validation. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47524	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47525	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause an improper validation of an array index. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47527	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the firmware where an attacker could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47529	New	6.7	MEDI				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47532	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47533	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause an improper validation of an array index. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47537	New	6.7	MEDI				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47538	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the firmware where an attacker could cause an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47539	New	6.7	MEDI				NVIDIA vGPU Virtual GPU Manager for Linux contains a vulnerability in the kernel mode layer where an attacker could cause an incorrect numeric conversion. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47542	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause improper input validation. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47543	New	6.7	MEDI				VIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause improper input validation. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47544	New	6.7	MEDI				NVIDIA vGPU Virtual GPU Manager for Linux contains a vulnerability in the kernel mode layer where an attacker could cause an out-of-bounds read. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47546	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the firmware where an attacker could cause improper input validation. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47547	New	6.7	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the firmware where an attacker could cause improper input validation. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-102133	New	6.6	MEDI				An optional, separately licensed repository-connector feature in Kiteworks Core did not neutralize special characters in a user-supplied path before passing it to an external command. An authenticated system administrator could inject additional commands and write arbitrary content to files owned by the service account running the connector, enabling code execution in that a...
CVE-2026-102135	New	6.6	MEDI				On a Kiteworks Email Protection Gateway cluster with database replication enabled, a party trusted by the cluster could submit a crafted serialized object that was deserialized without sufficient validation, potentially allowing code execution as the gateway service account. Replication is disabled by default, and exploitation requires control of a trusted cluster peer or ad...
CVE-2026-102145	New	6.6	MEDI				An authenticated administrator could cause the server to issue requests to, and interact with, internal network services that are not meant to be reachable through this interface. On its own this did not result in code execution.
CVE-2026-100274	New	6.5	MEDI				In JetBrains YouTrack before 2026.2.19197 project Admin could trigger DoS via a notification template
CVE-2026-100279	New	6.5	MEDI				In JetBrains YouTrack before 2026.2.19197 changing an integration URL exposed its stored credentials
CVE-2026-100513	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in CF7 Views – Complete Entry Management for Contact Form 7 <= 3.2.5 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101879	New	6.5	MEDI				OpenClaw Windows Node before 2026.7.1-3 contains a missing authorization vulnerability in NodeService capture handlers that allows connected gateways or agents to perform screen snapshots, camera snaps, and location captures without consent prompts. Attackers can invoke screen.snapshot, camera.snap, and location.get over the node WebSocket to silently capture screenshots, ph...
CVE-2026-101881	New	6.5	MEDI				OpenClaw Windows Node before 2026.7.1 contains an allocation of resources without limits vulnerability in the gateway WebSocket transport that allows connected gateways to exhaust node memory. Attackers can send an unending sequence of WebSocket continuation frames without EndOfMessage to cause unbounded memory growth until the node process crashes.
CVE-2026-102124	New	6.5	MEDI				A Kiteworks appliance setup interface did not enforce authentication once the appliance had completed initial configuration. An unauthenticated attacker with network access to the appliance could read and modify a limited set of setup records, including a contact name and email address captured during initial configuration.
CVE-2026-102139	New	6.5	MEDI				An authorization check in the large file exchange feature of Kiteworks Email Protection Gateway did not correctly establish that the requesting user was a party to the package being requested. An authenticated user of that optional feature could read the subject, message body, and attachments of packages they neither sent nor received.
CVE-2026-102146	New	6.5	MEDI				An authenticated Email Protection Gateway administrator holding only limited, delegated permissions could write files with attacker-controlled content to arbitrary locations accessible to the Email Protection Gateway service account. This exceeds the administrator's intended privileges and could be used to alter application files and configuration or to disrupt the availabil...
CVE-2026-102375	New	6.5	MEDI				Subscriber Broken Access Control in Optimole <= 4.2.14 versions.
CVE-2026-102386	New	6.5	MEDI				Subscriber Cross Site Scripting (XSS) in WP Photo Album Plus <= 9.3.02.003 versions.
CVE-2026-102397	New	6.5	MEDI				Unauthenticated Broken Access Control in Ultimate Maps by Supsysitic <= 1.5.5 versions.
CVE-2026-102588	New	6.5	MEDI				A flaw was found in Moodle. The XML grade import feature lacks proper Cross-Site Request Forgery (CSRF) token validation. By tricking an authenticated user with grade management permissions into visiting a malicious webpage, an attacker can trigger unauthorized requests on the victim's behalf. This flaw allows a remote attacker to set or overwrite student grades without auth...
CVE-2026-102991	New	6.5	MEDI				Mako is a template library written in Python. Prior to 1.4.2, on Windows, TemplateLookup.get_template() in mako/lookup.py resolves template URIs with posixpath, while Template.__init__() in mako/template.py validates them with os.path, which uses ntpath. A URI beginning with a drive designator causes ntpath to absorb the traversal segments before the leading dot-dot check, w...
CVE-2026-103001	New	6.5	MEDI			pip:PyJWT	PyJWT is a Python implementation of JSON Web Token standards. From 2.11.0 through 2.13.0, PyJWT's PyJWT._merge_options() method can modify a caller-supplied mutable options mapping when verify_signature is false. If an application reuses that same mapping for a later decode() or decode_complete() call and changes verify_signature to true, the mapping can retain false values ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103538	New	6.5	MEDI				A security flaw has been discovered in ZongXR SuperMarket 1.0.0.0. Affected by this issue is the function OrderController.deleteOrder of the file order/src/main/java/com/supermarket/order/controller/OrderController.java of the component Order Deletion Endpoint. Performing a manipulation of the argument orderId results in missing authentication. The attack is possible to be c...
CVE-2026-103592	New	6.5	MEDI				simple-php-router through 5.4.1.7 contains an IP restriction bypass vulnerability in the IpRestrictAccess middleware that allows remote unauthenticated attackers to bypass IP whitelist and blacklist protections. Attackers can spoof X-Forwarded-For, CF-Connecting-IP, or Client-IP headers to impersonate whitelisted addresses or evade blacklists, gaining access to IP-restricted...
CVE-2026-16596	New	6.5	MEDI				The WP Directory Kit plugin for WordPress is vulnerable to generic SQL Injection via the 'data_fields_list' parameter in all versions up to, and including, 1.5.4 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for authenticated attackers, with custom-level access and above, to ap...
CVE-2026-62078	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Premium Addons for Elementor <= 4.11.105 versions.
CVE-2026-62079	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Qi Addons For Elementor <= 1.11 versions.
CVE-2026-62080	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Happy Addons for Elementor <= 3.23.1 versions.
CVE-2026-62084	New	6.5	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Jeff Starr User Submitted Posts allows Stored XSS. This issue affects User Submitted Posts: from n/a through 20260810.
CVE-2026-67075	New	6.5	MEDI				HCL Digital Experience is affected by improper input sanitation. This can result in HTML injection which could be leveraged in content spoofing from a trusted domain. Apply HCL Digital Experience 9.5 CF238 or later to address this.
CVE-2026-91109	New	6.5	MEDI				The Simply Schedule Appointments plugin for WordPress is vulnerable to Insecure Direct Object Reference in all versions up to, and including, 1.6.12.31 via the 'complete_group' parameter due to missing validation on a user controlled key. This makes it possible for authenticated attackers, with subscriber-level access and above, to disclose every co-booker's private per-appo...
CVE-2026-93995	New	6.5	MEDI				Improper input validation in sshd-git in Apache MINA SSHD, versions up to 2.19.0 and 3.0.0-M1 to 3.0.0-M5. Apache MINA SSHD is a Java library for client-side and server-side SSH. Component org.apache.sshd:sshd-git provides though class GitPgmCommandFactory a way to configure an Apache MINA SSHD server such that authenticated SSH clients can remotely execute git command...
CVE-2026-93996	New	6.5	MEDI				Uncontrolled resource consumption in component sshd-scp in Apache MINA SSHD versions up to 2.19.0 or 3.0.0-M1 to 3.0.0-M5. Apache MINA SSHD is a Java library for client-side and server-side SSH. Component sshd-scp of Apache MINA SSHD provides a Java implementation of SCP. The SCP command protocol is line-oriented with LF-terminated lines. The protocol handler in sshd-scp ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94029	New	6.5	MEDI				Server-side memory exhaustion in Apache MINA SSHD 1.0.0 to 2.19.0 and 3.0.0-M1 to 3.0.0-M5, component sshd-sftp, in the SFTP v6 check-file-name/check-file-handle extension. Apache MINA SSHD is a Java library for client-side and server-side SSH. Using a very small "block size" (for instance 256, which is the minimum) on a huge file generates many (file size / block size) ...
CVE-2026-94074	New	6.5	MEDI				Unauthenticated Broken Access Control in Simply Schedule Appointments <= 1.6.12.29 versions.
CVE-2026-94077	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Safe SVG <= 2.5.0 versions.
CVE-2026-94674	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Pixel Manager for WooCommerce <= 1.69.0 versions.
CVE-2026-96338	New	6.5	MEDI				Subscriber Cross Site Scripting (XSS) in Profile Builder <= 4.0.2 versions.
CVE-2026-96347	New	6.5	MEDI				Subscriber Insecure Direct Object References (IDOR) in Bookly <= 28.2 versions.
CVE-2026-96829	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in The Plus Addons for Elementor Page Builder Lite <= 6.5.1 versions.
CVE-2026-96834	New	6.5	MEDI				Subscriber Sensitive Data Exposure in GiveWP <= 4.16.9 versions.
CVE-2026-96835	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in King Addons for Elementor <= 51.1.85 versions.
CVE-2026-97067	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in EWWW Image Optimizer <= 8.7.7 versions.
CVE-2026-97236	New	6.5	MEDI				Subscriber Cross Site Scripting (XSS) in ThemeREX Addons < 2.45.0 versions.
CVE-2026-97239	New	6.5	MEDI				Subscriber Broken Access Control in MCP Content Manager Lite <= 1.1.0 versions.
CVE-2026-97247	New	6.5	MEDI				Unauthenticated Broken Access Control in Blocksy Companion <= 2.1.55 versions.
CVE-2026-97262	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Visual Composer Website Builder <= 45.16.2 versions.
CVE-2026-97265	New	6.5	MEDI				Improper Neutralization of Input During Web Page Generation ('Cross-site Scripting') vulnerability in Crocoblock. Jetimpex Inc. JetEngine allows Stored XSS. This issue affects JetEngine: from n/a through 3.8.15.3.
CVE-2026-97266	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Virtue/Ascend/Pinnacle Toolkit <= 4.9.12.1 versions.
CVE-2026-97270	New	6.5	MEDI				Subscriber Cross Site Scripting (XSS) in CMB2 <= 2.13.0 versions.
CVE-2026-97279	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Polylang <= 3.8.9 versions.
CVE-2026-97286	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Strong Testimonials <= 3.3.11 versions.
CVE-2026-97288	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in OAuth Server <= 4.5.1 versions.
CVE-2026-97292	New	6.5	MEDI				Author Cross Site Scripting (XSS) in YITH WooCommerce Tab Manager <= 2.15.0 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97298	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in King Addons for Elementor <= 51.1.86 versions.
CVE-2026-97301	New	6.5	MEDI				Contributor Cross Site Scripting (XSS) in Cool Formkit Lite <= 2.7.8 versions.
CVE-2025-14564	New	6.4	MEDI				The Viable URL Media Uploader plugin for WordPress is vulnerable to Stored Cross-Site Scripting via SVG File uploads in all versions up to, and including, 1.0.0 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with Author-level access and above, to inject arbitrary web scripts in pages that will execute whenever ...
CVE-2026-11895	New	6.4	MEDI				The HT Mega Addons for Elementor – Elementor Widgets & Template Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via Data Table 'display_options' Setting in all versions up to, and including, 3.1.1 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with contributor-level access and above, t...
CVE-2026-14876	New	6.4	MEDI				The Smart Slider 3 plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'data-href' parameter in all versions up to, and including, 3.5.1.38 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with contributor-level access and above, to inject arbitrary web scripts in pages that will execute whe...
CVE-2026-47565	New	6.4	MEDI				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where a privileged user could trigger a race condition that leads to an out-of-bounds write. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-47586	New	6.4	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel module where an attacker could cause a use-after-free. A successful exploit of this vulnerability might lead to code execution, denial of service, escalation of privileges, information disclosure, and data tampering.
CVE-2026-6170	New	6.4	MEDI				The Bold Page Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'images' parameter of the plugin's bt_bb_css_image_grid shortcode in all versions up to, and including, 5.7.2 due to insufficient input sanitization and output escaping on user-supplied attributes. This makes it possible for authenticated attackers, with Contributor-level access a...
CVE-2026-6171	New	6.4	MEDI				The Bold Page Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'target' parameter of the plugin's bt_bb_icon shortcode in all versions up to, and including, 5.7.2 due to insufficient input sanitization and output escaping on user-supplied attributes. This makes it possible for authenticated attackers, with Contributor-level access and above, ...
CVE-2026-6172	New	6.4	MEDI				The Bold Page Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'caption' parameter of the plugin's bt_bb_image shortcode in all versions up to, and including, 5.7.2 due to insufficient input sanitization and output escaping on user-supplied attributes. This makes it possible for authenticated attackers, with Contributor-level access and above...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-6173	New	6.4	MEDI				The Bold Page Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'background_image' parameter of the plugin's bt_bb_section shortcode in all versions up to, and including, 5.7.2 due to insufficient input sanitization and output escaping on user-supplied attributes. This makes it possible for authenticated attackers, with Contributor-level acces...
CVE-2026-88037	New	6.4	MEDI				The Bold Page Builder plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the `title` attribute of the `bt_bb_service` shortcode in all versions up to, and including, 5.7.2. This is due to insufficient input sanitization and output escaping on user supplied attributes. This makes it possible for authenticated attackers, with Contributor-level access and abo...
CVE-2026-92712	New	6.4	MEDI				The ReactPress – Create React App for WordPress plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'permalink' parameter in all versions up to, and including, 3.4.0 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to inject arbitrary web scripts in pa...
CVE-2026-93908	New	6.4	MEDI				The Real Estate Manager – Property Listing and Agent Management plugin for WordPress is vulnerable to Stored Cross-Site Scripting via the 'before_price_text' parameter in all versions up to, and including, 7.3 due to insufficient input sanitization and output escaping. This makes it possible for authenticated attackers, with subscriber-level access and above, to inject arbit...
CVE-2026-102136	New	6.3	MEDI				In multi-node deployments, an attacker who had already obtained code execution on one appliance node could submit a value through an internal cluster interface that was written into monitoring configuration on another node without sufficient validation, potentially allowing OS commands to be executed there. Execution was limited to an unprivileged service account on that node.
CVE-2026-102983	New	6.3	MEDI			npm:@astrojs/netlify	Astro is a web framework for content-driven websites. From 5.2.0 until 8.2.4, the @astrojs/netlify adapter generates regular expressions for Netlify Image CDN remote-image allowlists without anchoring them to the beginning of the URL. Because Netlify evaluates these expressions with RegExp.test(), an allowed origin appearing only in a source URL's path or query can satisfy i...
CVE-2026-103115	New	6.3	MEDI				A security flaw has been discovered in OS4ED openSIS-Classic up to 9.3. This affects an unknown function of the file functions/CustomFieldsFnc.php of the component Student Search. The manipulation of the argument cust results in sql injection. It is possible to launch the attack remotely. The exploit has been released to the public and may be used for attacks. The project wa...
CVE-2026-103222	New	6.3	MEDI				A vulnerability was determined in Blosc C-Blosc2 up to 3.3.2. This impacts the function blosclz_decompress of the file blosc/blosclz.c of the component blosclz Decompression. Executing a manipulation can lead to integer overflow. The attack may be launched remotely. A high complexity level is associated with this attack. The exploitability is said to be difficult. Upgrading ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103226	New	6.3	MEDI				A vulnerability was identified in Artifex Ghostscript up to 10.09.0. Affected is the function type1_callsubr of the file devices/vector/gdevpsfx.c of the component Pdfrwrite. The manipulation leads to stack-based buffer overflow. Remote exploitation of the attack is possible. The exploit is publicly available and might be used. It is suggested to install a patch to address th...
CVE-2026-103227	New	6.3	MEDI				A weakness has been identified in GPAC up to 26.07.0. Affected by this issue is the function gf_dash_resolve_url of the file src/media_tools/dash_client.c of the component DASH Client. This manipulation causes buffer overflow. The attack is possible to be carried out remotely. Upgrading to version abi-16.26 can resolve this issue. Patch name: 4c8e26f278ff63eec57968f7bc696f60...
CVE-2026-103534	New	6.3	MEDI				A vulnerability was determined in David-Crty databasement up to 1.7.1. Affected is the function SnapshotPolicy.viewAny/SnapshotPolicy.view of the file /api/v1/snapshots of the component Snapshot Model. This manipulation causes improper access controls. Remote exploitation of the attack is possible. The exploit has been publicly disclosed and may be utilized. Upgrading to ver...
CVE-2026-103540	New	6.3	MEDI				A security vulnerability has been detected in formtools.org Form Tools up to 3.1.1. This vulnerability affects the function Clients::updateClientSettingsTab of the file global/code/Clients.class.php of the component Client Settings. The manipulation of the argument page_titles leads to improper neutralization of special elements used in a template engine. It is possible to i...
CVE-2026-103541	New	6.3	MEDI				A vulnerability was detected in formtools.org Form Tools up to 3.1.1. This issue affects the function Files::uploadFile of the file global/code/actions.php of the component Ajax Handler. The manipulation results in unrestricted upload. It is possible to launch the attack remotely. The exploit is now public and may be used. The project was informed of the problem early throug...
CVE-2026-103543	New	6.3	MEDI				A vulnerability has been found in itsourcecode Leave Management System 1.0. The affected element is an unknown function of the file /module/leavetype/controller.php. Such manipulation of the argument LEAVTID leads to sql injection. The attack can be launched remotely. The exploit has been disclosed to the public and may be used.
CVE-2026-91860	New	6.3	MEDI				A prototype pollution vulnerability exists in the deep merge helpers of Vaadin Charts and Vaadin Component Base. Merging an object the application does not control into a chart configuration or into a component's i18n property writes onto Object.prototype, making the injected properties visible to every object in the running application. Users of affected versions should a...
CVE-2026-96821	New	6.3	MEDI				Subscriber Privilege Escalation in FluentBoards <= 2.0.12 versions.
CVE-2026-103388	New	6.2	MEDI				MISP renders the source field of a Galaxy Cluster as a clickable hyperlink whenever the stored value passes PHP's FILTER_VALIDATE_URL validation. Because FILTER_VALIDATE_URL accepts the javascript: URI scheme, a user with galaxy editor privileges on the local instance or on a synced instance could store a javascript: URL as the cluster source. When another user views the af...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103389	New	6.2	MEDI				MISP contains a stored cross-site scripting (XSS) vulnerability in the galaxy icon handling path. The icon field of a galaxy object was persisted without any server-side validation through the galaxy add, edit, and sync/import capture endpoints. The stored value was subsequently concatenated directly into HTML markup by the D3-based correlation graph rendering scripts (both ...
CVE-2026-47096	New	6.1	MEDI				AJA HELO Plus firmware before 2.1.7 contains a stored cross-site scripting vulnerability that allows unauthenticated attackers with network access to inject malicious JavaScript by setting an unsanitized eParamID_SystemName value through the /config?action=set web configuration API. Attackers can exploit this flaw when device authentication is disabled to persistently execut...
CVE-2026-47518	New	6.0	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in a secure microcontroller component, where incorrect permission assignment for a critical resource allows an attacker with privileged local access to modify protected memory that should be restricted. A successful exploit of this vulnerability might lead to code execution and escalation of privileges.
CVE-2026-100267	New	5.9	MEDI				In JetBrains YouTrack before 2026.2.19197 reDoS attack was possible via mailbox regex mail-rule filters
CVE-2026-100276	New	5.9	MEDI				In JetBrains YouTrack before 2026.2.19197 guest users could remove a workflow action's visibility restriction and run the action
CVE-2026-102110	New	5.9	MEDI				An endpoint used during initial appliance setup did not require authentication and did not correctly enforce its intended state precondition, so during the initial activation window an unauthenticated network attacker could repeatedly re-trigger the privileged activation process. This could disrupt setup and leave the appliance in an incompletely configured state. The issue ...
CVE-2026-102384	New	5.9	MEDI				Author Cross Site Scripting (XSS) in Supreme Modules Lite <= 2.5.63 versions.
CVE-2026-55174	New	5.9	MEDI				UltrafastSecp256k1 is a high-performance, multi-backend secp256k1 engine with reproducible audit evidence, compatibility shims, and profile-based review scopes. Prior to version 4.2.0, UltrafastSecp256k1's ECDSA adaptor pre-signature verification accepts forged adaptor pre-signatures whose "r" value is not cryptographically bound to the adaptor point "T". This issue has been...
CVE-2026-76147	New	5.9	MEDI				A path traversal (ZIP Slip) vulnerability caused by insufficient authorization and integrity verification in the agent upgrade feature of Genian NAC/ZTNA allows a remote attacker to execute arbitrary code
CVE-2026-94681	New	5.9	MEDI				Unauthenticated Denial of Service Attack in WP Store Locator < 3.0.0 versions.
CVE-2026-103243	New	5.8	MEDI				LightLLM through 1.2.0 fails to validate image_url and audio_url parameters in multimodal endpoints, allowing unauthenticated attackers to perform server-side request forgery. Attackers can supply arbitrary URLs to fetch internal resources, with vision model processing disclosing content or error responses revealing internal network topology.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103397	New	5.6	MEDI				OpenSave before 2.4.0-beta.1 fails to validate sender identity in WAN relay requests, allowing unpaired room members to impersonate paired devices by spoofing the RelayMessage From field. Attackers who know the room code can join, read paired peer identifiers from announcements, and send forged requests to access protected sync routes including save data, snapshots, and file...
CVE-2026-102578	New	5.5	MEDI				A flaw was found in Moodle. An authenticated attacker with access to the question bank web service can submit unsanitized input directly into database queries, resulting in a SQL (Structured Query Language) injection vulnerability. This issue could allow an attacker to view, alter, or delete sensitive data stored in the underlying database.
CVE-2026-103230	New	5.5	MEDI				A vulnerability was determined in AdithyaYelloju Restaurant-Management-System up to 7f0e7e84255e8fcfd488e83f8f91451bbbf6b9c. Impacted is the function mysqli_query of the file User/ord.php of the component Order Placement. Executing a manipulation of the argument id/name can lead to sql injection. The attack can be launched remotely. The exploit has been publicly disclosed a...
CVE-2026-103232	New	5.5	MEDI				A weakness has been identified in AdithyaYelloju Restaurant-Management-System up to 7f0e7e84255e8fcfd488e83f8f91451bbbf6b9c. This affects the function mysqli_query of the file admin/table_booking.php. This manipulation of the argument Name causes sql injection. Remote exploitation of the attack is possible. The exploit has been made available to the public and could be used...
CVE-2026-103531	New	5.5	MEDI				A flaw has been found in OpenSC up to 0.27.1. The impacted element is the function setcos_construct_fci_44 of the file src/libopensc/card-setcos.c. Executing a manipulation of the argument type_attr can lead to stack-based buffer overflow. The attack can be launched remotely. This patch is called ad730304052937c32b4eb489a06835ac6123632c. It is best practice to apply a patch ...
CVE-2026-103641	New	5.5	MEDI				A flaw was found in GEGL. The Radiance HDR loader reads past the end of a memory-mapped image when an uncompressed scanline is shorter than the width declared in the file header. Opening a crafted HDR file crashes the application that uses the loader.
CVE-2026-47492	New	5.5	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer, where an attacker can cause improper access control. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47506	New	5.5	MEDI				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel-mode color transform path where excessive kernel stack use occurs when evaluating YCbCr420 display emulation. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47517	New	5.5	MEDI				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode driver where a local user may cause a null pointer dereference by submitting a crafted ioctl. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47534	New	5.5	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause a divide by zero. A successful exploit of this vulnerability might lead to denial of service.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-47549	New	5.5	MEDI				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel module where an unprivileged local user could cause a NULL pointer dereference. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47555	New	5.5	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where a user could cause uninitialized kernel memory to be copied back to userspace. A successful exploit of this vulnerability might lead to information disclosure.
CVE-2026-47557	New	5.5	MEDI				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an unprivileged user could cause a NULL pointer dereference. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47566	New	5.5	MEDI				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where an unprivileged user could cause a memory leak in error paths leading to kernel memory exhaustion. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47567	New	5.5	MEDI				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer, where a user could cause uncontrolled resource consumption by exhausting the DRM VMA offset address space. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47568	New	5.5	MEDI				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where a user could cause uncontrolled kernel log generation by repeatedly invoking an interface that emits unrate-limited error messages. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47581	New	5.5	MEDI				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel module where a user could cause improper locking. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47584	New	5.5	MEDI				NVIDIA GPU Display Driver for Windows contains a vulnerability in the kernel module where an attacker with local access could cause a NULL pointer dereference. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47603	New	5.5	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode driver where a local user may access another process's GPU channel state due to missing authorization checks. A successful exploit of this vulnerability might lead to information disclosure.
CVE-2026-47604	New	5.5	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode driver where a local user may access another process's GPU channel state due to missing authorization checks. A successful exploit of this vulnerability might lead to information disclosure.
CVE-2026-97238	New	5.5	MEDI				Subscriber Cross Site Scripting (XSS) in JetEngine <= 3.8.14.3 versions.
CVE-2026-100261	New	5.4	MEDI				In JetBrains YouTrack before 2026.2.18991 changing article visibility settings was possible without update permission

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101883	New	5.4	MEDI				OpenClaw Windows Node through 2026.9.4 contains a server-side request forgery vulnerability in the canvas.present capability that bypasses URL risk evaluation enforced by canvas.navigate. Attackers with gateway or agent access can issue canvas.present to make the node's WebView send requests to localhost, private networks, or tailnet services from the user's machine.
CVE-2026-102134	New	5.4	MEDI				Kiteworks Core did not apply its gateway-level API security controls to every request authenticated through the platform's central authentication service. An authenticated user could reach REST API functionality over a request path on which those controls, including enforcement of signed-out and revoked sessions, were not applied.
CVE-2026-102399	New	5.4	MEDI				Unauthenticated Cross Site Request Forgery (CSRF) in Photo Gallery by Supsysic <= 1.21.0 versions.
CVE-2026-103539	New	5.4	MEDI				A weakness has been identified in ZongXR SuperMarket 1.0.0.0. This affects the function startBuy of the file instant-buy/src/main/java/com/supermarket/instantbuy/controller/InstantBuyController.java of the component Instant Buy. Executing a manipulation of the argument Username can lead to missing authentication. The attack may be performed from remote. The exploit has been ...
CVE-2026-103587	New	5.4	MEDI				QloApps through 1.7.0 contains a reflected cross-site scripting vulnerability in the back-office Hotel Reservation System Book Now search, where date_to and id_room_type parameters are copied into template variables without validation. Attackers can craft a malicious link containing JavaScript payload in these parameters that executes in an authenticated administrator's sess...
CVE-2026-103588	New	5.4	MEDI				QloApps through 1.7.0 contains a reflected cross-site scripting vulnerability in the exceptions field of the back-office Transplant a module form. Attackers can craft a malicious link containing JavaScript payload in the exceptions parameter that executes in an authenticated administrator's session when the victim follows the link.
CVE-2026-103589	New	5.4	MEDI				QloApps through 1.7.0 contains a reflected cross-site scripting vulnerability in the back-office room type editor that fails to escape room_num, floor, and comment field values in input attributes. Attackers can induce authenticated back-office users to submit crafted POST requests with malicious payloads to execute arbitrary JavaScript in the victim's administrative session.
CVE-2026-103590	New	5.4	MEDI				QloApps through 1.7.0 contains a reflected cross-site scripting vulnerability in the back-office room type editor's length of stay fields. Attackers can induce authenticated administrators to submit crafted POST requests with malicious payloads in restriction_min_los and restriction_max_los parameters, executing arbitrary JavaScript in the victim's administrative session.
CVE-2026-12241	New	5.4	MEDI				The Advanced Woo Labels – Product Labels & Badges for WooCommerce plugin for WordPress is vulnerable to unauthorized modification of data due to an improperly secure capability check on the 'save_meta_boxes' function in all versions up to, and including, 2.51. This makes it possible for authenticated attackers, with Contributor-level access and above, to create AWS labels th...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-13720	New	5.4	MEDI				An Editor can set file-provisioning metadata (the grafana.app/managedBy, grafana.app/managerId and grafana.app/sourcePath annotations) when creating a dashboard through the dashboard API, because these fields were stored without an authorization check. The dashboard then appears file-provisioned, and administrators can no longer update or delete it through Grafana. The impac...
CVE-2026-62081	New	5.4	MEDI				Contributor Insecure Direct Object References (IDOR) in Flexible PDF Coupons <= 1.14.11 versions.
CVE-2026-62083	New	5.4	MEDI				Subscriber Other Vulnerability Type in Creator LMS <= 1.2.19 versions.
CVE-2026-94173	New	5.4	MEDI				Contributor Insecure Direct Object References (IDOR) in Business Directory <= 6.4.27 versions.
CVE-2026-96450	New	5.4	MEDI				Contributor Cross Site Scripting (XSS) in pixfort Core < 4.3.3 versions.
CVE-2026-97243	New	5.4	MEDI				Subscriber Broken Access Control in AllAble Connector <= 0.13.4 versions.
CVE-2026-97285	New	5.4	MEDI				Contributor Broken Access Control in The Events Calendar <= 6.17.5 versions.
CVE-2026-97299	New	5.4	MEDI				Unauthenticated Cross Site Request Forgery (CSRF) in Razorpay Payment Links for WooCommerce <= 2.1.5 versions.
CVE-2026-100260	New	5.3	MEDI				In JetBrains YouTrack before 2026.2.18991 mailbox integration allowed authentication after a password reset
CVE-2026-100508	New	5.3	MEDI				Unauthenticated Denial of Service Attack in Two Factor <= 0.16.0 versions.
CVE-2026-102144	New	5.3	MEDI				A resource exhaustion vulnerability in Kiteworks Email Protection Gateway allowed an unauthenticated remote attacker to repeatedly trigger a comparatively expensive server-side operation, causing a partial denial of service.
CVE-2026-103241	New	5.3	MEDI				A flaw has been found in vllm-project vLLM up to 0.26.0. This vulnerability affects unknown code of the file rust/src/parser/src/unified/gemma4.rs of the component Gemma4UnifiedParser. Executing a manipulation can lead to denial of service. The attack may be launched remotely. The exploit has been published and may be used. Upgrading to version 0.29.1rc0 is able to resolve t...
CVE-2026-103396	New	5.3	MEDI				bbs-go through 4.4.6 contains a permission bypass vulnerability in the AdminMiddleware authorization logic where the read-only dashboard.user.view permission rule matches the /api/admin/user/synccount endpoint before the intended dashboard.user.update rule. Authenticated users with only view permissions can call the synccount endpoint to trigger expensive full-table user rec...
CVE-2026-103399	New	5.3	MEDI				A flaw was found in SoupServer (libsoup). When an HTTP/1.x client sends a request with Expect: 100-continue and a request body, and SoupServer returns an early final (non-1xx) response before the body is read, the server neither drains the declared body bytes nor closes the connection. On a keep-alive connection, those leftover bytes are interpreted as a subsequent HTTP requ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103476	New	5.3	MEDI				yii2-starter-kit through 4.2.0 fails to validate article publication status in the attachment-download endpoint, allowing unauthenticated attackers to download files from draft articles. Attackers can enumerate sequential attachment identifiers to retrieve files from unpublished articles without authentication or authorization checks.
CVE-2026-103532	New	5.3	MEDI				A vulnerability has been found in immich-app Immich up to 2.7.5. This affects the function checkSharedLinkAccess of the file server/src/utls/access.ts of the component Shared Link Preview Handler. The manipulation of the argument Password leads to improper authorization. The attack may be initiated remotely. The reported GitHub issue was closed with the label "duplicate".
CVE-2026-103548	New	5.3	MEDI				Improperly stored passwords in the config file in Itron MV-90 xi 3.0 allows attackers to decode the passwords and password histories to gain access to the MV-90 application as any user.
CVE-2026-86778	New	5.3	MEDI				Observable response discrepancy vulnerability in Maksisoft Technology, IT, and Software Industry and Trade Inc. Maksisoft Gym allows Account Footprinting. This issue affects Maksisoft Gym: from 0.5.10 before 0.5.11.
CVE-2026-92537	New	5.3	MEDI				The Newsletter – Send awesome emails from WordPress plugin for WordPress is vulnerable to Insufficiently Protected Credentials in all versions up to, and including, 9.3.9 The plugin's public click-tracking REST route `/tnp/l/` is registered with `permission_callback => '__return_true'` and, upon receiving a valid keyed-MD5 signature, calls `set_user_cookie()`, which emits a ...
CVE-2026-92548	New	5.3	MEDI				The WP Popular Posts plugin for WordPress is vulnerable to Sensitive Information Exposure in all versions up to, and including, 7.4.2 via the 'context' parameter. This makes it possible for unauthenticated attackers to extract sensitive edit-context fields — including raw title, raw content body, password, meta, status, and guid — from non-public post objects such as wp_bloc...
CVE-2026-92872	New	5.3	MEDI				Pgpool-II inserts sensitive information into log file, which may allow an authenticated attacker to obtain the cluster information.
CVE-2026-93547	New	5.3	MEDI				A missing authorization check in the Vaadin Spreadsheet component allows an authenticated user of an application that renders a spreadsheet to add or replace cell comments on a sheet that has protection enabled, including on cells that are locked. Writing a comment to a cell that does not exist yet also creates the row and the cell. Users of affected versions should apply ...
CVE-2026-94545	New	5.3	MEDI				Satori is a library to convert HTML and CSS to SVG. Starting in version 0.0.27 and prior to version 0.33.5, Satori does not properly escape certain values before including them in generated SVG output. This can allow crafted values to be interpreted as SVG markup. The impact depends on how the generated SVG is consumed. Version 0.33.5 contains a patch. No complete workaround...
CVE-2026-94673	New	5.3	MEDI				Unauthenticated Insecure Direct Object References (IDOR) in Simply Schedule Appointments <= 1.6.12.31 versions.
CVE-2026-97066	New	5.3	MEDI				Unauthenticated Insecure Direct Object References (IDOR) in GiveWP <= 4.16.9 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97078	New	5.3	MEDI				Unauthenticated Insecure Direct Object References (IDOR) in Client Invoicing by Sprout Invoices <= 20.8.17 versions.
CVE-2026-97249	New	5.3	MEDI				Unauthenticated Bypass Vulnerability in Paid Member Subscriptions <= 3.0.9 versions.
CVE-2026-97259	New	5.3	MEDI				Authorization Bypass Through User-Controlled Key vulnerability in WP Hosting AS Pay with Vipps for WooCommerce allows Exploiting Incorrectly Configured Access Control Security Levels. This issue affects Pay with Vipps for WooCommerce: from n/a through 6.2.4.
CVE-2026-97261	New	5.3	MEDI				Unauthenticated Sensitive Data Exposure in Notivo <= 1.4.2 versions.
CVE-2026-97282	New	5.3	MEDI				Unauthenticated Insecure Direct Object References (IDOR) in Review Schema <= 3.1.0 versions.
CVE-2026-97302	New	5.3	MEDI				Unauthenticated Sensitive Data Exposure in MPG <= 4.2.3 versions.
CVE-2026-102459	New	5.1	MEDI				EasyFlow .NET developed by Digiwin has a Reflected Cross-site Scripting vulnerability. Unauthenticated remote attackers can execute arbitrary JavaScript codes in user's browser through phishing attacks.
CVE-2026-93460	New	5.1	MEDI				A stored cross-site scripting vulnerability via appended strings in email form fields exists in baserCMS. If this vulnerability is exploited, an arbitrary script may be executed in the user's web browser.
CVE-2026-93463	New	5.1	MEDI				Cross-Site Scripting via Script Validation Bypass exists in baserCMS. If this vulnerability is exploited, an arbitrary script may be executed in the user's web browser may be caused.
CVE-2026-93464	New	5.1	MEDI				A stored cross-site scripting vulnerability via custom content descriptions exists in baserCMS. If this vulnerability is exploited, an arbitrary script may be executed in the user's web browser.
CVE-2026-100272	New	4.9	MEDI				In JetBrains YouTrack before 2026.2.19197 missing authorisation in the notification template preview allowed Project Administrators to read restricted issues
CVE-2026-100278	New	4.9	MEDI				In JetBrains YouTrack before 2026.2.19197 users with restricted permission could edit and hide other users' comments
CVE-2026-102111	New	4.9	MEDI				Kiteworks did not enforce the maximum permitted value for a configurable security-policy setting. An authenticated administrator could set this value outside its intended range so that the associated control never activated, while the control continued to appear enabled in the administrative interface and audit log, allowing it to be silently rendered ineffective.
CVE-2026-102140	New	4.9	MEDI				An authenticated administrator could initiate an administrative import using a file whose contents were not fully verified, because the import validated only the file's header rather than the complete file. This could allow unverified or forged content to be accepted and processed, affecting the integrity of the imported data.
CVE-2026-97246	New	4.9	MEDI				Subscriber PHP Object Injection in ShortPixel Image Optimizer <= 6.5.5 versions.
CVE-2026-100265	New	4.8	MEDI				In JetBrains Rider before 2026.2.1 al Assistant could auto-update third-party skills without user confirmation

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-92899	New	4.8	MEDI				Apache WSS4J remembers the Nonce of each UsernameToken it accepts, so a captured token cannot be reused. It stored the Nonce as raw base64 text, but authentication decodes that text and uses the bytes.The same bytes can be written as base64 in several ways. An attacker who captured an authenticated request could re-send it with a space added to the Nonce: the password digest...
CVE-2026-100263	New	4.7	MEDI				In JetBrains YouTrack before 2026.2.18991 stored HTML injection via the User-Agent header was possible
CVE-2026-102107	New	4.6	MEDI				Kiteworks Core contains a business logic flaw in a Kiteworks file-request feature allowed an authenticated user to send a request that appeared to originate from another user, because the server did not verify that the requester was authorized to act as the specified account. This could be used to solicit files or information from a recipient under a trusted identity; exploi...
CVE-2026-102581	New	4.6	MEDI				A flaw was found in Moodle. Insufficient output escaping in templates used to display forum posts enables a stored cross-site scripting (XSS) vulnerability. An attacker can inject malicious content into a forum post, which then executes arbitrary script code in the browser of another user viewing the affected post.
CVE-2026-47526	New	4.4	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the firmware where an attacker could cause a null pointer dereference. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47531	New	4.4	MEDI				NVIDIA GPU Display Driver for Windows and Linux contains a vulnerability in the kernel mode layer where an attacker could cause a null pointer dereference. A successful exploit of this vulnerability might lead to denial of service.
CVE-2026-47562	New	4.4	MEDI				NVIDIA GPU Display Driver for Linux contains a vulnerability in the kernel mode layer where a user could inject crafted text into the kernel log because the supplied version string is not properly sanitized. A successful exploit of this vulnerability might lead to denial of service and data tampering.
CVE-2026-100257	New	4.3	MEDI				In JetBrains YouTrack before 2026.2.18991 sSRF via stored XHTML injection was possible during PDF export
CVE-2026-100258	New	4.3	MEDI				In JetBrains YouTrack before 2026.2.18991 missing authorisation allowed read-only users to read project settings
CVE-2026-100259	New	4.3	MEDI				In JetBrains YouTrack before 2026.2.18991 improper access control on Gantt chart allowed edits by users with view-only access
CVE-2026-100269	New	4.3	MEDI				In JetBrains YouTrack before 2026.2.19197 helpdesk project's Authorized Reporters list could be bypassed
CVE-2026-102090	New	4.3	MEDI				Kiteworks Core before version 9.5.1 is vulnerable to Content Injection. A URL parameter in the PDF viewer was insufficiently validated, allowing an attacker-controlled document to be loaded and displayed under the trust of the legitimate application domain. This could increase the credibility of phishing attempts relying on malicious links embedded in the displayed content.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102122	New	4.3	MEDI				Kiteworks did not correctly enforce which roles a shared folder's manager was permitted to assign. In a default configuration, an authenticated user holding the Manager role on a folder could grant the Owner role to themselves or to other members of that folder.
CVE-2026-102577	New	4.3	MEDI				A flaw was found in Moodle. Incorrect handling of IPv4-mapped IPv6 addresses within the URL downloader's host-blocking logic allows an authenticated remote user to bypass blocked-host restrictions. By supplying a crafted URL, an attacker can induce the server to make requests to restricted destinations, leading to Server-Side Request Forgery (SSRF).
CVE-2026-102579	New	4.3	MEDI				A flaw was found in Moodle. An incorrect capability check in the grade web service allows an authenticated student to access profile information of other students enrolled in the same course that they should not have permission to view. This issue leads to unauthorized information disclosure.
CVE-2026-102584	New	4.3	MEDI				A flaw was found in Moodle. Due to a missing capability check, a low-privileged authenticated user can trigger the recalculation of grade penalties without holding the required permissions. This issue allows unauthorized users to modify grade penalty records, potentially altering student assessment scores.
CVE-2026-102585	New	4.3	MEDI				A flaw was found in Moodle. When enrolling a user into a course while assigning them to a group, the application does not verify whether the selected group actually belongs to that course. An authenticated user with teacher privileges could exploit this flaw to add users to groups within courses they do not have authorization to access.
CVE-2026-102586	New	4.3	MEDI				A flaw was found in Moodle. Insufficient sanitization of username input on the password reset page allows a remote attacker to conduct a cross-site scripting (XSS) attack. By convincing an unauthenticated user to access a specially crafted password reset link, an attacker could execute arbitrary script in the victim's browser.
CVE-2026-103118	New	4.3	MEDI				A vulnerability was detected in GraphicsMagick up to 1.3.47. Affected by this vulnerability is the function ExtractPostscript of the file coders/wpg.c of the component WPG File Handler. Performing a manipulation results in uncontrolled recursion. The attack may be initiated remotely. The patch is named 627b5b1b2fc2. It is suggested to install a patch to address this issue. T...
CVE-2026-103387	New	4.3	MEDI				A weakness has been identified in garycourt uri-js up to 4.4.1. This affects the function URI.parse of the file src/schemes/mailto.ts of the component Mailto Header Handler. This manipulation of the argument to causes uncaught exception. The attack may be initiated remotely. The exploit has been made available to the public and could be used for attacks. The project was info...
CVE-2026-103542	New	4.3	MEDI				A flaw has been found in formtools.org Form Tools up to 3.1.1. Impacted is the function smart_fill of the file /global/code/actions.php of the component AJAX Endpoint. This manipulation of the argument url causes server-side request forgery. The attack can be initiated remotely. The exploit has been published and may be used. The project was informed of the problem early thr...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-13719	New	4.3	MEDI				An authenticated user can list alert rules stored in folders they are not allowed to read through the alert rules API list endpoint. When the set of folders the user may read was empty, the folder restriction was dropped and every alert rule in the organization was returned. From Grafana 13.1.0, any user can trigger this with a folder filter. The exposed data is rule configu...
CVE-2026-88999	New	4.3	MEDI				The Redux Framework plugin for WordPress is vulnerable to authorization bypass in all versions up to, and including, 4.5.14 This is due to the plugin not properly verifying that a user is authorized to perform an action. This makes it possible for authenticated attackers, with subscriber-level access and above, to delete arbitrary media library attachments, including adminis...
CVE-2026-94672	New	4.3	MEDI				Contributor Insecure Direct Object References (IDOR) in Safe SVG <= 2.5.0 versions.
CVE-2026-97074	New	4.3	MEDI				Subscriber Insecure Direct Object References (IDOR) in Newsletters, Email Marketing, SMS and Popups by Omnisend <= 1.9.0 versions.
CVE-2026-97079	New	4.3	MEDI				Subscriber Insecure Direct Object References (IDOR) in Webba Booking <= 6.5.0 versions.
CVE-2026-97267	New	4.3	MEDI				Subscriber Broken Access Control in Prevent files / folders access <= 2.6.7 versions.
CVE-2026-96825	New	4.2	MEDI				Subscriber Bypass Vulnerability in All In One WP Security & Firewall <= 5.4.8 versions.
CVE-2026-102137	New	4.1	MEDI				An authenticated administrator could bypass the content validation applied to an administrative file upload and store a file containing dangerous content on the appliance. This did not by itself result in code execution, which would require a separate vulnerability to run the stored file.
CVE-2026-103533	New	4.1	MEDI				A vulnerability was found in David-Crty databasement up to 1.7.1. This impacts the function https://github.com/David-Crty/databasement/pull/511 of the file <code>app/Http/Requests/Api/V1/RestoreRequest.php</code> of the component database-servers API Endpoint. The manipulation of the argument <code>schema_name</code> results in path traversal. The attack may be launched remotely. A high complexity lev...
CVE-2026-103436	New	3.7	LOW				apcupsd through 3.14.14 discloses uninitialized stack memory in <code>getupsvar()</code> in <code>src/cgi/upsfetch.c</code> (used by <code>upsstats.cgi</code> , <code>multimon.cgi</code> , and <code>upsfstats.cgi</code> . On the single-field path, when the matched STATUS line has fewer than three whitespace-separated tokens, <code>sscanf("%s %s %s", answer)</code> performs no assignment but the function returns success, and thus the caller prints the u...
CVE-2026-101887	New	3.5	LOW				BlueALSA (bluez-alsa/bluealsad) contains a division-by-zero vulnerability in the LC3plus sink decoder (<code>a2dp_lc3plus.c</code> , <code>a2dp_lc3plus_dec_thread</code>) that allows a Bluetooth-adjacent attacker to crash the daemon by sending a crafted RTP media header with an attacker-controlled frame count field set to zero. Attackers can establish an A2DP source connection with an LC3plus session ...
CVE-2026-100270	New	3.3	LOW				In JetBrains YouTrack before 2026.2.19197 low-level Admin Read permission users could disclose integration credentials via import configurations

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102138	New	3.3	LOW				An authenticated administrator on a node with an optional, separately licensed gateway role enabled could supply a connector URL that the server retrieved without sufficient validation of its scheme or destination, causing the server to issue requests to internal network services. Exploitation requires the licensed gateway role to be active.
CVE-2026-100280	New	3.1	LOW				In JetBrains YouTrack before 2026.2.19197 creating a project from an unreadable custom template was possible
CVE-2026-100264	New	2.7	LOW				In JetBrains YouTrack before 2026.2.18991 stored SMTP server credentials could be disclosed by changing the server host
CVE-2026-100271	New	2.7	LOW				In JetBrains YouTrack before 2026.2.19197 missing authorisation on several endpoints allowed authenticated users to access information from other projects
CVE-2026-102583	New	2.7	LOW				A flaw was found in Moodle. An incorrect capability check in the artificial intelligence (AI) editor placement's image generation web service allows an authenticated user to invoke the feature without holding the required capability. This flaw permits unauthorized users to access and utilize the AI image generation functionality.
CVE-2026-102587	New	2.7	LOW				A flaw was found in Moodle. User list filters do not properly enforce visibility restrictions on user profile fields. An authorized user with manager privileges can filter user lists using profile attributes they are not permitted to view directly, resulting in unauthorized information disclosure by inferring hidden user data.
CVE-2026-27085	New	2.7	LOW				Shop manager Content Injection in Astra WordPress Theme <= 4.13.12 versions.
CVE-2026-102580	New	2.2	LOW				A flaw was found in Moodle. An authenticated attacker can supply an improperly validated audience class name to the Report Builder component, allowing arbitrary class instantiation. This vulnerability enables the unauthorized creation of internal program objects, which may result in unexpected application behavior.
CVE-2026-102582	New	2.2	LOW				A flaw was found in Moodle. The manual enrolment management page did not properly check whether the manual enrolment plugin was disabled, allowing users with enrolment permissions to access the page directly by navigating to its URL. Consequently, an authorized user could manage manual enrolments even after an administrator disabled the feature in the user interface.
CVE-2026-103114	New	2.1	LOW				A vulnerability was identified in OS4ED openSIS-Classic up to 9.3. The impacted element is the function DBQuery_assignment of the file modules/grades/Assignments.php of the component Assignment Management Endpoint. The manipulation of the argument Tables leads to sql injection. It is possible to initiate the attack remotely. The exploit is publicly available and might be use...
CVE-2026-103116	New	2.1	LOW				A weakness has been identified in OS4ED openSIS-Classic up to 9.3. This impacts the function DBQuery of the file functions/GetStuListFnc.php of the component Student List Search Endpoint. This manipulation of the argument LO_sort causes sql injection. The attack can be initiated remotely. The exploit has been made available to the public and could be used for attacks. The pr...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103233	New	2.1	LOW				A security vulnerability has been detected in AdithyaYelloju Restaurant-Management-System up to 7f0e7e84255e8fcd488e83f8f91451bbbff6b9c. This impacts an unknown function of the file /admin/ of the component Admin Area. Such manipulation of the argument ID leads to authorization bypass. The attack can be executed remotely. The exploit has been disclosed publicly and may be u...
CVE-2026-103012	New	2.0	LOW				Claude Code selected an API key stored by Claude Code, for example from an earlier `/login` or written directly to its configuration, ahead of the user's valid Claude Enterprise or Team sign-in when fetching the organization's server-managed settings, even though the session itself authenticated with the Enterprise or Team account. When the settings endpoint rejected that st...
CVE-2026-103113	New	2.0	LOW				A vulnerability was determined in OS4ED openSIS-Classic up to 9.3. The affected element is the function save action of the file modules/students/Student.php of the component General Information Tab. Executing a manipulation of the argument students can lead to sql injection. The attack may be performed from remote. The exploit has been publicly disclosed and may be utilized....
CVE-2026-103117	New	2.0	LOW				A security vulnerability has been detected in OS4ED openSIS-Classic up to 9.3. Affected is the function db_properties of the file functions/Databaselnc.php of the component Save Data Handler. Such manipulation of the argument values leads to sql injection. The attack can be launched remotely. The exploit has been disclosed publicly and may be used. The project was informed o...
CVE-2026-76144	New	1.8	LOW				An unrestricted file upload vulnerability caused by insufficient file extension and integrity verification in Genian SSL PNS allows an attacker to upload a dangerous file that is not an official patch
CVE-2026-103440	New	1.2	LOW				Exposure of sensitive information through data queries vulnerability in The Wikimedia Foundation MediaWiki PageTriage extension allows Information Elicitation. This issue affects MediaWiki PageTriage extension: 1.46, 1.45, and 1.43.
CVE-2026-103445	New	1.2	LOW				Improper neutralization of Script-Related HTML tags in a web page (basic XSS) vulnerability in The Wikimedia Foundation MediaWiki Page_Forms extension allows Stored XSS. This issue affects MediaWiki Page_Forms extension: 1.46, 1.45, and 1.43.
CVE-2026-103585	New	1.2	LOW				Improper neutralization of Script-Related HTML tags in a web page (basic XSS) vulnerability in The Wikimedia Foundation MediaWiki MediaSearch extension allows Cross-Site Scripting (XSS). This issue affects MediaWiki MediaSearch extension: 1.46, 1.45, and 1.43.
CVE-2026-103437	New	1.1	LOW				Improper neutralization of Script-Related HTML tags in a web page (basic XSS) vulnerability in The Wikimedia Foundation MediaWiki ReadingLists extension allows Reflected XSS. This issue affects MediaWiki ReadingLists extension: 1.46 and 1.45.
CVE-2026-103443	New	1.1	LOW				Improper neutralization of Script-Related HTML tags in a web page (basic XSS) vulnerability in The Wikimedia Foundation MediaWiki Collection (Book) extension allows XSS Targeting Non-Script Elements. This issue affects MediaWiki Collection (Book) extension: 1.46, 1.45, and 1.43.
CVE-2026-103444	New	1.1	LOW				Improper neutralization of Script-Related HTML tags in a web page (basic XSS) vulnerability in The Wikimedia Foundation MediaWiki WikiForum extension allows Stored XSS. This issue affects MediaWiki WikiForum extension: master.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103584	New	1.1	LOW				Improper neutralization of Script-Related HTML tags in a web page (basic XSS) vulnerability in The Wikimedia Foundation MediaWiki CommonsMetadata extension allows Cross-Site Scripting (XSS). This issue affects MediaWiki CommonsMetadata extension: 1.46, 1.45, and 1.43.
CVE-2026-103438	New	0.3	LOW				Improper neutralization of Script-Related HTML tags in a web page (basic XSS) vulnerability in The Wikimedia Foundation MediaWiki Wikistories extension allows Cross-Site Scripting (XSS). This issue affects MediaWiki Wikistories extension: 1.46, 1.45, and 1.43.
CVE-2026-103439	New	0.3	LOW				Improper neutralization of Script-Related HTML tags in a web page (basic XSS) vulnerability in The Wikimedia Foundation MediaWiki Wikibase extension allows Cross-Site Scripting (XSS). This issue affects MediaWiki Wikibase extension: 1.46, 1.45, and 1.43.
CVE-2026-100689	New		MODE		0.004	PyPI:gitpython	**Affected:** `GitPython` **3.1.61** (latest release) and `main` — `git/objects/submodule/base.py`. `git diff 3.1.61 origin/main -- git/objects/submodule/` is empty, so both are identical here. --- ## The gap The fix for `GHSA-hmq2-w58f-27jc` added `Submodule._validated_name()` and wired it into `update()` and five siblings, closing the `.gitmodules` **name** → `.git/modu...
CVE-2026-101147	New						The Featured Image from URL (FIFU) WordPress plugin before 6.0.8, Featured Image from URL (FIFU) Premium WordPress plugin before 8.2.8 do not correctly enforce the REST API nonce, disabling the check for the whole request when a crafted URL is used, which could allow attackers to make a logged-in administrator perform any REST API action, such as creating a new administrator...
CVE-2026-101148	New						The BackupSheep WordPress Backup Plugin WordPress plugin through 1.8 does not properly validate its integration key, treating an unset or blank key as valid, which allows unauthenticated attackers to create and download full site backups, including the database with user password hashes, and to delete arbitrary files on the server, leading to sensitive data disclosure and si...
CVE-2026-101896	New		HIGH			npm:@angular/router	A denial of service (DoS) vulnerability was identified in `@angular/router` when Server-Side Rendering (SSR) is enabled on Node.js (V8). When `@angular/router` parses incoming request URLs, it extracts path segments, matrix parameters, and child outlets into plain JavaScript objects (`Record<string, string>`). When matrix parameter names or outlet names are numeric strings ...
CVE-2026-101898	New		HIGH		0.005	npm:axios	## Summary Axios for Node.js does not apply configured DNS lookup or proxy controls when a request uses `httpVersion: 2`. The HTTP/1 adapter path wraps and forwards `config.lookup`, builds normal request options, and applies proxy routing through `setProxy()`. The HTTP/2 path builds a session with `http2.connect()` using only `options.http2Options`, which drops the top-leve...
CVE-2026-101899	New		MODE			npm:axios	## Summary Axios supports proxy environment variables and evaluates `NO_PROXY` exclusions in the Node.js adapter. CIDR-form `NO_PROXY` entries such as `127.0.0.0/8`, `10.0.0.0/8`, or `169.254.169.254/32` are not interpreted as IP ranges. As a result, a request to an IP address inside a configured CIDR exclusion can still be sent through the configured proxy. This affects d...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101900	New		MODE		0.005	npm:axios	## Summary Axios contains a guard in the Node HTTP adapter to avoid using an inherited `Object.prototype.getHeaders` as a FormData header source. The fetch adapter calls the shared `resolveConfig()` helper before dispatch, and that helper lacks the same guard. If another vulnerability pollutes `Object.prototype` with FormData-like properties and `getHeaders()`, the fetch ad...
CVE-2026-101901	New		HIGH		0.004	npm:axios	## Summary Axios versions with Node.js HTTP/2 support can terminate the caller's process when a ClientHttp2Session emits an error event that is not handled by axios. This affects applications that use the Node HTTP adapter with httpVersion: 2. A malicious, unavailable, or non-HTTP/2 endpoint can cause an uncaught exception instead of a normal rejected axios request. ## Im...
CVE-2026-101902	New		MODE		0.004	npm:axios	## Summary Axios default-instance requests that omit an explicit method can read an inherited `method` value from `Object.prototype`. If another vulnerability in the same process pollutes `Object.prototype.method`, calls such as `axios.request({ url })` and `axios({ url })` can send a state-changing HTTP method instead of the expected default `GET`. Axios does not create t...
CVE-2026-101903	New		HIGH		0.004	npm:axios	## Summary Axios for Node.js parses `data:` URLs in `lib/helpers/formDataURL.js`. The current RFC-2397 parser uses a regular expression whose media type groups allow `/` inside both sides of the `type/subtype` match. A malformed `data:` URL containing many slashes and no comma forces the JavaScript regex engine to try many possible placements for the separator before failin...
CVE-2026-101904	New		MODE		0.004	npm:axios	## Summary Axios request interceptors may return a replacement config object. If an interceptor returns a plain object without an own `headers` property, `dispatchRequest()` later evaluates `config.headers` and can resolve an inherited `Object.prototype.headers` value. In a process where another vulnerability has polluted `Object.prototype.headers`, axios can send attacker-...
CVE-2026-101905	New		HIGH		0.003	npm:axios	## Summary Axios' Node HTTP adapter can act as a read-side prototype-pollution gadget for Node's sensitive `createConnection` request option. The adapter creates a null-prototype options object, but Node's HTTP client can copy or normalize request options into ordinary objects before connection creation. If `Object.prototype.createConnection` has been polluted elsewhere in ...
CVE-2026-101906	New		HIGH		0.004	npm:axios	## Summary Axios `shouldBypassProxy()` normalizes hostnames with `hostname.replace(/.+\$/, ")`. For a hostname shaped as many dots followed by a non-dot, the anchored regex can perform quadratic backtracking. Because axios re-evaluates proxy bypass rules for redirected requests, a malicious server can trigger this synchronous work through a crafted redirect `Location`. Th...
CVE-2026-101907	New		HIGH		0.004	npm:axios	## Summary Axios exposes `maxRedirects` to limit redirect following, and `maxRedirects: 0` is used by applications as a redirect-based SSRF guard. The Node HTTP adapter enforces this option. The fetch adapter does not read it and does not set a Fetch API `redirect` mode, so the runtime default of `redirect: 'follow'` applies. Applications are affected when they rely on `ma...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-101908	New		MODE		0.004	npm:axios	## Summary Axios fetch adapter requests can be altered by inherited properties on `fetchOptions`. The adapter resolves method, headers, body, signal, and credentials into `resolvedOptions`, creates a `Request`, and then calls `fetch(request, fetchOptions)` instead of `fetch(request, resolvedOptions)`. In runtimes such as Node's undici-backed fetch, inherited `fetchOptions.h...
CVE-2026-101909	New		HIGH		0.004	npm:axios	## Summary Axios form serialization reads `visitor`, `maxDepth`, `dots`, `indexes`, `metaTokens`, and `Blob` from an internal options object without own-property guards. When `Object.prototype` has been polluted elsewhere in the same process, those inherited values can change how axios serializes multipart and URL-encoded request bodies. Axios does not create the prototype...
CVE-2026-101915	New		LOW		0.003	npm:@grpc/grpc-js	### Impact If an application method handler crashes, the error message is included in the status message sent to the client. This can leak to the client any sensitive data that may be included in the error message. This impacts anyone using `@grpc/grpc-js` to run servers. ### Patches This vulnerability is fixed in 1.13.6 and 1.14.5. ### Workarounds This can be avoided by u...
CVE-2026-101916	New		HIGH		0.002	npm:@grpc/grpc-js	### Impact When server credentials are created with the `requireClientCertificate` option set to `false`, `getAuthContext` does not distinguish between authorized and unauthorized certificates in its return value. This can create improper authentication vulnerabilities for `@grpc/grpc-js` users who use the result of `getAuthContext` for authentication. In particular, `@grpc...
CVE-2026-101918	New		MODE		0.003	PyPI:pyjwt	## Summary `PyJWKClient.get_signing_key_from_jwt(token)` — the first step of the JWKS verification flow documented in `docs/usage.rst` — must decode a token's payload before its signature can be checked, via `jwt.api_jwt.decode_complete(token, options={"verify_signature": False})`. That call parses the payload with `json.loads` in `PyJWT._decode_payload` (`jwt/api_jwt.py:29...
CVE-2026-102270	New		MODE		0.002	PyPI:pyjwt	### Summary There is a Re-DoS vulnerability in the `is_pem_format` function which results in a intensive CPU usage if an attacker is been able to provide a custom certificate. ### Details The problem is that the lazy quantifier `.+?` will always first try to match as little as possible until it finds a `---- END`. Normally this means the complexity of this should be O(N). H...
CVE-2026-103500	New						An attacker could cause a heap buffer overflow by getting a user to open an email that is greater than or equal to 2GB in size. This vulnerability was fixed in Thunderbird 157, Thunderbird 140.17, and Thunderbird 153.4.
CVE-2026-19253	New						The Cache Enabler WordPress plugin before 1.8.17 does not validate a URL before using it to build a filesystem path in its cache purge routine, and does not confine the resulting deletion to the cache directory, allowing unauthenticated users to delete arbitrary files and directories on sites where another installed Cache Enabler WordPress plugin before 1.8.17 or passes a r...
CVE-2026-51852	New						agent-zero 1.7, 1.8, 1.9, and 1.10 is vulnerable to Directory Traversal in python/helpers/file_browser.py:FileBrowser.save_file_b64. The save_file_b64 method accepts user-controlled file paths without normalization or validation, allowing path traversal attacks.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-51853	New						agent-zero 1.7, 1.8, 1.9, and 1.10 is vulnerable to Directory Traversal in python/helpers/file_browser.py:FileBrowser.__init__. The FileBrowser class initializes with the host root directory as the workspace, allowing the agent to access any file on the system without restriction.
CVE-2026-51856	New						In agentscope 1.0.18, 1.0.19, and 1.0.19 when the RealtimeAgent session exposes execute_python_code as an available tool, a remote WebSocket user can prompt the agent to call that tool and run Python code in the service environment. In the validated path, RealtimeAgent._acting forwards the model-produced tool call to Toolkit.call_tool_function, which invokes execute_python_c...
CVE-2026-51857	New						In camel-ai camel 0.2.91a1, v0.2.91a2 and v0.2.91a3, CodeExecutionToolkit can run model-produced Python code through SubprocessInterpreter without an approval boundary.
CVE-2026-51858	New						In camel-ai camel 0.2.91a1, v0.2.91a2 and v0.2.91a3, TerminalToolkit.shell_exec allows prompt-driven shell command execution without an approval boundary.
CVE-2026-51859	New						bisheng 2.3.0, 2.4.0, and 2.4.0-beta1 is vulnerable to directory traversal in save_download_file (src/backend/bisheng/core/cache/utils.py:290).
CVE-2026-51860	New						bisheng 2.3.0, 2.4.0, and 2.4.0-beta1 is vulnerable to Directory Traversal in src/backend/bisheng/linsight/domain/task_exec.py.
CVE-2026-51861	New						bisheng 2.3.0, 2.4.0, and 2.4.0-beta1 is vulnerable to Code Injection in src/backend/bisheng/api/v1/validate.py.
CVE-2026-51862	New						DB-GPT 0.8.0 contains directory traversal in skill_upload (packages/dbgpt-app/src/dbgpt_app/openapi/api_v1/agentlic_data_api.py:40). A remote attacker can use the validated exploitation path to write files outside the intended workspace or storage boundary.
CVE-2026-51864	New						DB-GPT v0.7.5 and v0.8.0 contains directory traversal in python_file_upload (packages/dbgpt-app/src/dbgpt_app/openapi/api_v1/python_upload_api.py:42). A remote attacker can use the validated exploitation path to write files outside the intended workspace or storage boundary.
CVE-2026-51866	New						In DB-GPT 0.7.5 and 0.8.0, a skill uploaded through the real /api/v1/skills/upload route can later be executed through the real /api/v1/chat/react-agent flow.
CVE-2026-51867	New						agentgpt v.1.0.0 is vulnerable to Incorrect Access Control in next/src/server/api/routers/agentRouter.ts. An externally reachable path accepts a caller-selected object or tenant identifier and reaches a data-access operation without a visible owner, tenant, workspace, or membership binding on that object.
CVE-2026-51869	New						DB-GPT v0.8.0 sandbox API silently falls back to LocalRuntime and executes code on host.
CVE-2026-51870	New						DeepTutor v1.4.0 is vulnerable to command execution in /tutorbot/agent/tools/shell.py:ExecTool.execute.
CVE-2026-51871	New						Devika v1.0 is vulnerable to Code Injection in the Runner.execute function in src/agents/runner/runner.py which allows an attacker to achieve arbitrary code execution by exploiting the direct execution of LLM-generated content.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-51872	New						Devika v1.0 is vulnerable to Code Injection via the Runner.run_code function in src/agents/runner/runner.py.
CVE-2026-76169	New		HIGH		0.005	npm:fastify	### Impact Fastify routes a malformed URL under one plugin prefix to the custom not-found handler of a different sibling plugin, invoking the handler registered last and skipping the `preHandler` declared in its `setNotFoundHandler()`. When the request method has no route in the main router, a malformed request target reaches Fastify's internal not-found router before URL d...
CVE-2026-80490	New						Algorithm::AhoCorasick::XS versions through 0.04 for Perl read the haystack string length before the scalar is stringified. The matches, first_match and match_details methods use the T_STD_STRING typemap to translate Perl scalars (SVs) into strings via the std::string constructor, using the SvPV macro to stringify the haystack input, and the SvCUR macro to determine the len...
CVE-2026-81739	New						The Paytm Payment Gateway WordPress plugin before 2.8.9 does not sanitize and escape data it stores from payment callbacks before outputting it in an admin page, and the integrity check on those callbacks can be forged when the gateway is enabled without credentials, allowing unauthenticated users to store scripts that will run in the session of a store administrator.
CVE-2026-81809	New						The Paytm Payment Gateway WordPress plugin before 2.8.9 does not properly escape data taken from payment callbacks before using it in a SQL statement, and the integrity check on those callbacks can be forged when the gateway is enabled without credentials, allowing unauthenticated users to perform SQL injection attacks.
CVE-2026-84377	New		MODE		0.005	PyPI:litellm	### Impact Any authenticated LiteLLM proxy user could redirect an outbound provider call to a destination they control and cause the proxy to send its own configured provider credentials to that destination. The proxy's request-body validation was a denylist that did not cover every sensitive parameter and did not inspect parameters nested inside other request fields, so a ...
CVE-2026-84428	New		HIGH		0.005	npm:fastify	### Impact Fastify lowercases header-schema property names before compiling the schema, because Node.js stores request header names in lowercase. That normalization was incomplete: it lowercased only top-level `properties` keys and the root `required` array, and did not lowercase the JSON Schema Draft 7 `dependencies` keyword (its trigger keys and dependent property names) ...
CVE-2026-84469	New		HIGH		0.005	npm:fastify	### Impact Fastify decided whether to validate a request part by checking its schema for JavaScript truthiness. JSON Schema Draft 7 defines the boolean `false` as a valid schema that rejects every instance, but because `false` is falsy, a route that set `body`, `querystring`, `params`, or `headers` to `false` had that part left uncompiled: no validator was attached and the ...
CVE-2026-84504	New		HIGH		0.004	npm:fastify	### Impact Fastify runs a route's validator and, for a result shaped like `{ value, error }`, unwraps it: an `error` becomes a validation failure and `value` replaces the request part. This convention is intended for synchronous custom compilers (for example Joi). A JSON Schema `\$async` validator, however, resolves with the validated data itself, so Fastify applied the same...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-86610	New						The Download Manager WordPress plugin before 3.3.71 does not sufficiently sanitise and escape a package setting before outputting it back in a page, which could allow users with the Author role and above to perform Stored Cross-Site Scripting attacks against any visitor who opens the package's download dialogue, including administrators. Only sites running PHP below 8.1 are ...
CVE-2026-87817	New		HIGH		0.004	PyPI:gitpython	### Summary `Repo.__init__` decides which directory is the git directory by testing candidate paths in an order that considers the real `.git` **last**. Two earlier tests can be satisfied by ordinary tracked files. Git reserves only the literal name `.git`, so `HEAD`, `objects/`, `refs/`, `config`, `gitdir`, `commondir` and `hooks/` at a repository root are all legal tracks...
CVE-2026-87818	New		MODE		0.004	PyPI:gitpython	### Summary GitPython 3.1.59 blocks a previously available local-file read path through unsafe git diff options such as -O/--orderfile. However, the high-level diff API still permits --no-index with the default allow_unsafe_options=False. --no-index changes the semantics of the paths arguments: instead of repository-relative pathspecs, Git interprets them as arbitrary fil...
CVE-2026-87819	New		HIGH		0.005	PyPI:gitpython	### Summary GitPython's `Actor.name_email_regex` regular expression (`git/util.py`, line 863) is vulnerable to catastrophic backtracking (ReDoS — Regular Expression Denial of Service). When GitPython parses the `author` or `committer` header of a git commit object that contains a long string with an unterminated `<` (no matching `>`), the Python regex engine enters quadrati...
CVE-2026-87970	New						The If-So Dynamic Content WordPress plugin before 1.10.2 does not escape a request-supplied value before reflecting it in an unauthenticated AJAX response that is served as HTML, allowing attackers to execute arbitrary JavaScript in the browser of a visitor who opens a crafted link.
CVE-2026-87973	New						The If-So Dynamic Content WordPress plugin before 1.10.2 does not sanitize a conversion name before storing it, nor escape it when rendering the analytics page, allowing users with editor-level access to store JavaScript that executes in the session of a higher-privileged user who views that page.
CVE-2026-89296	New						The Pro Like Button WordPress plugin before 2.0 does not properly sanitize and escape a parameter before using it in a SQL query, allowing unauthenticated users to perform SQL injection attacks.
CVE-2026-90776	New		HIGH		0.007	npm:nodemailer	### Summary `nodemailer/lib/addressparser` parses one shape of address in O(n^2) time. A single ~640 KB address value blocks the Node.js event loop for roughly 7 seconds. And it is reachable without auth: mailparser feeds inbound email headers straight into this parser, so one crafted email is enough to stall a service that parses mail. ### Details The parser builds a sin...
CVE-2026-90972	New						The WP Fusion Lite WordPress plugin before 3.48.0 does not perform a capability check on two of its admin AJAX handlers, allowing any authenticated subscriber to read other users' email addresses and to trigger a cross-user CRM re-sync.
CVE-2026-90974	New						The WP Fusion Lite WordPress plugin before 3.48.0 does not require authentication on a settings handler that runs during admin initialization, allowing unauthenticated users to overwrite the site's CRM integration endpoint and credentials, after which synced user data is delivered to an attacker-chosen host.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-91776	New		HIGH		0.004	Maven:com.fasterxml.jackson.core:jackson-databind, Maven:tools.jackson.core:jackson-databind	### Summary With `@JsonTypeInfo(use = Id.NAME, defaultImpl = ...)` , every distinct unknown raw type ID selects the same fallback deserializer but is retained as a separate key in `TypeDeserializerBase._deserializers` . An attacker who can repeatedly supply new unknown type IDs can grow this process-lifetime cache without a configured bound. ### Details The affected path is...
CVE-2026-91777	New		HIGH		0.004	Maven:com.fasterxml.jackson.core:jackson-databind, Maven:tools.jackson.core:jackson-databind	### Summary When an `@JsonIdentityInfo` collection or map first creates N unresolved object-ID references and later resolves the same IDs in reverse order, jackson-databind scans the remaining pending-reference accumulator for each resolution. A shallow JSON document whose size grows linearly can therefore cause quadratic CPU work during deserialization. ### Details The a...
CVE-2026-92081	New		MODE		0.004	npm:fastify	### Impact `fastify` crashes with an uncaught `ERR_HTTP2_INVALID_CONNECTION_HEADERS` exception when a route that registers a response trailer via `reply.trailer()` is served over HTTP/2. Fastify unconditionally adds the `Transfer-Encoding: chunked` header when a trailer is set, which is forbidden on HTTP/2, so Node.js throws while serializing the response headers. The excep...
CVE-2026-92172	New						Prior to v66.0.0.733.524 of Meta Horizon OS, OVRMediaService could be induced to send a privileged PendingIntent including a com.oculus.horizon CallerIdentity to an arbitrary application registering for com.oculus.systemactivities.SCREENSHOT via a broadcast receiver. That would allow the application to impersonate the com.oculus.horizon package towards any endpoint within th...
CVE-2026-92173	New						Prior to v74.0.0.878.1682 of Meta Horizon OS, MediaSyncJobReceiver could be induced to send a privileged PendingIntent including a com.oculus.vrshell CallerIdentity to an arbitrary application listening via NotificationListenerService. That would allow the application to impersonate the com.oculus.vrshell package, as well as packages signed with the same key, towards any end...
CVE-2026-92412	New						The Five Star Restaurant Reviews WordPress plugin before 2.3.14 does not properly escape a user-supplied value before outputting it into an HTML tag, allowing unauthenticated attackers to inject arbitrary web script that runs in the browser of anyone tricked into submitting a crafted request, including a logged-in administrator.
CVE-2026-93981	New		MODE		0.002	npm:hono	### Summary `hono/jsx` does not HTML-escape a plain string placed directly as a child or `fallback` of `Suspense` or `ErrorBoundary` , as the only child of a `Context.Provider` , or as the root value of `renderToString()` / `renderToReadableStream()` from `hono/jsx/dom/server` . Such a string is emitted as markup instead of text. ### Details These paths stringify their input...
CVE-2026-96173	New						The Payments for Hubtel WordPress plugin before 1.0.2 does not verify that the requester is authorized to view an order before redirecting a public payment-callback request, allowing unauthenticated attackers to obtain the order key of an arbitrary order and view its contents.
CVE-2026-96200	New						The Payments for Hubtel WordPress plugin before 1.0.2 does not verify that payment notifications received by its payment callback come from the payment provider, allowing unauthenticated attackers to mark arbitrary orders as paid without payment.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-96255	New						The Payments for Hubtel WordPress plugin before 1.0.2 does not prevent public access to a debug log in which it records payment requests, including the store's payment gateway API credentials in plain text, allowing unauthenticated attackers to obtain those credentials.
GHSA-3hv7-mjh2-fv65	New		MODE			PyPI:tornado	## Summary `HTTPServerRequest.__init__` in `tornado/httputil.py` parses the URL query string via `parse_qs_bytes()` with no field-count limit — while the sibling POST-body parsing path (`parse_body_arguments`) received a `max_num_fields=1000` cap added earlier in this exact same release (v6.5.8, commit `8d6363ed`), explicitly to bound parsing cost for the identical underlying...
GHSA-96h4-vgxj-gvm2	New		MODE			npm:@nestjs/microservices	## Summary A peer that can open a TCP connection to a NestJS microservice using the built-in TCP transport can make the server process allocate memory without limit, on either side of the connection, until the process is killed by the OS or by its container memory limit. No authentication, no credentials, and no valid message are required. Applications are affected only if...
GHSA-9c5c-9qcx-q35q	New		HIGH			npm:@nestjs/platform-fastify	Field Value --- --- Ecosystem npm Package `@nestjs/platform-fastify` Affected versions `>= 12.0.0, < 12.0.2` and `< 11.2.4` Patched versions `12.0.2` and `11.2.4` (upgrade to `12.0.3` / `11.2.5`) ### Summary On the Fastify adapter, an HTTP request that uses an `**absolute-form request target**` (`GET http://host/path HTTP/1.1` instead of `...`
GHSA-c2m8-h5v5-343r	New		HIGH			PyPI:tornado	#### Summary StaticFileHandler allows an unauthenticated attacker to read arbitrary files from the server's filesystem by requesting a path that resolves to a symbolic link placed inside the static root directory. Any application that serves user-uploadable content, or whose static directory is populated by a build/deploy pipeline that creates symlinks (e.g. npm link, webpack...
GHSA-chx6-46f5-w4vp	New		HIGH			PyPI:tornado	An unbounded memory accumulation (decompression bomb) in `tornado.curl_httpclient.CurlAsyncHTTPClient` — the client-side sibling gap of CVE-2026-49855 — verified end-to-end on the 2026-08-15 master snapshot (`6.6.dev1`) and present unchanged in the latest release tag `v6.5.8` and on master (checked 2026-08-17). When a Tornado application configures the curl client (the docum...
GHSA-p98j-92pf-mc4p	New		LOW			npm:dompurify	## Summary In `IN_PLACE` mode DOMPurify sanitizes the caller's live DOM subtree directly. To close a known hazard (GHSA-55q2-fjhq-7xh7), the library neutralizes any node a hook detaches during sanitization by stripping its subtree's non-allow-listed attributes, but this neutralization is wired only into the `beforeSanitizeElements` and `uponSanitizeElement` hook sites. An `...
GHSA-vcvr-r3jv-pc5j	New		CRIT			npm:next	## Impact The Node.js `ImageResponse` implementation from `next/og` is affected by an upstream vulnerability. This can lead to remote code execution. Affected applications pass attacker-controlled values into SVG content, attributes, or styles during image generation: ``tsx import { ImageResponse } from 'next/og' export async function GET(request: Request) { const val...
MAL-2026-17339	New					npm:reactjs-risk	--- _-= Per source details. Do not edit below this line._= ## Source: amazon-inspector (0e58c82916c5199ef9e73a5d70f91d120312151eb5c28090d8bbf6dbf4117543) The package's preinstall lifecycle script collects host identity metadata from the installer machine — os.hostname(), the output of `whoami`/os.userInfo().username, and os.platform() — hex-encodes the values, and issues ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17340	New					npm:@astracode/bytes-new	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17341	New					npm:@badzz88/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17342	New					npm:@bellaxchuu/belbails	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17343	New					npm:@bellaxchuu/crystalred	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17344	New					npm:@bellaxchuu/familyxtrx	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17345	New					npm:@bellaxchuu/flowblue	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17346	New					npm:@bellaxchuu/privatebails	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17347	New					npm:@bellaxchuu/skyblue	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17348	New					npm:@bellaxchuu/teambails	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17349	New					npm:@bellaxchuu/velvetry	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17350	New					npm:@bellaxchuu/xtrxbailes	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17351	New					npm:@bottino/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17352	New					npm:@fhkryxv/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17353	New					npm:@fhkryxv/baileys-new	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17354	New					npm:@hanzofc/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17355	New					npm:@ikanngeming/ikannbail	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17356	New					npm:@ikyyjee/ikyksingle	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17357	New					npm:@ikyyjee/ikyysinggle	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17358	New					npm:@ikyyjee/ikyksingle	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17359	New					npm:@japofc/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17360	New					npm:@jojoxyz/condemnedforce-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17361	New					npm:@kanaraa/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17362	New					npm:@kelvdra/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17363	New					npm:@kxa/bails	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17364	New					npm:@lendkzn/xntaabail	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17365	New					npm:@lendxntaa/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17366	New					npm:@levvicode/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17367	New					npm:@mikudeveloper/grace	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17368	New					npm:@mivesensei/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17369	New					npm:@noxleyss/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17370	New					npm:@nyzzpedia/baileys-new	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17371	New					npm:@nyzzpediaa/baileys-new	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17372	New					npm:@ostyado/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17373	New					npm:@queenanya/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17374	New					npm:@rennpm/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17375	New					npm:@revizahoshii/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17376	New					npm:@revizahoshii/hoshino	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17377	New					npm:@saazkira/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17378	New					npm:@sairidev/baileys-new	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17379	New					npm:@sakataoffc/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17380	New					npm:@teamolduser/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17381	New					npm:@wanzlonely/bails4u	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17382	New					npm:@wenzyx1/bails	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17383	New					npm:@xatanccchii/velycxbail	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17384	New					npm:@xayz/baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17385	New					npm:albert-anitabaileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17386	New					npm:anuaja	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17387	New					npm:arsya-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17388	New					npm:baileys-xbats	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17389	New					npm:bungoma	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17390	New					npm:cantarella-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17391	New					npm:eliteprotech-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17392	New					npm:focashi	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17393	New					npm:ishumdz-bail	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17394	New					npm:kasabaileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17395	New					npm:keithbaileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17396	New					npm:kiyoramarkets	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17397	New					npm:levvleys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17398	New					npm:lilys-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17399	New					npm:monte-md-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17400	New					npm:my-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17401	New					npm:noverojs	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17402	New					npm:noxleyss	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17403	New					npm:noxxleys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17404	New					npm:saturn-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17405	New					npm:shadowmd	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17406	New					npm:spencer-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17407	New					npm:syncxbails	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17408	New					npm:whalibmob	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17409	New					npm:xvinleys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17410	New					npm:xzbails	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17411	New					npm:xzvbails	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-17412	New					npm:xzvexpzcbaily	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17413	New					npm:yonzoffic-baileys	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17414	New					npm:yonzofficial	This package is part of a large family (100+ identified as of September 2026) of near-identical forks of the Baileys WhatsApp Web library that inject a covert channel-subscription action into the WhatsApp socket layer. On connect, the injected code issues an authenticated `w:mex` FOLLOW query (query_id 7871414976211147) against one or more attacker-chosen WhatsApp Channel/Ne...
MAL-2026-17415	New					npm:com.epi.e2e_test	--- _-= Per source details. Do not edit below this line._= ## Source: amazon-inspector (5a0c1068af335818f2b9d905f2d39ebe594f84a6c63e470877692554bc95103b) package.json declares a preinstall script that runs index.js on npm install. index.js collects host identifiers (os.homedir(), os.hostname(), os.userInfo()).username, dns.getServers(), current working directory) along wit...
MAL-2026-17416	New					PyPI:friendly-greeting-tools	Versions 0.1.0 through 0.3.6 of friendly-greeting-tools disguise encoded Snowflake credential and data theft routines as a hello-world demo. In versions through 0.3.5, the default run_demo payload reads the Snowflake session token, connection configuration, dbt profiles, and pip configuration, then stages encrypted copies in /workspace using a hard-coded RSA public key; ever...
MAL-2026-17417	New					PyPI:beautifytext	beautifytext 1.0.3 imports beautifyText/_compat.py from its __init__.py and from a setup.py install hook. That module starts a detached background process that registers the host (hostname, user, OS, working directory) with https://bleodw.wisp.uno, then polls it for jobs to run shell commands or read and write files, and posts the results back. --- _-= Per source details. D...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94952	Updated - CVSS added	9.8	CRIT				A stack-based buffer overflow vulnerability exists in the web management interface of TOTOLINK N150RT (NTR150) firmware V3.4.0-B20201030. It is reachable through the route /boafm/formPortFw (port-forwarding configuration handler) and is triggered by the ip_subnet and fw_ip request parameters during the rule-addition flow.
CVE-2026-100758	Updated - CVSS added	9.6	CRIT				Sandbox escape in the DOM: Navigation component. This vulnerability was fixed in Firefox ESR 153.4, Thunderbird 157, Thunderbird 140.17, Thunderbird 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103056	Updated - CVSS changed (9.0 → 9.4)	9.4	CRIT				AiSOC versions 7.2.0 before 12.0.0 contain a command injection vulnerability in the actions service that builds CrowdStrike Real Time Response command strings by interpolating unescaped action parameters in crowdstrike_rtr.py and endpoint.py. Authenticated users can inject single quotes into file_path, path, script_name, or script_args parameters to break out of quoted argum...
CVE-2023-54400	Updated - CVSS changed (9.8 → 9.3)	9.3	CRIT				Fumasoft Fumeng Cloud contains a SQL injection vulnerability in the AjaxMethod.ashx endpoint that allows unauthenticated remote attackers to inject arbitrary SQL through the Name parameter of the getEmpByname action without any authentication. Attackers can exploit UNION-based SQL injection techniques against the Microsoft SQL Server backend to extract, disclose, and modify ...
CVE-2026-103040	Updated - CVSS changed (9.8 → 9.3)	9.3	CRIT				LightLLM through 1.2.0 contains a remote code execution vulnerability in the router profiler service when started with --enable_profiling flag. The service exposes an unauthenticated RPyC server with pickle deserialization enabled, allowing attackers to execute arbitrary code by sending crafted serialized objects to the profiler command queue.
CVE-2026-103041	Updated - CVSS changed (9.8 → 9.3)	9.3	CRIT				LightLLM through 1.2.0 multimodal deployments expose an unauthenticated RPyC cache service with pickle deserialization enabled on all interfaces. Attackers can send crafted serialized objects to exposed cache methods to execute arbitrary code with service privileges.
CVE-2026-101894	Updated - CVSS added	9.1	CRIT		0.008		The decompress package for Node.js extracts archives. Prior to 10.2.2 and 11.1.4, the default decompress(input, output) API relies on lexical containment checks that do not account for the kernel following a planted symlink chain. An attacker can supply a crafted archive containing chained symlink entries so that a later entry resolves outside the output directory. This allo...
CVE-2026-102268	Updated - CVSS added	9.1	CRIT		0.002		PyJWT is a Python implementation of JSON Web Token standards. Prior to 2.14.0, is_pem_format in jwt/utlis.py is affected because is_pem_format does not recognize every PEM representation accepted by the cryptography loader. This occurs when an application mixes HMAC and asymmetric algorithms and supplies a mutated public-key PEM as raw key bytes. As a result, HMACAlgorithm.p...
CVE-2026-79536	Updated - CVSS added	9.1	CRIT				bytebase dbhub v1.2.0 was discovered to contain a SQL injection vulnerability in the /utlis/sql-parser.ts component. This vulnerability allows attackers to access sensitive database information via a crafted SQL statement.
CVE-2026-79537	Updated - CVSS added	9.1	CRIT				metatool-ai MetaMCP through 2.4.22 contains an insecure direct object reference (IDOR) in the MCP transport session dispatch. The session store (getSession in session-lifetime-manager.ts) is keyed only by the client-supplied mcp-session-id header with no owner, namespace, or endpoint binding, and the per-endpoint authorization middleware validates only the URL endpoint's own...
CVE-2026-97689	Updated - Fix/version updated	8.9	HIGH			pip:urllib3	## Impact urllib3's [streaming API](https://urllib3.readthedocs.io/en/2.7.0/advanced-usage.html#streaming-and-i-o) is designed for efficiently handling large HTTP responses by reading the content in chunks, rather than loading the entire response body into memory at once. When decoding a [chunked-transfer-encoded response](https://httpwg.org/specs/rfc9112.html#chunked.encod...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-67993	Updated - CVSS added	8.8	HIGH				basecamp/upright at commit efe4f2e5254ac6e57e45d2261804cca74dbbca3f contains a login cross-site request forgery issue in the static credentials callback.
CVE-2026-71971	Updated - CVSS changed (8.2 → 8.8)	8.8	HIGH				U-Boot before 2026.10-rc3 with CONFIG_IP_DEFRAG enabled contains an out-of-bounds write vulnerability in the __net_defragment() function in net/net.c. Remote attackers can send a crafted IP fragment with non-zero offset and More-Fragments flag set during netboot to corrupt adjacent memory and crash the bootloader.
CVE-2026-74220	Updated - CVSS changed (8.2 → 8.8)	8.8	HIGH				U-Boot before 2026.10-rc5 contains a buffer overflow in nfs_read_reply() function in net/nfs-common.c that allows attackers to corrupt memory by supplying crafted NFS READ reply lengths. A malicious NFS server can exploit signed integer handling to bypass length validation and write far past the destination buffer, crashing the bootloader or corrupting memory.
CVE-2026-74221	Updated - CVSS changed (8.2 → 8.8)	8.8	HIGH				U-Boot before 2026.10-rc5 contains a buffer overflow in nfs_readlink_reply() function in net/nfs-common.c when processing NFS server responses. A malicious NFS server can send crafted READLINK replies with negative or oversized symlink length values to corrupt memory and crash the bootloader.
CVE-2026-94953	Updated - CVSS added	8.8	HIGH				A stack-based buffer overflow vulnerability exists in the web management interface of TOTOLINK N150RT (NTR150) firmware V3.4.0-B20201030. It is reachable through the route /boafm/formAjaxSet using the topicurl=setting/setWiFiRepeaterConfig branch and the ApCliWEPKey field.
CVE-2026-94954	Updated - CVSS added	8.8	HIGH				A stack-based buffer overflow vulnerability exists in the web management interface of TOTOLINK N150RT (NTR150) firmware V3.4.0-B20201030. It is reachable through the route /boafm/formFilter (access-control / URL filter configuration handler) and is triggered by the url request parameter when the addFilterUrl (or addFilterUrlFlag) action flag is set.
CVE-2026-95362	Updated - CVSS added	8.8	HIGH				Cross-site request forgery in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-100700	Updated - CVSS added	8.7	HIGH		0.003		nodemailer before 10.0.6 contains a denial of service vulnerability in the addressparser free-text fallback regex pattern that exhibits quadratic backtracking behavior. Attackers can supply crafted email header values with long whitespace-free runs to block the Node.js event loop for tens of seconds, causing service unavailability.
CVE-2026-102253	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH				iperf3 versions prior to 3.22 contains a denial of service vulnerability that allows unauthenticated remote attackers to crash-loop the server's UDP receive worker into an unrecoverable infinite loop by sending a single crafted control-channel parameter message followed by one 16-byte UDP datagram. Attackers can permanently pin the affected per-stream receive thread at appro...
CVE-2026-103043	Updated - CVSS changed (7.5 → 8.7)	8.7	HIGH				anchorme through 3.0.8 contains a regular expression denial of service vulnerability in the IPv6 host extraction regex due to catastrophic backtracking. Attackers can supply specially crafted input strings with repeated patterns to cause exponential regex engine backtracking, blocking the Node.js event loop and denying service to other requests.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-61519	Updated - CVSS changed (8.8 → 8.7)	8.7	HIGH				Liberu CRM 0.9.1 before 10.0.0 contains a broken access control vulnerability that allows any user holding a pending team invitation to invite additional attacker-controlled accounts with elevated privileges by exploiting a flawed authorization predicate in TeamPolicy::addTeamMember() that grants invitation rights based solely on the existence of a pending invitation email m...
CVE-2026-102911	Updated - CVSS changed (9.9 → 8.6)	8.6	HIGH				A flaw has been found in zosmaai pi-llm-wiki up to 0.11.7. Affected is an unknown function of the file mcp/index.ts of the component wiki_capture_source MCP tool. Executing a manipulation of the argument url can lead to os command injection. The attack can be executed remotely. The exploit has been published and may be used. Upgrading to version 0.11.8 is able to address thi...
CVE-2026-102794	Updated - CVSS changed (9.1 → 8.5)	8.5	HIGH				A vulnerability has been found in Ziroom ZHOME A0101 1.0.1.0. This issue affects some unknown processing of the file /api/ZRnetwork/ping. Such manipulation of the argument url leads to command injection. It is possible to launch the attack remotely. The exploit has been disclosed to the public and may be used. The vendor was contacted early about this disclosure but did not ...
CVE-2026-102875	Updated - CVSS changed (7.8 → 8.5)	8.5	HIGH				VLC media player before 3.0.24 contains a path traversal vulnerability in the skins2 ThemeLoader that fails to validate member names in .vlt skin archives. Attackers can craft malicious skin files with path traversal sequences to write arbitrary files with VLC user privileges, enabling code execution through Lua script injection.
CVE-2026-79403	Updated - CVSS added	8.4	HIGH				An issue in Kilo Code before v7.4.1 allows a local attacker to execute arbitrary code via the permission/allow-everything endpoint
CVE-2026-100702	Updated - CVSS added	8.2	HIGH		0.003		Nodemailer before 10.0.2 fails to properly flatten deeply nested arrays in recipient fields such as to, cc, and bcc, allowing attackers to cause stack exhaustion. Attackers can supply a deeply nested JSON recipient array that triggers recursive Array.toString() conversion, exhausting the call stack and terminating the Node.js process.
CVE-2026-100756	Updated - CVSS added	8.1	HIGH				Incorrect boundary conditions in the Audio/Video: Playback component. This vulnerability was fixed in Firefox ESR 153.4, Thunderbird 157, Thunderbird 140.17, Thunderbird 153.4, Firefox 157, Firefox ESR 115.42, and Firefox ESR 140.17.
CVE-2026-95301	Updated - CVSS added	8.1	HIGH				Missing authorization in Extensions in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass site isolation via a crafted HTML page. (Chromium security severity: High)
CVE-2026-95344	Updated - CVSS added	8.0	HIGH				Race condition in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass site isolation via a crafted Chrome extension. (Chromium security severity: Medium)
CVE-2026-95376	Updated - CVSS added	8.0	HIGH				Externally controlled reference in DevTools in Google Chrome prior to 154.0.8037.57 allowed an adjacent attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-102930	Updated - Fix/version updated	7.7	HIGH			pip:virtualenv	`download_wheel()` runs `pip download` and hands the result straight to the seeder, with nothing checking the bytes it gets back. The embedded pip and setuptools wheels carry a `BUNDLE_SHA256` that virtualenv checks on every load, but a wheel fetched over the network for the periodic-update feature or the `--download` flag had no equivalent verification. A compromised index...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97687	Updated - Fix/version updated	7.6	HIGH			pip:urllib3	## Impact urllib3 supports configuring TLS independently for an HTTPS proxy and the target server. `proxy_ssl_context`, `proxy_assert_hostname`, and `proxy_assert_fingerprint` configure the TLS connection to the proxy. `ssl_context` and the other target-specific TLS parameters configure the connection to the target server. In urllib3 versions 1.26.0 through 2.7.0, these c...
CVE-2026-100241	Updated - CVSS added	7.5	HIGH				Exposure of Sensitive Information to an Unauthorized Actor vulnerability in Wikimedia Foundation Mediawiki - EventBus Extension allows Excavation. This issue affects Mediawiki - EventBus Extension: 1.47.0-alpha.
CVE-2026-100244	Updated - CVSS added	7.5	HIGH				Exposure of Sensitive Information to an Unauthorized Actor vulnerability in Wikimedia Foundation Mediawiki - CentralAuth Extension allows Excavation. This issue affects Mediawiki - CentralAuth Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-102276	Updated - CVSS added	7.5	HIGH		0.004		The brace-expansion library generates arbitrary strings containing a common prefix and suffix. Prior to 1.1.19, 2.1.5, 3.0.7, and 5.0.10, crafted brace patterns can exhaust the native stack in parseCommaParts because parseCommaParts recursively processes the remainder once per brace group and uses push.apply to pass every element of a very large comma-part array as a functio...
CVE-2026-102278	Updated - CVSS added	7.5	HIGH		0.004		The brace-expansion library generates arbitrary strings containing a common prefix and suffix. Prior to 1.1.20, 2.1.6, 3.0.8, and 5.0.11, deeply nested brace groups cause expand_() to recurse once per nesting level at comma-member and single-set expansion sites, exhausting the native stack before output limits can apply and potentially terminating the Node.js process. expand...
CVE-2026-102281	Updated - CVSS added	7.5	HIGH		0.004		Nest is a framework for building scalable Node.js server-side applications. Prior to 11.2.4 and 12.0.2, a single message with a deeply nested object in its pattern can terminate a NestJS microservice using the TCP or RabbitMQ transport. ServerTCP#handleMessage and ServerRMQ#handleMessage pass a client-controlled non-string pattern to JSON.stringify to derive the handler look...
CVE-2026-102728	Updated - CVSS added	7.5	HIGH				Two client-side TLS/DTLS handshake parsers in NetX Secure read fields from a server-supplied message before validating that the message is long enough to contain them. Both are bounded out-of-bounds reads on a remotely reachable path, both are reached from a TLS or DTLS client connecting to a malicious or malformed server, and both have the same shape: the bounds check exist...
CVE-2026-102758	Updated - CVSS added	7.5	HIGH				The `_nx_secure_x509_asn1_tlv_block_parse()` function parses ASN.1 TLV (tag-length-value) blocks out of DER-encoded data. It is the primitive underneath all X.509 certificate parsing in NetX Secure, and therefore runs on certificates supplied by a remote peer during the TLS handshake. The function reads the one-byte ASN.1 tag from the caller's buffer *before* checking tha...
CVE-2026-54873	Updated - CVSS added	7.5	HIGH				Issue summary: QUIC process may keep memory for QUIC packet buffer for much longer period than necessary. Impact summary: Remote peer can exploit this vulnerability by sending maliciously crafted packets, making the local QUIC stack to keep the memory for packet buffers allocated. The time for which the memory remains allocated is entirely under the control of the potential...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102266	Updated - CVSS added	7.4	HIGH		0.002		PyJWT is a Python implementation of JSON Web Token standards. From 2.13.0 until 2.14.0, HMACAlgorithm.from_jwk is affected because PyJWK verification path used the decoded key without applying prepare_key validation. This occurs when a trusted JWK Set contains an oct entry with an empty k value. As a result, an attacker signs an HMAC token with the same zero-length key accep...
CVE-2026-102267	Updated - CVSS added	7.4	HIGH		0.002		PyJWT is a Python implementation of JSON Web Token standards. Prior to 2.14.0, PyJWT PyJWKClient is affected because redirect destinations are not revalidated against the JWKS trust boundary. This occurs when a configured trusted JWKS endpoint returns an attacker-influenced redirect. As a result, PyJWKClient follows the redirect and consumes the redirected response as key ma...
CVE-2026-102271	Updated - CVSS added	7.4	HIGH		0.002		PyJWT is a Python implementation of JSON Web Token standards. From 2.4.0 until 2.14.0, PyJWT HMACAlgorithm.prepare_key is affected because asymmetric-key guard relies on textual markers that are absent from DER encoding. This occurs when an application mixes HMAC and asymmetric algorithms and supplies a DER public key as the shared verification key. As a result, PyJWT uses p...
CVE-2026-102272	Updated - CVSS added	7.4	HIGH		0.002		PyJWT is a Python implementation of JSON Web Token standards. From 2.13.0 until 2.14.0, HMACAlgorithm.prepare_key in jwt/algorithms.py is affected because raw-JWK detector does not normalize accepted Unicode byte-order marks before checking for JSON. This occurs when a public JWK is prefixed with a UTF-8 BOM and used in a mixed-algorithm verification path. As a result, publi...
CVE-2026-102273	Updated - CVSS added	7.4	HIGH		0.002		PyJWT is a Python implementation of JSON Web Token standards. From 2.13.0 until 2.14.0, PyJWT HMACAlgorithm.prepare_key is affected because HMAC key guard only recognizes top-level public JWK forms and misses container representations. This occurs when an application allows HMAC and asymmetric algorithms and passes a public JWK container as the raw key. As a result, public a...
CVE-2026-100288	Updated - CVSS added	7.2	HIGH				Cleartext storage of sensitive information in the database in Devolutions Server 2026.3.5.0 and earlier allows an attacker with read access to the database to obtain external identity provider tokens and active session identifiers via direct inspection of stored records.
CVE-2026-103054	Updated - CVSS vector changed	7.1	HIGH				AiSOC versions before 12.0.0 contain an authorization bypass vulnerability in the MSSP module that allows authenticated users to add arbitrary tenants to portfolios they own. Attackers can submit tenant UUIDs via the add_tenants_to_portfolio endpoint to claim unclaimed tenants and read their security alerts, incidents, and posture metrics without consent.
CVE-2026-74225	Updated - CVSS vector changed	7.1	HIGH				U-Boot before 2026.10-rc5 contains out-of-bounds memory access in dhcp6_parse_options() that fails to validate SERVERID and CLIENTID option lengths from DHCPv6 packets. Attackers on the local network can send crafted DHCPv6 ADVERTISE or REPLY packets during netboot to corrupt memory and crash the bootloader.
CVE-2026-100699	Updated - CVSS added	6.9	MEDI		0.002		Nodemailer is a Node.js email-sending library. In versions >= 9.1.0 and < 10.0.9, the address parser (src/addressparser) mishandles addresses whose local-part is a quoted string and that are followed by RFC 5322 comments, allowing trailing comment-separated domain atoms to be retained in the normalized address. For example, the input "user"@example.com(x)evil.com is parsed t...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-97688	Updated - Fix/version updated	6.9	MEDI			pip:urllib3	### Impact urllib3's streaming API is designed for the efficient handling of large HTTP responses by reading content in chunks instead of loading the entire response body into memory at once. urllib3 can decompress response bodies according to the HTTP `Content-Encoding` header. When streaming a compressed, chunked response, urllib3 first consumes data already buffered by ...
CVE-2026-102310	Updated - CVSS added	6.5	MEDI			google:chrome	Missing authorization in Payments in Google Chrome prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-102320	Updated - CVSS added	6.5	MEDI			google:chrome	Missing authorization in CORS in Google Chrome prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-102330	Updated - CVSS added	6.5	MEDI			google:chrome	Incorrect authorization in Sitelsolation in Google Chrome prior to 154.0.8037.92 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95297	Updated - CVSS added	6.5	MEDI				Missing authorization in Contextual Tasks in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95330	Updated - CVSS added	6.5	MEDI				Improper state validation in Downloads in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95366	Updated - CVSS added	6.5	MEDI				Use of released resource in Core in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-101911	Updated - CVSS vector changed	6.3	MEDI		0.003		ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Prior to 10.7.1, the Address6 constructor, Address6.isValid, and parse code in src/ipv6.ts accept unbounded strings and expand invalid characters through RE_BAD_CHARACTERS into large diagnostics. Material impact occurs only when an application accepts a very large attacker-controlled ...
CVE-2026-101912	Updated - CVSS vector changed	6.3	MEDI		0.004		ip-address is a library for parsing and manipulating IPv4 and IPv6 addresses in JavaScript. Prior to 10.7.1, the isInSubnet and isHostInSubnet methods in src/common.ts compare masked binary strings without validating that both operands use the same IP family. A cross-family containment check whose leading address bits match makes the masked strings compare equal even though ...
CVE-2026-102635	Updated - CVSS changed (3.7 → 6.3)	6.3	MEDI				ImageMagick versions before 7.1.2-32 and 6.9.13-57 contain uninitialized heap memory disclosure in the GIF decoder's application extension handler in coders/gif.c. Attackers can craft malicious GIF files that cause the number parser to read uninitialized heap memory and store contents as image metadata, disclosing sensitive heap information.
CVE-2026-79535	Updated - CVSS added	6.3	MEDI				mbailey VoiceMode <= 8.10.1 is vulnerable to OS Command Injection. The update_config MCP tool (and the "voicemode config set" CLI) writes a caller-supplied value into ~/.voicemode/voicemode.env without shell-safe escaping.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-81872	Updated - CVSS added	6.3	MEDI		0.005		OpenTelemetry-Go is the Go implementation of OpenTelemetry. Prior to version 0.21.0, the go.opentelemetry.io/otel/sdk/log BatchingProcessor can enter a tight CPU loop when attacker-driven log emission fills its asynchronous export buffer while the exporter is backpressured. NewBatchingProcessor wraps the exporter with newBufferExporter(exporter, 1), and the poll loop calls q...
CVE-2026-95375	Updated - CVSS added	6.3	MEDI				Incorrect authorization in BrowserTag in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass web origin policy via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-100238	Updated - CVSS added	6.1	MEDI				Improper Neutralization of Input During Web Page Generation (XSS or 'Cross-site Scripting') vulnerability in Wikimedia Foundation Mediawiki - Flow Extension allows Stored XSS. This issue affects Mediawiki - Flow Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-100243	Updated - CVSS added	6.1	MEDI				Improper Neutralization of Input During Web Page Generation (XSS or 'Cross-site Scripting') vulnerability in Wikimedia Foundation Mediawiki - WikiSEO Extension allows Stored XSS. This issue affects Mediawiki - WikiSEO Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-100245	Updated - CVSS added	6.1	MEDI				Improper Neutralization of Input During Web Page Generation (XSS or 'Cross-site Scripting') vulnerability in Wikimedia Foundation Mediawiki - Wikibase Extension allows Stored XSS. This issue affects Mediawiki - Wikibase Extension: from * before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-102329	Updated - CVSS added	6.1	MEDI			google:chrome	Cross-site scripting in WebUI in Google Chrome prior to 154.0.8037.92 allowed a remote attacker to bypass web origin policy into a privileged page via a crafted HTML page. (Chromium security severity: High)
CVE-2026-103045	Updated - CVSS added	6.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - Refreshed skin allows Stored XSS. This issue affects Mediawiki - Refreshed skin: before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-103046	Updated - CVSS added	6.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in Wikimedia Foundation MediaWiki - WikiLambda extension allows Stored XSS. This issue affects MediaWiki - WikiLambda extension: before 1.46.1.
CVE-2026-103047	Updated - CVSS added	6.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - CentralAuth extension allows Stored XSS. This issue affects Mediawiki - CentralAuth extension: before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-103049	Updated - CVSS added	6.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - Cargo extension allows Reflected XSS. This issue affects Mediawiki - Cargo extension: before 1.46.1.
CVE-2026-103050	Updated - CVSS added	6.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - MassMessage extension allows Stored XSS. This issue affects Mediawiki - MassMessage extension: before 1.46.1, 1.45.5, 1.43.10.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103051	Updated - CVSS added	6.1	MEDI				Improper neutralization of input during web page generation ('cross-site scripting') vulnerability in The Wikimedia Foundation Mediawiki - CentralNotice extension allows Stored XSS. This issue affects Mediawiki - CentralNotice extension: before 1.46.1, 1.45.5, 1.43.10.
CVE-2026-71972	Updated - CVSS changed (5.9 → 6.0)	6.0	MEDI				U-Boot through 2026.10-rc5 contains an out-of-bounds write vulnerability in the video_display_rle8_bitmap function in drivers/video/video_bmp.c. Attackers can supply a crafted RLE8-compressed BMP image to corrupt memory adjacent to the framebuffer and crash the bootloader.
CVE-2026-102274	Updated - CVSS added	5.9	MEDI		0.004		PyJWT is a Python implementation of JSON Web Token standards. From 2.9.0 until 2.14.0, PyJWKSet does not catch the plain ValueError raised for malformed RSA JWK components by RSAAAlgorithm.from_jwk in jwt/api_jwk.py. This occurs when a JWK Set contains a malformed RSA key alongside otherwise usable keys. As a result, one malformed member aborts construction of the entire PyJ...
CVE-2026-79534	Updated - CVSS added	5.9	MEDI				mark3labs mcp-filesystem-server v0.11.1 is vulnerable to Directory Traversal due to an improper link resolution in validatePath (filesystemserver/handler/helper.go). When filepath.EvalSymlinks returns os.IsNotExist for a dangling symlink, the fallback validates only the parent directory and returns the unresolved path, so write_file (and modify_file, copy_file, move_file, cr...
CVE-2026-102938	Updated - Fix/version updated	5.8	MEDI			pip:virtualenv	### Summary `pyvenv.cfg` is a line-based format with no escape syntax. `PyEnvCfg.write()` wrote values verbatim, while `PyEnvCfg._read_values()` parses the file with `str.splitlines()`. A value containing a line boundary therefore became additional configuration lines, and because reading is last-wins, the injected keys replaced any key written earlier in the file. ### Imp...
CVE-2026-102845	Updated - CVSS changed (5.3 → 5.5)	5.5	MEDI				A security vulnerability has been detected in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. This issue affects the function error_reporting of the file index.php of the component HTTP Response. The manipulation leads to information disclosure. The attack may be initiated remotely. The exploit has been disclosed publicly and may be used. This ...
CVE-2026-102874	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI				A vulnerability was identified in HKUDS AnyTool 0.1.0. Affected is the function subprocess.run of the file anytool/local_server/main.py of the component Execute Endpoint. The manipulation of the argument command/shell leads to os command injection. It is possible to initiate the attack remotely. The exploit is publicly available and might be used. The project was informed of...
CVE-2026-102908	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI				A vulnerability was determined in SourceCodester Online Reviewer Management System 1.0. This issue affects some unknown processing of the file /reviewer_0/admins/assessments/examproper/questions-view.php. Executing a manipulation of the argument ID can lead to sql injection. It is possible to launch the attack remotely. The exploit has been publicly disclosed and may be util...
CVE-2026-102909	Updated - CVSS changed (7.3 → 5.5)	5.5	MEDI				A vulnerability was identified in SourceCodester Online Reviewer Management System 1.0. Impacted is an unknown function of the file /reviewer_0/admins/assessments/examproper/btn_functions.php. The manipulation of the argument access_code leads to sql injection. The attack can be initiated remotely. The exploit is publicly available and might be used.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2024-31027	Updated - CVSS added	5.4	MEDI				Cross Site Scripting vulnerability in Greek Universities Network (GUnet) Open eClass Platform v.3.15 allows a remote attacker to execute arbitrary code via the last name, first name, and username parameters in the user registration functionality.
CVE-2026-100822	Updated - CVSS added	5.4	MEDI				Spoofing issue in the Networking: HTTP component. This vulnerability was fixed in Firefox ESR 153.4, Thunderbird 157, Thunderbird 153.4, and Firefox 157.
CVE-2026-100823	Updated - CVSS added	5.4	MEDI				Spoofing issue in the Downloads component in Firefox for Android. This vulnerability was fixed in Firefox 157.
CVE-2026-93332	Updated - CVSS added	5.4	MEDI				Improper access control in the partial connection API in Devolutions Server 2026.3.5.0 and earlier allows an authenticated low-privileged user to read, create, modify, and delete System Vault entries via a crafted API request.
CVE-2026-95287	Updated - CVSS added	5.4	MEDI			google:chrome	Missing authorization in Navigation in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass site isolation via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95290	Updated - CVSS added	5.4	MEDI				Missing authorization in NFC in Google Chrome prior to 154.0.8037.57 allowed a remote attacker who had compromised the renderer process to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-95352	Updated - CVSS added	5.4	MEDI			google:chrome	Incorrect authorization in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass web origin policy via a crafted Chrome extension. (Chromium security severity: Low)
CVE-2026-95370	Updated - CVSS added	5.4	MEDI				Inappropriate implementation in NFC in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass system access restrictions via a crafted HTML page. (Chromium security severity: Medium)
CVE-2026-101917	Updated - CVSS added	5.3	MEDI		0.004		PyJWT is a Python implementation of JSON Web Token standards. Prior to 2.14.0, PyJWT get_signing_key_from_jwt is affected because unknown kid misses force refreshes without a negative cache or minimum refresh interval. This occurs when unauthenticated tokens repeatedly use the same unknown kid or varying kid values absent from the cached JWKS. As a result, each cache miss ca...
CVE-2026-102265	Updated - CVSS added	5.3	MEDI		0.003		PyJWT is a Python implementation of JSON Web Token standards. From 2.13.0 until 2.14.0, PyJWS._load in jwt/api_jws.py is affected because parser catches ValueError but not RecursionError. This occurs when a deeply nested token header reaches json.loads. As a result, RecursionError escapes the documented PyJWT error hierarchy. Consequently, an unauthenticated malformed token ...
CVE-2026-102277	Updated - CVSS added	5.3	MEDI		0.003		The brace-expansion library generates arbitrary strings containing a common prefix and suffix. Prior to 1.1.21, 2.1.7, 3.0.9, and 5.0.12, the expand function handles untrusted {a},b)-shaped patterns with many trailing closing braces by restarting its scan once for each trailing closing brace. The successive full-input rescans with linear working-string growth cause quadratic...
CVE-2026-102879	Updated - CVSS changed (5.0 → 5.3)	5.3	MEDI				ClaraVerse through 0.3.1 contains server-side request forgery protection bypasses in the download_file and scrape_web agent tools. Authenticated users can bypass hostname validation and IPv6 transition address filtering to make the server request internal services and cloud instance metadata endpoints.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103053	Updated - CVSS changed (5.4 → 5.3)	5.3	MEDI				AiSOC versions 9.0.0 before 12.0.0 fail to enforce authentication on the response-action API endpoints when AISOC_DEV_MODE is enabled and AISOC_ACTIONS_SERVICE_TOKEN is empty in the default Docker Compose deployment. Unauthenticated attackers can list response-action integrations, submit and approve actions on behalf of arbitrary principals, and dispatch containment actions ...
CVE-2026-103057	Updated - CVSS changed (4.3 → 5.3)	5.3	MEDI				AiSOC versions 5.1.0 before 12.0.0 contain an authentication bypass vulnerability in the realtime service internal endpoints POST /internal/agent-event and POST /internal/push. Attackers can post arbitrary events with spoofed tenant identifiers to broadcast malicious content over WebSocket and Redis SSE channels or send unauthorized notifications to registered devices.
CVE-2026-35189	Updated - CVSS added	5.3	MEDI				Issue summary: A certificate with many nameRelativeToCRLIssuer CRL distribution points causes disproportionate heap growth when OpenSSL caches X.509 extensions. Impact summary: Receiving a crafted certificate from a malicious peer can lead to significant memory pressure and possible Denial of Service in clients or in servers that solicit client certificates. CWE: CWE-770: ...
CVE-2026-42772	Updated - CVSS added	5.3	MEDI				Issue summary: The QUIC stream reassembly algorithm performance deteriorates progressively as packets are arriving out of order. The worst case has a quadratic complexity proportional to the number of stream frames kept in the buffer for the received stream data. Impact summary: A remote QUIC peer that completes the handshake can create a connection-scoped CPU pressure and ...
CVE-2026-79417	Updated - CVSS added	5.3	MEDI				Improper Access Control in ArgusMonitor.sys in Argotronic eGbr ArgusMonitor 7.4.02 and earlier allows local, low-privileged users to bypass device handle access restrictions via a TOCTOU condition in IRP_MJ_CREATE and send a crafted IOCTL 0x9C4024A8 request, causing denial-of-service.
CVE-2026-81869	Updated - CVSS added	5.1	MEDI		0.002		OpenTelemetry-Go is the Go implementation of OpenTelemetry. From version 1.10.0 until 1.33.0, the sdk/trace/span.go attribute truncation path can fail to enforce AttributeValueLengthLimit for string and string-slice attributes containing the valid Unicode replacement character U+FFFD. safeTruncateValidUTF8 treats the valid replacement rune as invalid UTF-8 and returns the or...
CVE-2026-102269	Updated - CVSS added	4.8	MEDI		0.002		PyJWT is a Python implementation of JSON Web Token standards. Prior to 2.14.0, PyJWT signature segment is affected because signature segment decoding accepts characters outside the canonical Base64URL representation. This occurs when non-Base64URL characters are appended to a valid compact JWS signature segment. As a result, base64url_decode produces the same signature bytes...
CVE-2026-95292	Updated - CVSS added	4.8	MEDI			google:chrome	Incorrect authorization in Safebrowsing in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass system access restrictions via crafted network traffic. (Chromium security severity: Low)
CVE-2026-95300	Updated - CVSS added	4.8	MEDI				Missing authorization in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass system access restrictions via crafted network traffic. (Chromium security severity: Medium)
CVE-2026-95358	Updated - CVSS added	4.4	MEDI				Incorrect authorization in Mobile in Google Chrome on on Android prior to 154.0.8037.57 allowed a local attacker to bypass system access restrictions into a privileged page via a co-installed app. (Chromium security severity: Medium)

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102312	Updated - CVSS added	4.3	MEDI			google:android, google:chrome	UI misrepresentation in Omnibox in Google Chrome on on Android prior to 154.0.8037.92 allowed a remote attacker to spoof address bar via a crafted HTML page. (Chromium security severity: High)
CVE-2026-71974	Updated - CVSS changed (4.8 → 4.3)	4.3	MEDI				U-Boot before 2026.10-rc3 contains an out-of-bounds write vulnerability in read_slotted_partition() that fails to validate image size against partition bounds. Attackers with physical access can supply crafted boot media with oversized headers to write past the load buffer into bootloader memory on devices without Android Verified Boot protection.
CVE-2026-95340	Updated - CVSS added	4.3	MEDI				Incorrect authorization in PictureInPicture in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95342	Updated - CVSS added	4.3	MEDI				Missing authorization in V8 in Google Chrome prior to 154.0.8037.57 allowed a remote attacker to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-95361	Updated - CVSS added	4.3	MEDI				Confused deputy in DevTools in Google Chrome prior to 154.0.8037.57 allowed a remote attacker leveraging social engineering to bypass web origin policy via a crafted HTML page. (Chromium security severity: Low)
CVE-2026-35191	Updated - CVSS added	3.7	LOW				Issue summary: The OpenSSL QUIC server, when configured to not preform address validation, can be forced to count incoming packets multiple times in its unvalidated credit computation, leading to a violation of the RFC 9000 unvalidated connection amplification limit of 3 times the amount of data received. Impact summary: A remote attacker able to spoof packets to a server u...
CVE-2026-102279	Updated - CVSS added	3.1	LOW		0.002		Laravel is a web application framework. Prior to 12.69.0 and 13.30.0, Laravel exception debug pages with APP_DEBUG=true pass attacker-controlled input to a Tippy.js tooltip configured with allowHTML true, enabling DOM-based cross-site scripting when a user hovers over the tooltip. This issue is fixed in versions 12.69.0 and 13.30.0.
CVE-2026-97711	Updated - Fix/version updated	2.3	LOW			npm:serialize-javascript	### Impact `serialize-javascript` escapes its output so it is safe to embed inside a ` <script>` element. In 7.1.1 that guarantee does not hold for function values: a crafted function body can carry a literal, unescaped `<script>` into the output, terminating the script element early so the remainder is parsed as HTML. `SCRIPT_CLOSE_REGEXP` used `<script[^>]*>` as it...</td></tr> <tr> <td>CVE-2026-102842</td><td>Updated - CVSS changed (6.3 → 2.1)</td><td>2.1</td><td>LOW</td><td></td><td></td><td></td><td>A vulnerability was identified in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. Affected by this issue is the function app_user_login_model.php::cekUserLogin of the file application/models/app_user_login_model.php of the component KCFinder File Manager. Such manipulation of the argument ADMIN_RS_KCFINDER leads to unrestricted upload. It is po...</td></tr> <tr> <td>CVE-2026-102847</td><td>Updated - CVSS changed (4.3 → 2.1)</td><td>2.1</td><td>LOW</td><td></td><td></td><td></td><td>A flaw has been found in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. The affected element is the function kirim of the file application/modules/web/controllers/buku_tamu.php of the component Guest Book. This manipulation of the argument nama/email/pesan causes cross site scripting. Remote exploitation of the attack is possible. The exploit ...</td></tr> </table> </div></script>

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102877	Updated - CVSS changed (4.4 → 2.1)	2.1	LOW				Fider before 0.38.0 contains a server-side request forgery vulnerability due to a time-of-check time-of-use gap in URL validation for webhooks and custom OAuth provider endpoints. Administrators controlling DNS can perform DNS rebinding attacks to make the Fider server send requests to internal services or cloud metadata endpoints.
CVE-2026-102771	Updated - CVSS changed (4.7 → 2.0)	2.0	LOW				A security vulnerability has been detected in Naichen ThinkCMF up to 8.0.7. Affected by this issue is the function MailController::templatePut of the file cmf-api/src/admin/controller/MailController.php of the component Email Template. The manipulation leads to improper neutralization of special elements used in a template engine. The attack is possible to be carried out rem...
CVE-2026-102844	Updated - CVSS changed (2.7 → 2.0)	2.0	LOW				A weakness has been identified in gedelumbung HospitalManagement up to c2d45543789a3887067d3915f69d44cfc2cf76a8. This vulnerability affects the function detail of the file application/modules/admin/controllers/laporan_data_pasien.php. Executing a manipulation of the argument id_param can lead to authorization bypass. The attack can be launched remotely. The exploit has been ...
CVE-2026-102912	Updated - CVSS changed (4.7 → 2.0)	2.0	LOW				A vulnerability was identified in SourceCodester Online Leave Management System 1.0. This issue affects some unknown processing of the file /admin/?page=reports. The manipulation of the argument date_start/date_end leads to sql injection. Remote exploitation of the attack is possible. The exploit is publicly available and might be used.
CVE-2026-102621	Updated - CVSS changed (3.3 → 1.9)	1.9	LOW				A vulnerability was identified in Freedesktop Poppler up to 26.08.0. Affected is the function SplashClip::clipToPath of the file splash/SplashClip.cc. Such manipulation leads to integer overflow. The attack can only be performed from a local environment. The exploit is publicly available and might be used. Upgrading to version 26.09.0 is able to address this issue. The name ...
CVE-2026-102601	Updated - CVSS changed					composer:league/flysystem	## Related public issue (context, not a duplicate) Closed issue #1429 ("Handle non-UTF-8 paths", 2024-03-24) raised exactly this general concern and even suggested detection via `preg_match('/u', \$path) !== 1` -- note the reporter's suggested check explicitly compares `!== 1`, which *would* correctly treat PCRE's `false` return as "reject." The maintainer's reply pointed t...
CVE-2026-102820	Updated - Fix/version updated					rust:pageant	## Summary `MemoryMap::read` in the `pageant` crate (part of the russh workspace, used by russh's SSH-agent client on Windows via `AgentClient::connect_pageant`) copies a **peer-controlled** number of bytes out of an 8192-byte shared-memory view with **no bounds check** — unlike the sibling `MemoryMap::write`, which correctly rejects oversize access with `Error::Overflow`. ...
CVE-2026-102821	Updated - Fix/version updated					rust:russh	## Summary A russh **server** can be driven to unbounded heap growth (process OOM / kill) by a peer that speaks only standard SSH messages, in the **default configuration**. The peer starts a key re-exchange (sends `SSH_MSG_KEXINIT`) but never sends the follow-up `SSH_MSG_KEX_ECDH_INIT`, leaving the server's kex state machine in `SessionKexState::InProgress` **indefinitely...
CVE-2026-102822	Updated - Fix/version updated					rust:russh	#### Summary `SshBlockCipher` implementations (AES-CBC, AES-CTR, 3DES-CBC, etc.) report `needs_mac() == true`, meaning they are documented/intended to always be paired with a separate integrity MAC. However, key-exchange negotiation only checks `needs_mac()` inside the *fallback* branch of MAC algorithm selection (used when no common MAC algorithm exists). If both peers' pref...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102823	Updated - Fix/version updated					rust:russh	### Summary CVE-2026-68930 was fixed by adding `Session::is_established_channel()` in `russh/src/server/encrypted.rs`, which gates every channel-scoped SERVER-side message (CHANNEL_REQUEST, CHANNEL_DATA, CHANNEL_EOF, CHANNEL_CLOSE, CHANNEL_WINDOW_ADJUST, CHANNEL_EXTENDED_DATA) on `enc.channels.get(&channel).is_some_and( c  c.confirmed)` before invoking any `Handler` callback...
CVE-2026-102824	Updated - Fix/version updated					rust:russh	## Vulnerability The hybrid ML-KEM 768 + X25519 key exchange implementation in `russh/src/kex/hybrid_mlkem.rs` does not validate that the remote peer's X25519 public key is not the zero point (all-zero 32-byte value). This allows a remote peer to force the X25519 contribution to the combined shared secret to zero, reducing the hybrid KEX to a single-algorithm exchange. Aff...
CVE-2026-102825	Updated - Fix/version updated					rust:russh	#### Details ##### Affected versions and vulnerable location - Confirmed present on default branch `main` at HEAD `0089c89c94753bebbec12b956c07a1cd38740379`. - Crate version at HEAD: `0.62.4`. - Vulnerable locations on current default branch: - `russh/src/server/mod.rs:91` (`pub max_auth_attempts: usize`) - `russh/src/server/mod.rs:121` (default `max_auth_attempts: 10`) ...

Added to CISA KEV today

None in this window.

P1 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-76504	New	9.8	CRIT	Yes		cisco:catalyst_sd-wan_manager	A vulnerability in the API session-based authentication management of Cisco Catalyst SD-WAN Manager could allow an unauthenticated, remote attacker to access an affected system with privileges of the admin user. This vulnerability is due to improper handling of URI encoding in an HTTP request, which allows the request to bypass an authentication rule that is intended to r...

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102427	New	10.0	CRIT				Joomla Extension - ordasoft.com - Unauthenticated Remote Code Execution in OrdaSoft Joomla CCK < 8.3.16 - site/uploader.php is reached through the component's normal frontend routing (task=getContent), a task with no authentication or ACL check anywhere in the dispatch chain. The handler validates the uploaded file's content with a real magic-byte MIME check, but the extensi...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-55107	New	10.0	CRIT				Kobako is a Ruby gem that embeds a Wasm-isolated mruby interpreter inside applications, allowing execution of untrusted Ruby scripts (LLM-generated code, user formulas, student submissions, third-party plugins) in-process without giving them access to host memory, files, network, or credentials. From version 0.1.0 to before version 0.9.1, a guest mruby script running inside ...
CVE-2026-76570	New	10.0	CRIT				Joomla Extension - joomcode.com - Unauthenticated SQL injection in read and write queries in JCTables 1.21.1 - The front-end CRUD API controller performs no Joomla token validation and no authentication check on any task. Table names, column names, and values are taken directly from request parameters and concatenated into SQL queries, allowing SQLi for reading and writing ...
CVE-2026-96349	New	10.0	CRIT				Unauthenticated Remote Code Execution (RCE) in SiteSkite <= 2.1.8 versions.
CVE-2026-100512	New	9.8	CRIT				Contributor PHP Object Injection in Nested Pages <= 3.3.2 versions.
CVE-2026-102115	New	9.8	CRIT				Kiteworks Core did not correctly validate a parameter submitted to the password reset workflow. An unauthenticated attacker who knew the email address of a user with a locally stored password could potentially reset that account's password without access to the emailed reset link and then authenticate as that user, including where the account holds administrative privileges.
CVE-2026-18782	New	9.8	CRIT				Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Trex Digital Smart Manufacturing Systems Inc. Trex MES allows Command Line Execution through SQL Injection. This issue affects Trex MES: through 2026-09-29.
CVE-2026-55494	New	9.8	CRIT				Tugtainer is a self-hosted app for automating updates of Docker containers. Prior to version 1.30.4, Tugtainer Agent allows unauthenticated access to Docker management APIs when AGENT_SECRET is not configured. The Agent uses request signatures to protect its API routes. However, in agent/auth.py, the signature verification function returns successfully if Config.AGENT_SECRET...
CVE-2026-82307	New	9.8	CRIT				Improper neutralization of special elements used in an SQL command ('SQL injection') vulnerability in Dolusoft Software Technologies SOPLOG allows SQL Injection. This issue affects SOPLOG: before Soplog 2026.9.4.1.
CVE-2026-88920	New	9.8	CRIT				An authentication bypass in the DOM security processor in Apache WSS4J allows unauthenticated remote attackers to forge authenticated SOAP messages via a crafted unsigned SAML sender-vouches assertion containing an attacker-controlled key. Users are recommended to upgrade to versions 4.0.2 or 3.0.6 or 2.4.4, which fix this issue.
CVE-2026-96350	New	9.8	CRIT				Subscriber Privilege Escalation in Estatik <= 4.3.5 versions.
CVE-2026-97248	New	9.8	CRIT				Unauthenticated PHP Object Injection in Booking Activities <= 1.18.7.1 versions.
CVE-2026-97274	New	9.8	CRIT				Unauthenticated Bypass Vulnerability in OAuth Single Sign On – SSO (OAuth Client) <= 7.1.2 versions.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102149	New	9.4	CRIT				Kiteworks Email Protection Gateway did not sufficiently restrict which account a certificate could be assigned to. This could allow an attacker to associate a certificate with another user's account, affecting the confidentiality and integrity of that account's encrypted mail and, where certificate-based login is enabled, potentially permitting unauthorized access to the acc...
CVE-2026-102489	New	9.4	CRIT				Zammad versions 6.3.0 to 6.5.4 are vulnerable a session hijack vulnerability that leads to remote code execution as the zammad user. The vulnerability is also present in version 7.0.0 to version 7.1.3, but not exploitable due to environment conditions.
CVE-2026-102490	New	9.4	CRIT				All versions of Zammad including the latest alpha enable the local zammad user to escalate privileges to root.
CVE-2026-14157	New	9.4	CRIT				Use of an Externally Controlled Format String in the ASUS Router modules allow a remote authenticated user to execute arbitrary commands via a crafted file uploaded through the web management interface.
CVE-2026-55181	New	9.4	CRIT				Tugtainer is a self-hosted app for automating updates of Docker containers. Prior to version 1.30.3, Tugtainer's OIDC authentication can still be initiated even when OIDC_ENABLED=false. The /auth/oidc/enabled endpoint correctly reports that OIDC is disabled. However, a direct request to /auth/oidc/login still starts the OIDC login flow, returns HTTP 302, sets an oidc_state c...
CVE-2026-93903	New	9.4	CRIT				LiteSpeed Web Server (LSWS) before 6.3.7 build 1 mishandles internal redirect URL validation in a certain "corner case."
CVE-2026-102147	New	9.3	CRIT				A stored cross-site scripting (XSS) weakness in Kiteworks Core could allow an unauthenticated attacker to store crafted content that later executes arbitrary JavaScript in the authenticated session of an administrator who views the affected page. This could have permitted the attacker to gain full administrative control, including the creation of a new administrative account.
CVE-2026-102455	New	9.3	CRIT				EasyFlow .NET developed by Digiwin has a Insecure Deserialization vulnerability. Unauthenticated remote attackers can execute arbitrary code on the server by sending maliciously crafted serialized content.
CVE-2026-102458	New	9.3	CRIT				EasyFlow .NET developed by Digiwin has a Missing Authentication vulnerability. Unauthenticated remote attackers can obtain other users' plaintext passwords through a specific API.
CVE-2026-103395	New	9.3	CRIT				LightLLM through 1.2.0 visual_only deployments expose an unauthenticated RPyC service with allow_pickle enabled that deserializes attacker-supplied arguments in the remote_infer_images method. Attackers can reach the visual RPyC port and pass objects with __reduce__ methods to execute arbitrary code with service account privileges.
CVE-2026-103470	New	9.3	CRIT				In Internet2 Grouper before 7.5.1 (in some configurations), a user who is allowed to create or edit rules in the User Interface can escalate privileges.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-103475	New	9.3	CRIT				yii2-starter-kit through 4.2.0 exposes the Yii debug and Gii modules to all IP addresses by setting allowedIPs to ["*"] in its default development configuration. Unauthenticated remote attackers can access the debug endpoint to read sensitive data including session cookies and database queries, or access the Gii endpoint to generate and write PHP files into the application d...
CVE-2026-74864	New	9.3	CRIT				sogo_yhn configures SOGo with a parameter that forces the request with HTTP header "x-webobjects-remote-user" to be treated as sent by a verified user without performing password validation. Since Nginx does not strip this header, any client can supply it arbitrarily and gain access as any user, including a privileged user, without providing a password. This issue was fi...
CVE-2026-76142	New	9.3	CRIT				Insufficient authentication and access control on the internal-only IPC SOAP endpoint of the Genian NAC/ZTNA policy server allows an unauthenticated attacker to invoke internal functions
CVE-2026-82824	New	9.3	CRIT				Hitachi Coding Software Suite contains a vulnerability related to Path Traversal vulnerability that allows an attacker to access, create, modify, or delete files. This issue affects Hitachi Coding Software Suite: through 3.3.0.
CVE-2026-82825	New	9.3	CRIT				Hitachi Coding Software Suite contains a vulnerability related to Missing Authentication for Critical Function. This allows an unauthenticated attacker to invoke a critical API, potentially leading to unauthorized retrieval or alteration of sensitive information, or unauthorized manipulation. This issue affects Hitachi Coding Software Suite: through 3.3.0.
CVE-2026-82827	New	9.3	CRIT				Hitachi Coding Software Suite contains a vulnerability related to Use of Hard-coded Cryptographic Key. The Hardcoding of JWT signing secret key allows an attacker to generate unauthorized Bearer tokens and exploit administrative functions. This issue affects Hitachi Coding Software Suite: through 3.3.0.
CVE-2026-82829	New	9.3	CRIT				Hitachi Coding Software Suite contains a vulnerability related to Hidden Functionality vulnerability which allows an attacker to gain unauthorized access by exploiting hidden accounts or hard coded credentials. This issue affects Hitachi Coding Software Suite: through 3.3.0.
CVE-2026-96822	New	9.3	CRIT				Unauthenticated SQL Injection in Books Gallery <= 4.8.3 versions.
CVE-2026-101276	New	9.2	CRIT				iperf3 3.21 (esnet/iperf) contains a remote, unauthenticated heap use-after-free: the server's per-test watchdog server_timer_proc() frees streams without cancelling/joining their worker threads, so a blocked worker dereferences a freed iperf_stream; fixed in 3.22.
CVE-2026-101283	New	9.2	CRIT				iperf3 3.20–3.21 (esnet/iperf) has a pre-auth heap buffer overflow in decrypt_rsa_message(): a 256-byte RSA buffer is BIO_read with the attacker-controlled ciphertext length (guard warns only), so an unauthenticated client overflows the heap via an oversized authtoken; fixed in 3.22

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102508	New	9.2	CRIT				Improper Verification of Cryptographic Signature and Improper Certificate Validation in the OPC UA driver of Apache PLC4X (PLC4J) allows an attacker in a network position between client and server to impersonate the OPC UA server and to read, forge or modify secure-channel traffic, including user credential ssent by the client. The defect manifests differently depending on ...
CVE-2026-102992	New	9.2	CRIT				piscina is a node.js worker pool implementation. Prior to 4.9.4, 5.3.2, and 6.0.0-rc.5, Piscina stores ThreadPool.options in src/index.ts as a plain object that inherits from Object.prototype. Applications with a separate prototype-pollution primitive can therefore supply inherited values for security-sensitive options that do not have own defaults. An inherited execArgv val...
CVE-2026-103547	New	9.2	CRIT				In ldapd in OpenBSD 7.8 before errata 057 and 7.9 before errata 021, delegated BSD authentication results are correlated only by the LDAP child process client file descriptor and LDAP message ID. After a connection closes, a later connection that reuses the same file descriptor and message ID can receive the earlier authentication result. A remote attacker who can reach ldap...
CVE-2026-19445	New	9.2	CRIT				A remote, unauthenticated TLS client can make a server crash or call through a freed pointer if its sni_callback assigns a different context to SSLSocket.context (the documented way to select a certificate per server name) and nothing else keeps the original ssl.SSLContext alive. Typical cases are servers that create an SSLContext per connection or replace it while connectio...
CVE-2026-74865	New	9.2	CRIT				sogo_yhn configures SOGo with a parameter "SOGoTrustProxyAuthentication=YES". This causes the password to be bypassed during HTTP Basic authentication. An unauthenticated attacker who provides the username of an existing user and any arbitrary password can successfully log in to that user's account. This issue was fixed in version 5.8.0-ynh9.
CVE-2026-102095	New	9.1	CRIT				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Server-Side Request Forgery. Kiteworks Email Protection Gateway performed server-side fetches of URLs contained in the message content it processed, without adequately restricting the fetch destination. A remote, unauthenticated sender could craft a message that caused the gateway to issue requests to i...
CVE-2026-102102	New	9.1	CRIT				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Server-Side Request Forgery (SSRF). A server-side request forgery (SSRF) weakness in Kiteworks Email Protection Gateway could allow a remote, unauthenticated attacker to induce the gateway to issue crafted requests to internal or otherwise unintended network destinations. The requests are triggered whil...
CVE-2026-102103	New	9.1	CRIT				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Server-Side Request Forgery (SSRF). A server-side request forgery (SSRF) weakness in Kiteworks Email Protection Gateway could allow a remote, unauthenticated attacker to induce the gateway to issue crafted requests to internal or otherwise unintended network destinations. The requests are triggered whil...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-102104	New	9.1	CRIT				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Server-Side Request Forgery (SSRF). A server-side request forgery (SSRF) weakness in Kiteworks Email Protection Gateway could allow a remote, unauthenticated attacker to induce the gateway to issue crafted requests to internal or otherwise unintended network destinations. The requests are triggered whil...
CVE-2026-102105	New	9.1	CRIT				Kiteworks Email Protection Gateway before version 9.5.0 is vulnerable to Server-Side Request Forgery (SSRF). A server-side request forgery (SSRF) weakness in Kiteworks Email Protection Gateway could allow a remote, unauthenticated attacker to induce the gateway to issue crafted requests to internal or otherwise unintended network destinations. The requests are triggered whil...
CVE-2026-102106	New	9.1	CRIT				Improper authentication in a Kiteworks Email Protection Gateway administrative service. An administrative service in Kiteworks Email Protection Gateway did not consistently enforce administrator authentication, so the required password check could be bypassed. An attacker who referenced a valid administrator account could potentially create, modify, or delete internal users ...
CVE-2026-62308	New	9.1	CRIT				Tugtainer is a self-hosted app for automating updates of Docker containers. Prior to version 1.30.6, Tugtainer allows an authenticated user to make the backend server send outbound HTTP requests to arbitrary user-supplied URLs through the notification test endpoint. The /settings/test_notification endpoint accepts a urls field and passes it directly to Apprise without restri...
CVE-2026-75969	New	9.1	CRIT				Missing authentication for critical function vulnerability for all PTZOptics cameras and the Firmware Upgrade Tool - Firmware Update modules. A missing authentication vulnerability in the firmware update mechanism of affected PTZOptics cameras allows an unauthenticated user to install modified firmware on the device without administrator credentials. This vulnerability al...
CVE-2026-77185	New	9.1	CRIT				Authentication bypass in sshd-core in Apache MINA SSHD versions 2.0.0 to 2.19.0 and 3.0.0-M1 to 3.0.0-M5 for a certain (presumed rare) way to implement an SSH server. Apache MINA SSHD is a Java library for client- and server-side SSH. In the server part of the library, a mechanism to perform "asynchronous authentication" exists. A server implemented with Apache MINA SSHD...
CVE-2026-87830	New	9.1	CRIT				In the StAX streaming WS-SecurityPolicy validator, certain relative or unsupported XPath expressions can be converted into paths that never match the actual XML element path. A remote SOAP peer may therefore send a required element without the expected signature or encryption. Users are recommended to upgrade to versions 4.0.2 or 3.0.6 or 2.4.4, which fix this issue.
CVE-2026-89238	New	9.1	CRIT				WSS4J EncryptedHeader child confusion could promote an attacker-controlled plaintext element as the decrypted header, leading to incorrect confidentiality coverage and possible policy bypass. Users are recommended to upgrade to versions 4.0.2 or 3.0.6 or 2.4.4, which fix this issue.
CVE-2026-92966	New	9.1	CRIT				The The Appointment Booking Plugin – LatePoint Calendar & Scheduling for WordPress plugin for WordPress is vulnerable to arbitrary shortcode execution in all versions up to, and including, 5.7.0. This is due to the software allowing users to execute an action that does not properly validate a value before running do_shortcode. This makes it possible for unauthenticated att...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-94052	New	9.1	CRIT				A missing check in LdapPasswordAuthenticator in component sshd-ldap in Apache MINA SSHD versions 1.2.0 to 2.19.0 or 3.0.0-M1 to 3.0.0-M5 bypassed authentication checks. Apache MINA SSHD is a Java library for client-side and server-side SSH. The optional sshd-ldap component provides support for integrating password and publickey authentication on the server side with an L...
CVE-2026-94053	New	9.1	CRIT				Authentication bypass via LDAP injection in component sshd-ldap in Apache MINA SSHD versions 1.2.0 to 2.19.0 and 3.0.0-M1 to 3.0.0-M5. Apache MINA SSHD is a Java library for client-side and server-side SSH. The optional sshd-ldap component provides support for integrating password and publickey authentication on the server side with an LDAP server. sshd-ldap is an...
CVE-2026-97196	New	9.1	CRIT				Improper Validation of Unsafe Equivalence in Input vulnerability in Liquid Web / StellarWP GiveWP allows Authentication Bypass. This issue affects GiveWP: from n/a through 4.16.9.
CVE-2026-55176	New	9.0	CRIT				Soft Machine is a Virtual Machine–based agentic development environment / Cloud OS. In versions 0.2.247 and prior, two authentication helpers in /app/server.js — verifyContainerAuth() and authenticateWorkspaceHttp() — accept the global CONTAINER_SHARED_SECRET as a bearer token without verifying which workspace the caller belongs to. Because that secret is set identically on ...
CVE-2026-94389	New	9.0	CRIT				Unauthenticated Remote Code Execution (RCE) in AcyMailing SMTP Newsletter <= 11.0.5 versions.

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.